

2025 年网络安全报告

主要威胁、新兴趋势和 CISO 建议

目录

01

引言

02

2024 年网络安全事件

03

网络安全趋势

04

全球分析

05

备受瞩目的全球漏洞

06

事件响应视角

07

2025 年行业预测

08

CISO 建议



引言

2025 年网络安全状况



01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议

引言

我很高兴为您介绍 Check Point《网络安全报告》，这也是我们连续第 13 年度出版这个报告。2024 年，诸如人工智能和云基础设施之类的进步改善了我们的日常生活，但也给网络犯罪分子带来了可乘之机。本报告重点强调了这些变化对现实世界的影响，并给 CISO 提供关于 2025 年的网络安全趋势和切实可行的建议。

手握十多年的分析经验，Check Point 研究院的见解有着其它公司无法比拟的数据资源和专业分析团队组合。我们从企业和中小企业客户的网络、云、电子邮件、终端和移动设备收集攻击遥测数据。通过结合事件响应、暗网和开源发现，我们在 170 多个国家/地区实现了可见性，以揭示全球和地区趋势。

《2025 年网络安全报告》重点强调了关键威胁，包括：

- 通过虚假信息影响了全球三分之一选举的人工智能策略。
- 信息窃取攻击猛增 58%，主要针对企业访问权限。
- 勒索软件攻击从加密转向数据窃取勒索，医疗保健行业现已成为第二大攻击目标。
- 混合网络使得本地和云端之间能够转换和移动。
- 硬件和软件供应链遭受的攻击猛增幅度最大

我想强调 Check Point 对客户安全的承诺。在 2024 年，边缘设备遭到利用，通过泄露的凭证和漏洞访问企业网络。众多被披露的零日漏洞之一出现在 Check Point 的一款产品中：VPN 信息披露漏洞 (CVE-2024-24919)。我们迅速披露了该漏洞，在一天内发布了补丁，并积极为少数可能受影响的客户提供事件响应和缓解支持。保护客户是我们无可动摇的职责。

虽然 Check Point 旨在通过我们的研究来保护我们的客户，但我们也希望这份报告能够满足更广泛行业的需求，把我们专业团队所获得的信息和分析分享给您。我代表 Check Point 大家庭，希望这份报告能使安全从业者和 C-level 高管受益匪浅。

祝您阅读愉快！

Maya Horowitz，研究副总裁

MAYA HOROWITZ

研究副总裁





2024 年网络安全 安全事件

2025 年网络安全状况

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

定义 2024 年的网络安全事件

一月

在披露了两个零日漏洞后，Ivanti 的 Connect Secure VPN 面临大规模的漏洞利用。数以千计的 VPN 设备遭到入侵，众多受害者受到了影响，如美国网络安全与基础设施安全局 (CISA)。

Check Point 研究院发现了一个针对 100 多个热门项目持有者的 NFT 骗局。诈骗者发送看似合法的空投，这些空投链接到欺诈性网站。受害者被诱骗并连接到他们的资金账户，攻击者由此就可以窃取受害者的资金。

微软报告称遭到了 Midnight Blizzard (Nobelium) 组织的攻击，该组织使用密码攻击入侵了公司的电子邮件帐户，包括高层领导、网络安全和法务人员的帐户等。

Harmony Endpoint 终端安全防御平台和威胁萃取方案能够防范这种威胁 (APT.Win.APT29; APT.Wins.Nobelium)

HealthEC LLC 经历了一次数据泄露事件，该事件影响了 450 万人，他们的姓名、地址、出生日期、社会安全号码、医疗和账单信息以及健康保险数据都遭到了泄露。

二月

谷歌 Chrome 浏览器的 V8 JavaScript 引擎中已确认存在一个高严重性漏洞 CVE-2024-0517。该漏洞可能允许远程攻击者通过特制的 HTML 页面进行损坏。后来，谷歌修补了该漏洞。

Check Point Harmony IPS 能够防范这种威胁 (谷歌 Chrome 越界写入 (CVE-2024-0517))

Check Point 研究院发现了微软 Outlook 中的一个严重的远程代码执行 (RCE) 漏洞，被称为 #MonikerLink (CVE-2024-21413)。#MonikerLink 允许远程攻击者部署一个绕过受保护视图协议的链接，这有可能导致凭证泄露和 RCE 能力。后来，微软修补了该漏洞。

Check Point IPS 刀片能够防范这种威胁 (Microsoft Outlook 恶意 Moniker Link 远程代码执行 (CVE-2024-21413))

美国司法部破坏了 APT Volt Typhoon 在针对美国关键基础设施时用来掩盖身份的 KB 僵尸网络。该组织利用易受攻击的、没有维保和技术支持的思科和 SOHO 设备来获取初始访问权限。作为回应，CISA 和 FBI 为供应商发布了关于保障 SOHO 路由器安全的指南。

Check Point 威胁萃取方案能够防范这种威胁 (APT.Wins.VoltTyphoon; InfoStealer.Wins.VoltTyphoon)

第一季度

三月

ALPHV 勒索软件团伙攻击了 UnitedHealth Group (联合健康集团) 的子公司，窃取了 6 太字节的数据。这导致美国在全球的军事诊所和医院业务中断，不得不临时采用人工处方流程。

Check Point 威胁萃取方案和 Harmony Endpoint 终端安全防御平台能够防范这种威胁 (Ransomware.Wins.BlackCat.ta.*; Ransomware.Win.BlackCat)

一项由人工智能驱动的照片和视频编辑服务 Cutout.Pro 经历了一次数据泄露事件，致使 2000 万用户的个人数据被暴露，包括电子邮件地址、哈希密码和 IP 地址。

某 APT 组织在一场网络间谍活动中瞄准了全球 70 个政府实体，该活动自 2022 年初以来一直活跃，利用的是面向互联网的服务器中的漏洞和鱼叉式网络钓鱼策略。

Check Point 研究院追踪了受经济利益驱动的威胁行为者 Magnet Goblin，它利用了诸如 Ivanti Connect Secure VPN、Magento 和 Qlik Sense 等服务器中的 一日漏洞。并部署了新的 Linux 版本的 NerbianRAT 和 WARPWIRE JavaScript 凭证窃取程序，这同时也证明该漏洞很容易被威胁攻击者快速利用。

Check Point IPS 和 Harmony Endpoint 终端安全防御平台能够防范这种威胁 (RAT_Linux_Nerbian_*)

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

定义 2024 年的网络安全事件

四月

Check Point 的研究人员检测到了一场域名仿冒活动，该活动由部署在 PyPI（Python 包索引）上的 500 多个恶意软件包组成，存在 PII 盗取恶意软件安装的风险。

Check Point CloudGuard Code Security 能够防范这种威胁。

黑客活动组织 RGB-TEAM在 Telegram 上泄露了近十年的 10 万份犯罪记录。数据包括盗窃和贩毒等犯罪的详细信息。

AT&T 发生数据泄露事件，约 5100 万名前任和现任客户的个人信息被曝光，可能包括全名、家庭住址、电子邮件地址、电话号码、社会安全号码、AT&T 帐户号码和 AT&T 密码。

Check Point 研究院报告称，出现了一波诈骗攻击浪潮，攻击者使用各种方法，包括恶意二维码和钓鱼邮件，获取美国纳税人的凭证以窃取美国国税局的退税。

美国和英国宣布对黑客组织 APT31 提起刑事诉讼并实施制裁，因其涉嫌对美英政府官员发动攻击。Check Point 研究院探讨了该组织对零日漏洞的利用。

五月

Check Point 研究院发现了一场网络间谍活动，其目标是非洲和加勒比地区的政府组织。该活动归因于威胁行为者采用 Cobalt Strike Beacon 作为有效载荷，实现了诸如 C2 通信和命令执行等后门功能，同时最大限度地减少了其自定义工具的暴露。这种方法表明他们对目标有更深入的了解。

捷克共和国、德国和北约披露了一场针对捷克机构的间谍活动，该活动通过微软 Outlook 的一个漏洞进行，此漏洞归因于 APT28组织，该组织一直在欧洲进行长期的间谍活动。

戴尔发生数据泄露事件，影响了 4900 万客户，此前其数据库被列在一个黑客论坛上。被曝光的数据包括全名、家庭住址和订单详情。

一次数据泄露事件曝光了来自印度的 500GB 生物识别数据，在选举期间影响了警察、军人和公职人员。此次泄露涉及 ThoughtGreen Technologies 和 Timing Technologies 未受保护的数据库，包括指纹和面部扫描数据。这些信息可能被用于操纵印度选举中的生物识别系统。

第二季度

六月

臭名昭著的网络犯罪团伙 ShinyHunters 在一个网络犯罪论坛上出售来自 Ticketmaster 和桑坦德银行的数据。此次数据泄露可能导致数百万客户的个人信息被曝光。有报告指出，该威胁行为者通过使用大型云存储公司 Snowflake 一名员工被盗的凭证，获取了 Ticketmaster 和桑坦德银行的访问权限。

日本加密货币交易所 DMM Bitcoin 证实发生了数据泄露事件，导致价值 3.08 亿美元的 BTC 损失，这是最大的加密货币盗窃案之一。

Water Sigbin 8220 团伙利用了 Oracle WebLogic 中的漏洞（CVE-2017-3506 和 CVE-2023-21839），使用具有十六进制 URL 编码和无文件执行技术的 PowerShell 脚本部署了加密货币挖矿恶意软件。

Check Point IPS 能够防范这种威胁（Oracle WebLogic WLS 安全组件远程代码执行 (CVE-2017-10271)、Oracle WebLogic 服务器不当访问控制 (CVE-2023-21839)）

Check Point 研究院分析了 Rafel RAT，这是一种用于对安卓设备进行间谍活动和勒索软件攻击的开源远程管理工具。该恶意软件针对知名组织，尤其是军事领域，受害者主要来自美国、中国和印度尼西亚。它能够实现数据窃取、监控和对设备的完全控制，导致了严重的隐私和安全漏洞攻击。

Check Point 的 Harmony Mobile 能够防范这种威胁。

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

定义 2024 年的网络安全事件

七月

Check Point 研究院发现了“[Stargazers Ghost Network](#)”，它由 3000 个 GitHub 存储库组成，通过使用“分发即服务” (DaaS) 模式的网络钓鱼计划来分发恶意软件和恶意链接。该网络共享了各种类型的恶意软件，如 Atlantida Stealer 和 RedLine，并已获得巨额利润。

Check Point Harmony Endpoint 终端安全防护平台和威胁萃取方案能够防范这种威胁 (InfoStealer.Win.Atlantida.*、Trojan.WIN32.AtlantidaStealer*、InfoStealer.Wins.Lumma.ta*、InfoStealer.Win.Lumma*、Injector.Win.RunPE.C、Loader.Wins.GoBitLoader.A、Trojan.Wins.Imphash.taim.LV、InfoStealer.Wins.Redline.ta.BY)

RockYou2024 是一次涉及近 100 亿个明文密码的泄露事件，这些密码来自多次数据泄露，引起了凭证填充和暴力破解攻击的重大风险，可能会影响到各种在线帐户和服务。

在一次勒索软件攻击中，Rite Aid 的 4500 万条记录被盗，据称其中包括客户的身份信息和 Rite Aid 奖励号。RansomHub 勒索软件组织声称对此负责，并威胁要泄露被盗数据。

Check Point 威胁萃取方案和 Harmony Endpoint 终端安全防护平台能够防范这种威胁 (Ransomware.Win.RansomHub; Ransomware.Wins.RansomHub.ta.*)

位置安全应用程序 Life360 和项目管理工具 Trello 因 API 漏洞遭遇数据泄露。Life360 的 442,519 名客户的个人信息被曝光，而 Trello 有 21.1GB 的数据被泄露。威胁行为者“emo”声称对此负责，并在暗网上分享了被盗数据。

八月

Check Point 研究院发现，超过 2 万个 Ubiquiti 摄像头和路由器存在漏洞 (CVE-2017-0938)，容易受到放大攻击和隐私风险的影响，原因是暴露的 UDP 端口 10001 和 7004。这些端口允许未经授权访问设备信息，可能会被用于技术和社会工程攻击。

Check Point 研究院指出，服务器端模板注入 (SSTI) 漏洞有所增加，这些漏洞使攻击者能够执行命令并访问敏感数据。显著的案例包括 Atlassian Confluence 和 CrushFTP。这些漏洞带来了重大风险，如数据窃取和信誉损害，反映在关键 CVE 的增加上

Check Point IPS 能够防范这种威胁 (Python 服务器端模板注入、Java 服务器端模板注入、PHP 服务器端模板注入、Ruby 服务器端模板注入、Node.js 服务器端模板注入、表达式语言服务器端模板注入)

在 7 月某国总统选举之后，Check Point 研究院显示，该国政府有关的选举舞弊指控，黑客活动组织“Cyber Hunters”对政府发起了 DDoS 攻击和黑客攻击尝试。

Harmony Endpoint 终端安全防护平台和威胁萃取方案能够防范这种威胁 (InfoStealer.Wins.PhemedroneStealer.*)

九月

勒索软件组织 RansomHub 从 Planned Parenthood（计划生育协会）的蒙大拿分部窃取了 93GB 的敏感数据，主要影响了该组织的行政 IT 系统。

Check Point 威胁萃取方案和 Harmony Endpoint 终端安全防护平台能够防范这种威胁 (Ransomware.Win.RansomHub; Ransomware.Wins.RansomHub.ta.*)

Check Point 研究院发现了一个网络活动，使用恶意软件 Veaty 和 Spearal 攻击某国政府网络。其技术包括被动式 IIS 后门、DNS 隧道以及通过被入侵的电子邮件进行 C2 通信，这表明与 APT34 组织有关联。该活动可能利用社会工程学进行初始感染，并拥有复杂的 C2 基础设施。

Check Point 威胁萃取方案和 Harmony Endpoint 终端安全防护平台能够防范这种威胁 (APT.Wins.Oilrig.ta.B/C/D/E、APT.Win.OilRig.F、APT.Win.OilRig.WA.G、APT.Win.OilRig.H)

FBI、CISA 以及 NSA 报告称，GRU 29155 部队进行了网站篡改、数据窃取和 WhisperGate 恶意软件攻击，扰乱了援助工作。他们还在全球范围内针对政府、金融、交通、能源和医疗保健等部门。

Check Point 威胁萃取方案和 Harmony Endpoint 终端安全防护平台能够防范这种威胁 (Trojan.Win.WhisperGate; Trojan.Wins.WhisperGate.ta.*; Trojan.Wins.WhisperGate)

ChatGPT 的 macOS 应用程序中存在一个漏洞，使攻击者能够通过间接的提示将持久性间谍软件 SpAIware 植入该应用程序的内存中，从而能够持续窃取用户输入和聊天会话的数据。后来，OpenAI 解决了这个问题。

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

定义 2024 年的网络安全事件

十月

Check Point 研究院分析了“[Operation MiddleFloor](#)”，这是一场在 2024 年 10 月选举前针对摩尔多瓦政府和教育部门的虚假信息活动。“[Lying Pigeon](#)”组织使用伪造的电子邮件来传播有关欧盟成员国身份的虚假信息，同时收集数据以发动潜在的恶意软件攻击。

一个名为 Mamba 2FA 的新的钓鱼即服务平台瞄准了中间人钓鱼攻击。它模仿 Microsoft 365 的登录页面，绕过多因素身份验证，窃取通过 Telegram 机器人发送给攻击者的凭证和 Cookie。

FBI 和 CISA 正在调查与“[Salt Typhoon](#)”组织对美国电信公司（包括 AT&T、Verizon 和 Lumen Technologies）的入侵事件。这些攻击的目标是当选总统特朗普、前副总统哈里斯和其他知名政客的窃听系统和设备。

十一月

FBI、美国财政部以及以色列国家网络安全局 (INCD) 发布了一份联合网络安全公告，指称网络组织 [Emennet Pasargad](#) 发起了一场大规模冒充 INCD 并针对以色列组织的网络钓鱼活动。Check Point 研究院[分析了该恶意软件](#)，追踪了其演变和学习过程。

Check Point 威胁萃取方案和 Harmony Endpoint 终端安全防御平台能够防范这种威胁（[Behavioral.Win.FakeChrome.B](#) 和 [Trojan.Wins.FakeUpdater.A](#)）

Check Point 研究院监测到了一场大规模的网络钓鱼活动，被称为“[CopyRh\(ight\)adamantys](#)”，它使用了最新版本的 Rhadamanthys 窃取程序（0.7 版）。这场网络钓鱼活动以版权为主题，冒充不同的公司，针对美国、欧洲、东亚和南美洲等地区，根据不同的 Gmail 帐户为每封电子邮件量身定制内容。

Check Point 威胁萃取方案和 Harmony Endpoint 终端安全防御平台能够防范这种威胁（[InfoStealer.Wins.Rhadamanthys.ta.V](#)、[InfoStealer.Wins.Rhadamanthys.*](#) 和 [InfoStealer.Wins.Rhadamanthys.*](#)）

Check Point 研究院追踪了“[WIRTE 威胁](#)”行为者，并且在 2024 年已扩展到与针对以色列实体的 SameCoin 恶意软件相关的破坏性攻击。

Check Point 威胁萃取方案和 Harmony Endpoint 终端安全防御平台能够防范这种威胁（[APT.Wins.Wirte.ta.A/B/C/D/E/F](#)、[ransom.win.honey](#) 以及 [infostealer.win.blackguard.d](#)）

第四季度

十二月

Check Point 研究院发现了 [Godot Engine](#)（一个游戏开发平台）的一种新的漏洞利用，该漏洞可执行恶意的 GDScript 代码。该技术使攻击者能够在 Windows、macOS、Linux、Android 和 iOS 等平台上传播恶意软件，同时避开大多数防病毒解决方案的检测。恶意加载程序“[GodLoader](#)”使用了这种技术，并且已经感染了超过 17,000 台机器。

Check Point Harmony Endpoint 终端安全防御平台和威胁萃取方案可以提供强大的防御和保护（[Technique.win.GDscript.*](#)、[Dropper.Win.Godot.*](#)）

Check Point 研究院分析了 [Akira](#) 勒索软件的最新变种，它由 Rust 语言编写，在 2024 年初的攻击目标主要是针对 ESXi 裸金属虚拟机管理程序服务器。该报告展示了如何使用 Rust 的习惯用法、样板代码和编译器策略来创建复杂的勒索软件。

Check Point Harmony Endpoint 终端安全防御平台和威胁萃取方案为抵御这种威胁提供保护（[Ransomware_Linux_Akira_C/D](#)、[Ransomware.Wins.Akira.G/H](#)）



网络安全 趋势

2025 年网络安全状况



01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议

网络战争 2024 版

全球社会长期以来一直在猜测，毁灭性的战争将在网络空间展开，各个国家将部署能够在一次决定性打击中使关键基础设施瘫痪的数字末日武器。然而，尽管网络活动以前所未有的速度升级，但这样的末日事件尚未发生。无论是由于能力有限、对相互毁灭的恐惧，还是不愿意引发不可逆转的混乱，网络战争的性质走上了一条不同的道路。

各国已将重点转向破坏公众信任、利用社会裂痕以及从内部破坏机构稳定的冲突。活动包括在社交媒体上操纵信息，这些网络攻击受国家支持，但“黑客活动分子”团体声称为此负责，并且对受感染网络和安全措施薄弱设备的秘密访问威胁持续存在。

虚假信息影响力行动

2024 年，在人工智能和大型语言模型 (LLM) 融合的推动下，虚假信息宣传活动的复杂程度达到了新的高度。这些活动聚焦于全球事件，许多国家被指控使用先进策略来操纵公众舆论、破坏信任并干扰选举，以破坏民主进程的稳定。

根据 Check Point 研究院的发现，在 2023 年 9 月至 2024 年 2 月期间全球举行的选举中，至少有三分之一使用了人工智能，要么是候选人自己使用，要么可能是外国势力使用。比如组织使用了深度伪造包含政治人物形象的伪造新闻片段。这些内容通过 X（原名 Twitter）和 Facebook 进行传播，利用平台算法针对特定的选民群体。人工智能生成的机器人进一步传播分裂性的叙述，伪装成真实的意见文章来分化选民。

网络攻击活动还通过“黑客攻击和泄露”行动攻击知名政治人物，将目标对准了美国总统选举。记者、活动家和说客也成为了社会工程、冒充、网络钓鱼和凭证收集恶意软件的攻击目标。这些行动展示了将虚假信息 with 网络渗透相结合以影响公众看法的能力。

与此同时，人工智能生成的深度伪造视频，描绘虚假的背书和误导性的公共服务公告。这些视频在 X 和 TikTok 等平台上广泛传播，旨在诋毁候选人并加深党派分歧。此外，带有歪曲的民意调查问题的热门帖子似乎显示了对某些候选人的支持或捏造的欺诈证据，破坏了对选举过程的信任。

除了备受瞩目的美国总统选举外，罗马尼亚的总统选举以及摩尔多瓦的欧盟公投也成为网络驱动虚假信息战的主要目标。攻击者使用人工智能生成的文章和社交媒体帖子来模仿合法的新闻来源，诋毁候选人，左右公众舆论。描绘候选人发表有争

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

议言论的深度伪造视频广泛传播，而具有误导性的民意调查问题表明对特定候选人的支持下降。虚假的社交媒体帐户被利用并被操纵内容以进行干预，推动极右翼候选人当选。在其意外赢得第一轮选举后，解密的情报揭示了外国干预的程度，促使前所未有的选举结果被废除并安排新的投票。在另一个国家，一场名为“Operation MiddleFloor”的活动针对政府和教育部门，使用伪造的电子邮件和文件来传播反欧盟的叙述，并破坏对亲欧领导层的信任。

巴黎奥运会成为虚假信息的另一个重点关注对象。Storm-1679 组织传播了有关腐败、裁判不公和暴力威胁的虚假叙述。自动化帐户和机器人放大了这些言论，以抹黑该赛事。更具攻击性的是，“Emennet Pasargad”组织利用了奥运会显示系统供应商的漏洞来干扰广播，并以虚假身份向运动员发出威胁。

这些对民主国家和北约等西方政治联盟的攻击变得愈发有效和危险，因为民主国家面临着日益增长的挑战。网络文化战争、社交媒体助长的民粹主义以及利用先进算法定制有利内容的政治化媒体平台，为外国势力破坏公众信任创造

了肥沃的土壤。与特定国家的宣传一致或支持其宣传的内容的传播已经扎根，加深了社会分裂。

许多国家已经通过加强监管并将虚假信息视为对关键基础设施的威胁来做出回应。美国国土安全部强调选举干预是一种威胁，而加拿大扩大了 CSIS 法案以促进更好的情报共享。欧盟对 Meta 等平台实施了严格的规定以遏制虚假信息。OpenAI 和微软正在关停与多国的帐户。

破坏性和干扰性恶意软件

各国越来越依赖破坏性恶意软件作为网络战中的重要武器。这些以擦除恶意软件和其它破坏性工具为特征的“高调”行动，以关键基础设施为目标，扰乱其基本服务并制造混乱。

在中东局势日益紧张的情况下，地区威胁组织展示了擦除恶意软件的破坏性潜力。多个黑客活动分子身份为幌子部署了恶意软件，针对国家的关键基础设施和私营组织，擦除数据并扰乱服务。

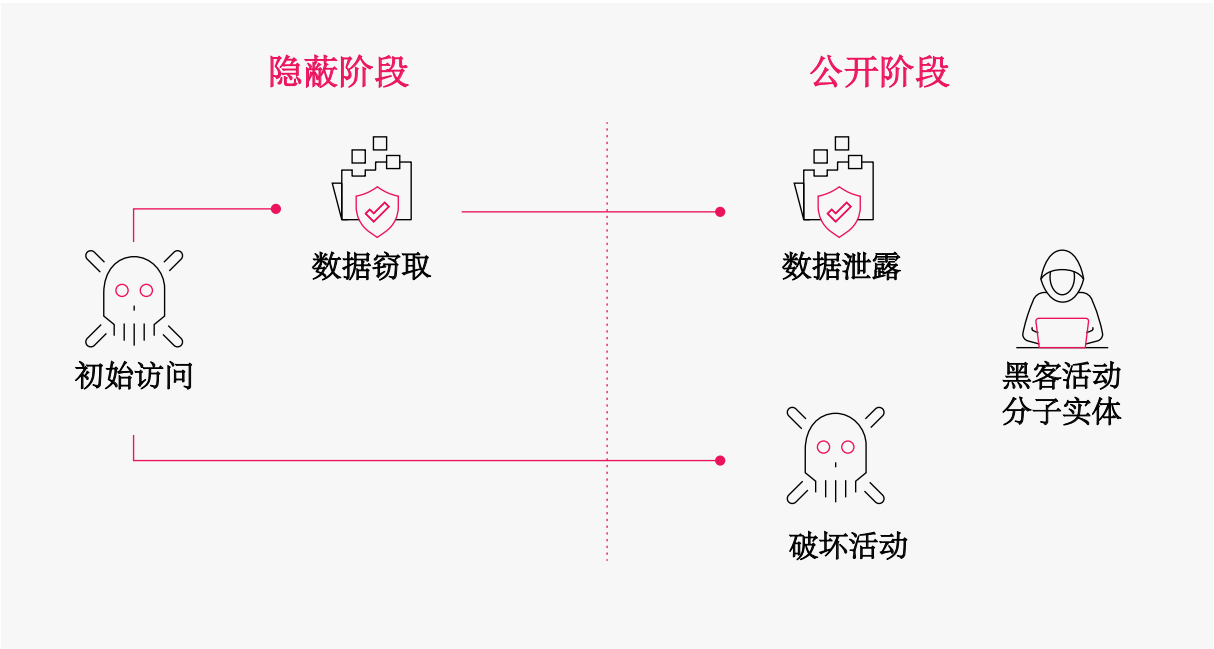


图 1 – 典型的作战行动策略。

同样，WIRTE 组织展示了其不断发展的网络能力，通过使用 SameCoin 擦除变体攻击以色列的医院和市政当局，加剧了持续冲突带来的心理和后勤损失。

在东欧，出现将破坏性恶意软件武器化的现象，这种恶意软件不仅旨在摧毁系统，还能更深入地嵌入环境中，窃取敏感的军事计划并切断重要的通信渠道。这些行动突显了恶意软件被利用并作为其地缘冲突中的重要支持机制。

破坏准备 – 可能的“红色按钮”

虽然一些国家采取了影响巨大的一次性攻击，但其它国家则采取了较为低调的方式。他们渗透到关键系统的深处，为未来潜在的大规模破坏奠定基础。有些行为者专注于渗透关键基础设施，并在其中持续保持隐蔽性。利用诸如路由器、VPN 设备和物联网系统等边缘设备中的漏洞，对安全性较低的网络组件的



- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

未授权访问权限，使他们能够收集情报并建立潜在的“红色按钮”能力 — 这种访问权限可用于未来的大规模破坏。这种战略定位在美国目标中尤为明显。

有些组织便展现了这种方法，重点加强利用美国关键基础设施中的防火墙和路由器。利用“借地生存”(LOTL) 技术，依靠受感染环境中的合法管理工具来躲避检测。能够绕过传统的网络安全措施并保持隐蔽，为未来的行动做好准备。

“Salt Typhoon”瞄准了包括 AT&T 和 Verizon 在内的主要互联网服务提供商 (ISP)，利用漏洞拦截和操纵网络流量。

“黑客活动分子”团体

去年，随着各国依靠庞大的网络人物网络来服务其地缘政治议程，国家支持的网络战的模糊边界变得越来越明显。这些人物中的许多人，自称是出于意识形态动机的独立黑客活动分子，其实是国家赞助的幌子。通过放大分裂性的叙述并针对公众信任，黑客活动组织成为更广泛的影响力行动的关键组成部分，使他们的赞助者能够掩盖其直接参与，同时利用爱国言论来扩大其影响。在公众兴趣下降和日益疲劳的背景下，2024 年出现了一个显著的趋势：联盟的形成，不同的团体在共同的旗帜下联合起来，形成一个更强大、更有凝聚力的阵线。

在个体方面，黑客活动组织也加强了他们的活动，主要针对以色列和阿尔巴尼亚的目标。像 Malek Team 和 Handala Hack

这样的组织进行了网站篡改活动、黑客入侵和数据泄露操作以及破坏活动，并声称对入侵以色列网络和窃取数太字节的敏感数据负责。Karma 针对以色列组织部署了诸如 BiBi 和 No Justice 擦除器这样的破坏性工具。Cyber Avengers 瞄准了包括以色列、美国和爱尔兰的电网和供水系统等关键基础设施。“Homeland Justice”组织也攻击了阿尔巴尼亚的政府机构，以报复其收留反对派组织“Mujahedin-e-Khalq”(MEK)。这些活动突显了组织将黑客活动与网络战相结合的特征。

同样，其它的攻击行为者也体现了相似的策略，比如有些组织将目标对准对立的国家的 key 基础设施，主要进行分布式拒绝服务 (DDoS) 攻击和其它操纵活动，扰乱了对立国家的政府及私营部门的运作。

除了个人力量外，黑客活动分子还通过结盟来扩大影响力。这些组织的显著特征和活动包括针对国际上大型活动的协调式 DDoS 攻击和宣传活动。试图将网络攻击与心理操纵相结合以影响公众舆论。



图 2 – 关于创建“Holy League”的电报帖子。

2024 年，黑客活动突显了网络空间中联盟和影响力不断变化的动态，反映了东西方之间的地缘政治紧张局势。像“Holy League”这些联盟往往反映了现实世界的发展。这些团体通过反复声明合作来强调他们的统一战线，试图在日益复杂的现代网络冲突格局中持续吸引关注、增强其心理影响并扩大全球影响力。

01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议

网络驱动和金融战

其它国家还在部署黑客活动分子进行干扰和破坏稳定，而有些国家的网络行动超越了激进主义的伪装。比如精心策划的一个庞大且相互关联的网络行动机构，将金融犯罪与间谍活动相结合，以在国际制裁的重压下帮助维持其陷入困境的政权。

一些国家的“金融战”还可以视为是一种微妙的平衡行为：勒索软件和加密货币盗窃为国家计划提供资金，而间谍活动则收集情报以增强军事和技术能力。

“Lazarus Group”作为网络犯罪核心机构的典型代表，在 2024 年以其特有的老练手法带头开展行动。一次行动伪装成一个以坦克为主题的加密货币游戏，利用谷歌 Chrome 的零日漏洞部署了 Manuscript 后门程序。其目标不仅是窃取加密货币，还增加了间谍活动的元素。今天窃取的钱包可能为明天窃取的军事蓝图提供资金。

像 BlueNoroff 这样的子团体进一步完善了这种方法。他们的“隐藏风险”活动通过令人信以为真的钓鱼邮件和旨在操纵交易并将资金吸入政权金库的假新闻网站来引诱加密货币交易者。这也展示了如何将虚假信息部署策略利用于网络犯罪。

还有些组织模糊了金融盗窃和破坏之间的界限，瞄准美国的医疗保健组织，使用以网络犯罪为导向的“Play”勒索软件对关键系统进行加密，以勒索加密货币付款。这些行动不仅是为了即时的经济收益，还充当了在地缘政治危机中破坏重要部门策略的试验场。

甚至就业领域也变成了战场。2024 年，西方公司在不知情的情况下接纳了伪装成远程 IT 自由职业者的特工。特工通过渗透以虚假身份进入公司环境，这些特工实现了双重目的：为政权创造硬通货，并伺机访问敏感的组织网络。

从预测的灾难性打击到持续的战斗

以广泛的视角纵观今年，网络战已表现为在多个领域中分割的持续的小规模战斗，而非旨在一举击垮国家的灾难性的打击。这些冲突很少有明确的赢家或输家，但大多成功地侵蚀了信任，削弱了机构，并模糊了国家和民间领域之间的界限。

影响力行动成为关键战线，由人工智能驱动虚假信息活动瞄准了选举、社会凝聚力 and 地缘政治稳定。同时，破坏性恶意软件、黑客活动前沿组织以及金融网络犯罪成为一些国家进行胁迫、破坏稳定和自我维持的工具。

虽然民主国家试图通过收紧法规和投资网络防御来适应，但他们脚下的网络战场已经发生了变化。网络战不再局限于数字基础设施，而是已经渗透到社会结构中。关于信息和认知的战斗有可能比曾经预期的物理系统攻击持续时间更久。

“

如今的网络战已经从即时的破坏演变为包括为侵蚀系统（无论是社会系统还是物理系统）奠定基础的持续性的行动。现在，各国挥舞着诸如人工智能生成的深度伪造和社交媒体操纵等网络“武器”，同时其秘密行动确保能够访问关键基础设施，为未来的攻击做好准备。

”

ELI SMADJA

安全研究小组经理



01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

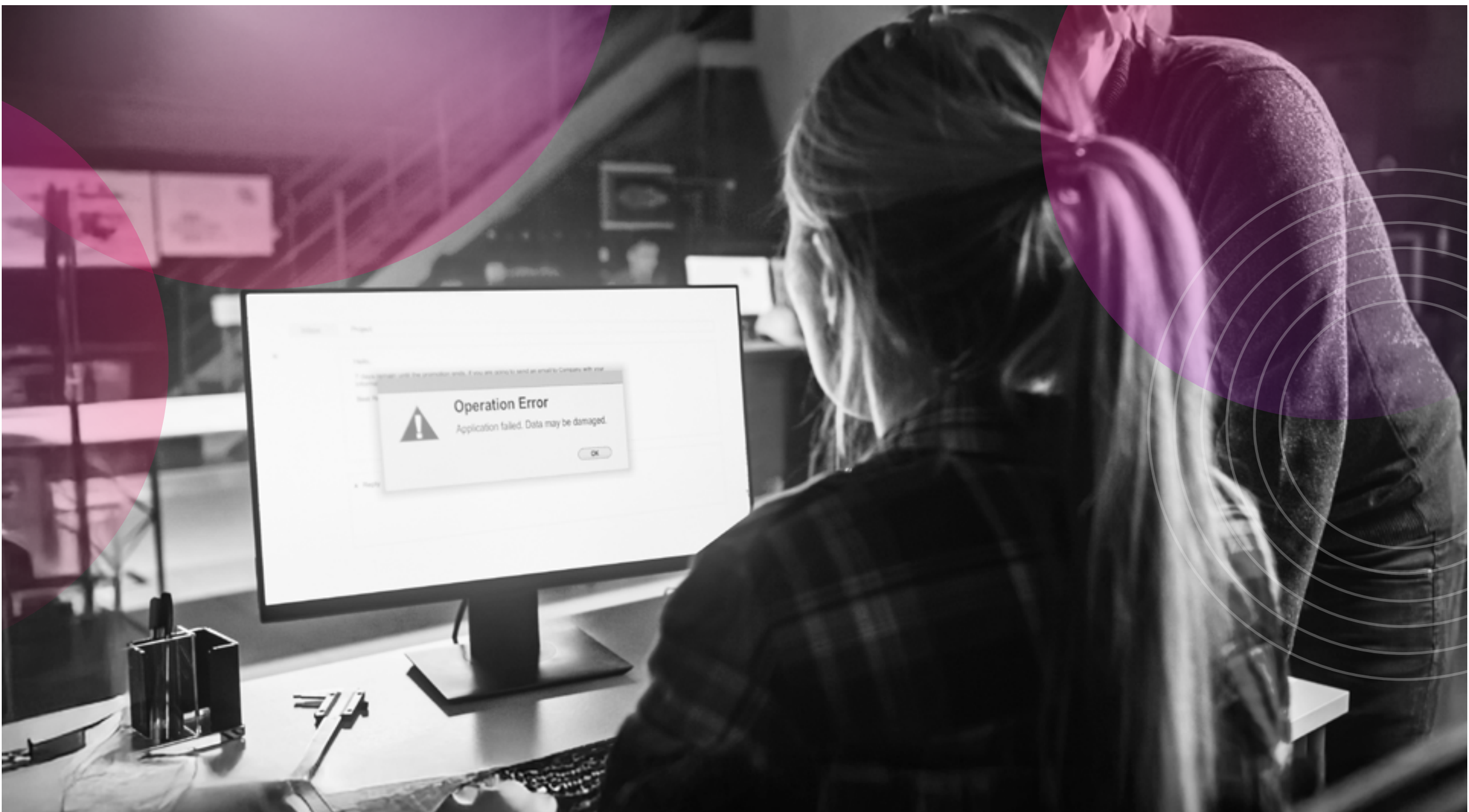
04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议



2024 年的勒索软件生态系统： 执法行动的影响、针对医疗保健领域以及数据泄露勒索的兴起

2024 年，勒索软件仍然是全球企业面临的最重大网络威胁，其规模 and 影响都达到了新的高度。鲜为人知的勒索软件组织“Dark Angels”据报道获得了一家未具名的《财富》50 强公司高达 7500 万美元的赎金支付，而 ALPHV 则从 Change Healthcare 那里勒索到 2200 万美元。在 Change Healthcare 这起案件中，勒索软件攻击导致服务中断数月，超过 1 亿名患者的医疗记录被盗。Change Healthcare 的母公司 UnitedHealth 报告称 2024 年第一季度受到了高达 8.72 亿美元的影响。这包括 5.93 亿美元的直接应对成本和 2.79 亿美元的业务中断损失。此外，该公司还拨出 8 亿美元用于未来的索赔储备。

尽管有此增长，但 2024 年的赎金支付中位数仍约为 20 万美元，大多数攻击都在悄然进行，很少引起公众关注。

除了备受瞩目的案例外，今年的威胁形势从根本上发生了变化。持续的执法压力和罪犯之间的纠纷导致 LockBit（多年来在勒索软件领域占主导地位的一方）及其主要竞争对手 ALPHV 垮台。它们的退出为新的威胁组织 RansomHub 的壮大铺平了道路。此外，曾经被认为较少成为目标的医疗保健部门，成为了网络犯罪分子的主要关注点。最后，威胁行为者愈发从传统的基于加密的策略转向单纯的数据勒索，这标志着其犯罪手段更加精简和危险。

执法行动及其对勒索软件生态系统的影响

虽然网络安全措施提供了保护，但它们不足以应对已成为企业首要网络威胁的勒索软件。并且打击此类攻击的行为因缺乏国际合作而受到阻碍。

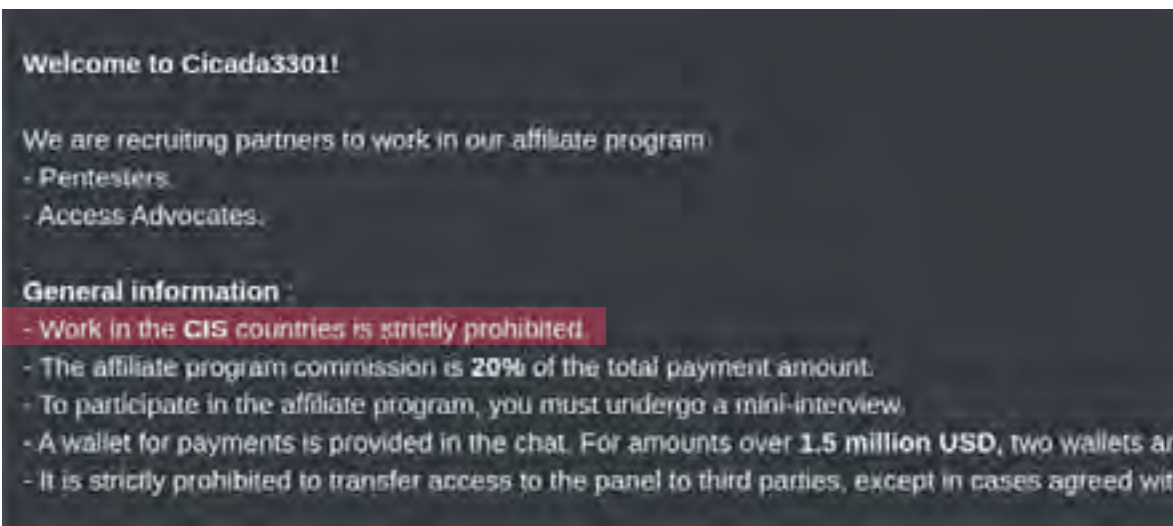


图 3 - 暗网帖子，指明 Cicada3301! 组织的招募条件，禁止针对独立国家联合体 - CIS 开展活动。

应对这一威胁需要国际执法持续的且相互协调的行动进行共同努力，例如共享情报、协调法律框架，以及共同追捕肇事者并

01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议

拆除他们的基础设施等。令人鼓舞的是，2024 年出现了几个此类行动的有效范例。

在前几年，打击行动成功地针对了主要的勒索软件团体，如 **Hive**、**Ragnar** 等。2024 年 2 月，由英国国家犯罪局 (NCA) 和 FBI 领导的协调国际执法行动“**克洛诺斯行动**”，对勒索软件即服务 (RaaS) 生态系统中的主导团体 **LockBit** 造成了重大打击。这次行动查封了 **LockBit** 的数据泄露站点 (DLS) 并拆除了关键基础设施，极大地扰乱了他们的运营。当局控制了多个国家的 34 台服务器，包括荷兰、德国和美国。该行动持续到 10 月，并在波兰和乌克兰逮捕了关键人物，同时法国和美国司法当局发布了起诉书。执法机构获取并公布了 **LockBit** 的解密密钥和内部数据，使其运营和附属网络受到进一步审查。

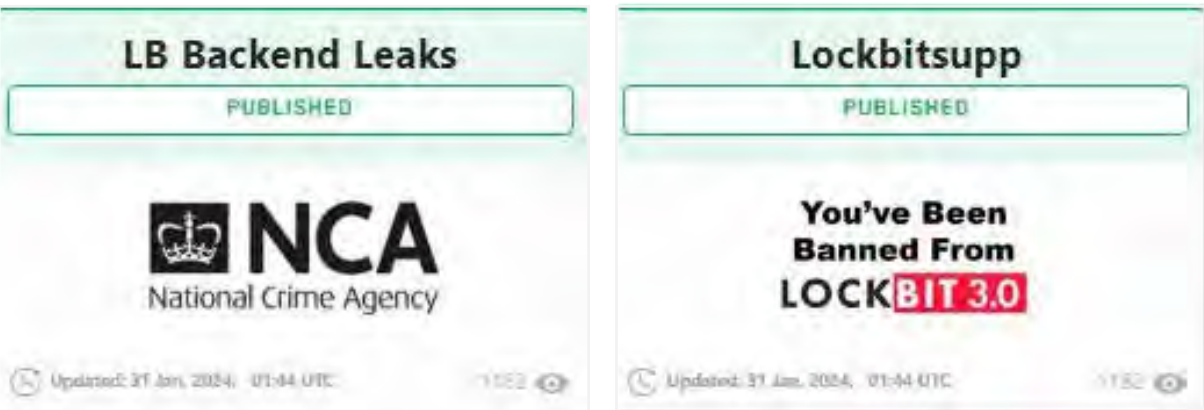


图 4 - 来自 LockBit 羞辱网站的截图损害了其信誉（来源：NCA）。

这次行动不仅旨在拆除 **LockBit** 的技术基础设施，还意在损害其在网络犯罪领域中的形象。**LockBit** 的信誉对其运营至关重要，这从其积极参与犯罪论坛和媒体采访中可见一斑。该组织的领导人，被称为 **LockBitSupp**，经常在这些平台上互动，推广他们的勒索软件服务，并保持公众形象。这种曝光度对于招募附属机构以及向受害者保证他们在处理赎金支付和数据方面的“专业性”是不可或缺的。

在“克洛诺斯行动”之后，**LockBit** 的活动显著减少。一旦他们的内部通信和附属机构身份被曝光，他们就失去了信任。**LockBit** 试图通过发布虚假的重复名单或其它攻击者的受害者

名单来营造“一切照旧”的形象，随着向基于数据的勒索转变，这种现象有所增加。尽管 **LockBit** 试图重新开展业务，但持续的执法压力以及在网络犯罪社区内信誉的丧失阻碍了他们的复苏。然而，在 2024 年的最后一周，该组织宣布了一个新版本，**LockBit 4.0**。只有时间才能证明这是否标志着这个犯罪组织的复苏。

ALPHV 是另一个退出舞台的主要 RaaS 参与者。在 2023 年底，他们受到了一次执法行动的打击，但短暂恢复后又激进地对医疗保健实体重新展开了攻击行动。

2024 年 2 月，**ALPHV** 的一个附属机构攻击了 **Change Healthcare**。该组织扣下了该附属机构的全部 2200 万美元，拒绝给其分成。然后该组织在其 DLS 上伪造了一份查封通知，并宣布退休。

虽然这两个主导团体的清除在短期和长期内影响了勒索软件的格局，但对遏制该生态系统的攻击数量作用甚微。事实上，公布的受害者数量稳步上升。这种韧性突显了 RaaS 运营的性质：独立的附属机构在很大程度上不受单个品牌或运营商垮台的影响，只是迁移到其它平台。这些附属机构摆脱了先前的从属关系，找到了提供必要基础设施、泄露站点和支持服务的其它 RaaS 团体，确保他们的勒索软件攻击渠道保持完整。

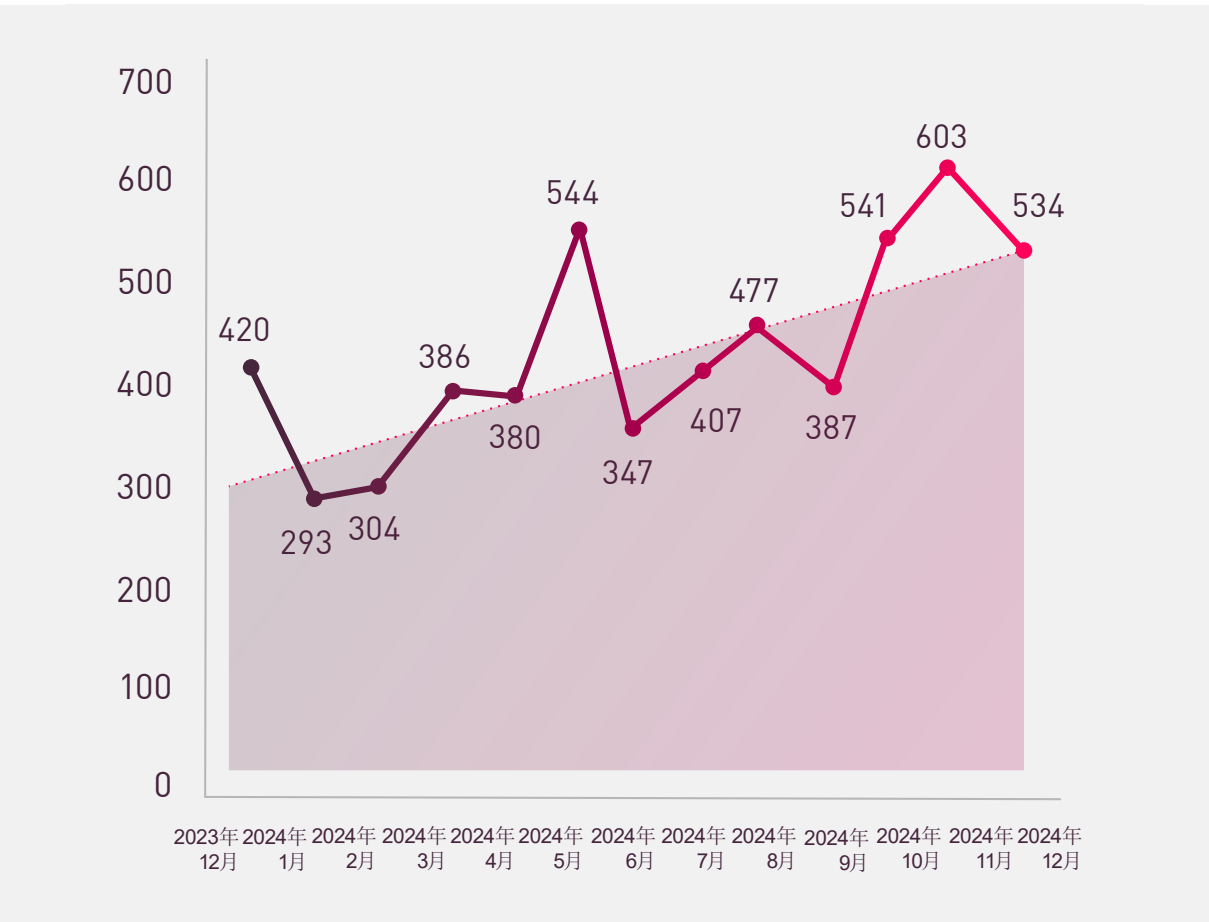


图 5 - 勒索软件数据泄露网站上报告的受害者总数。



01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议



在事件刚发生后的那段时间，没有任何一个实体能够复制 LockBit 和 ALPHV 之前所拥有的市场主导地位。虽然 RansomHub 似乎准备担当领导角色，但其地位远未得到保证。相反，该领域进入了一个竞争分散的时期，像 Akira、Play、Medusa、Dan0n、Hunters 和 Bianlian 这样的中型参与者，争相招募附属机构并积聚势力。

ALPHV 扣留附属机构的赎金分成所带来的后果，再加上 LockBit 受损的信誉以及泄露的勒索软件代码的可用性，推动了更多自主勒索软件运营商的崛起。越来越多规模较小的勒索软件独立团体出现，他们不愿意依赖已建立的 RaaS 框架或与中心化运营商分享利润。通过利用泄露的代码，这些参与者定制了自己的勒索软件变种和基础设施，减少了对主要 RaaS 提供商的依赖，促进了一个更加分散和竞争激烈的勒索软件生态系统。

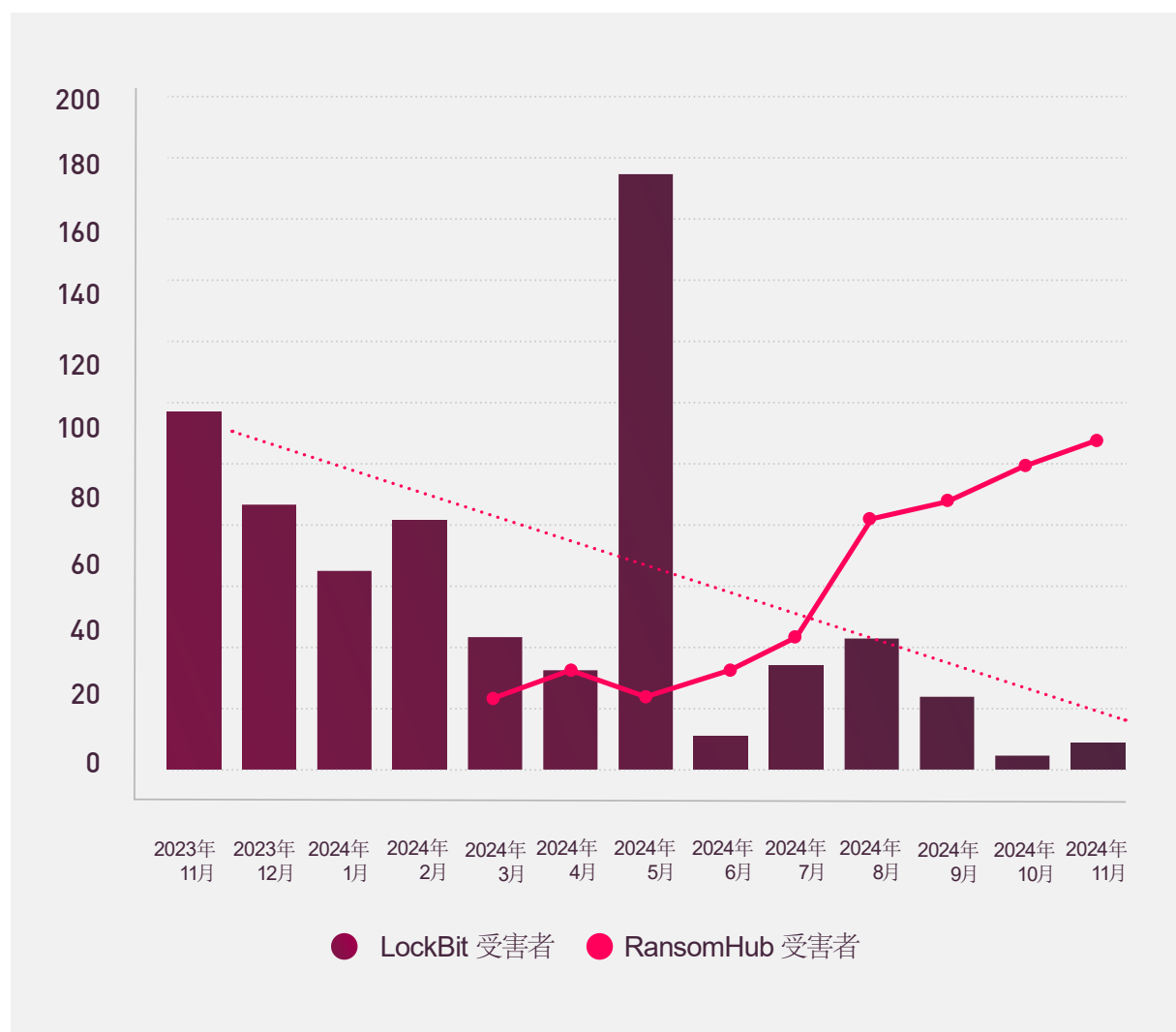


图 6 - 2024 年报道的 LockBit 与 RansomHub 数据泄露站点的受害者。

随着 2024 年接近尾声，RansomHub 成为新的主导者，在 11 月占报告受害者的 16%。同期，超过 40 个其它双重勒索软件组织仍然活跃，每个组织都维护着自己的数据泄露站点，并瞄准新的受害者。

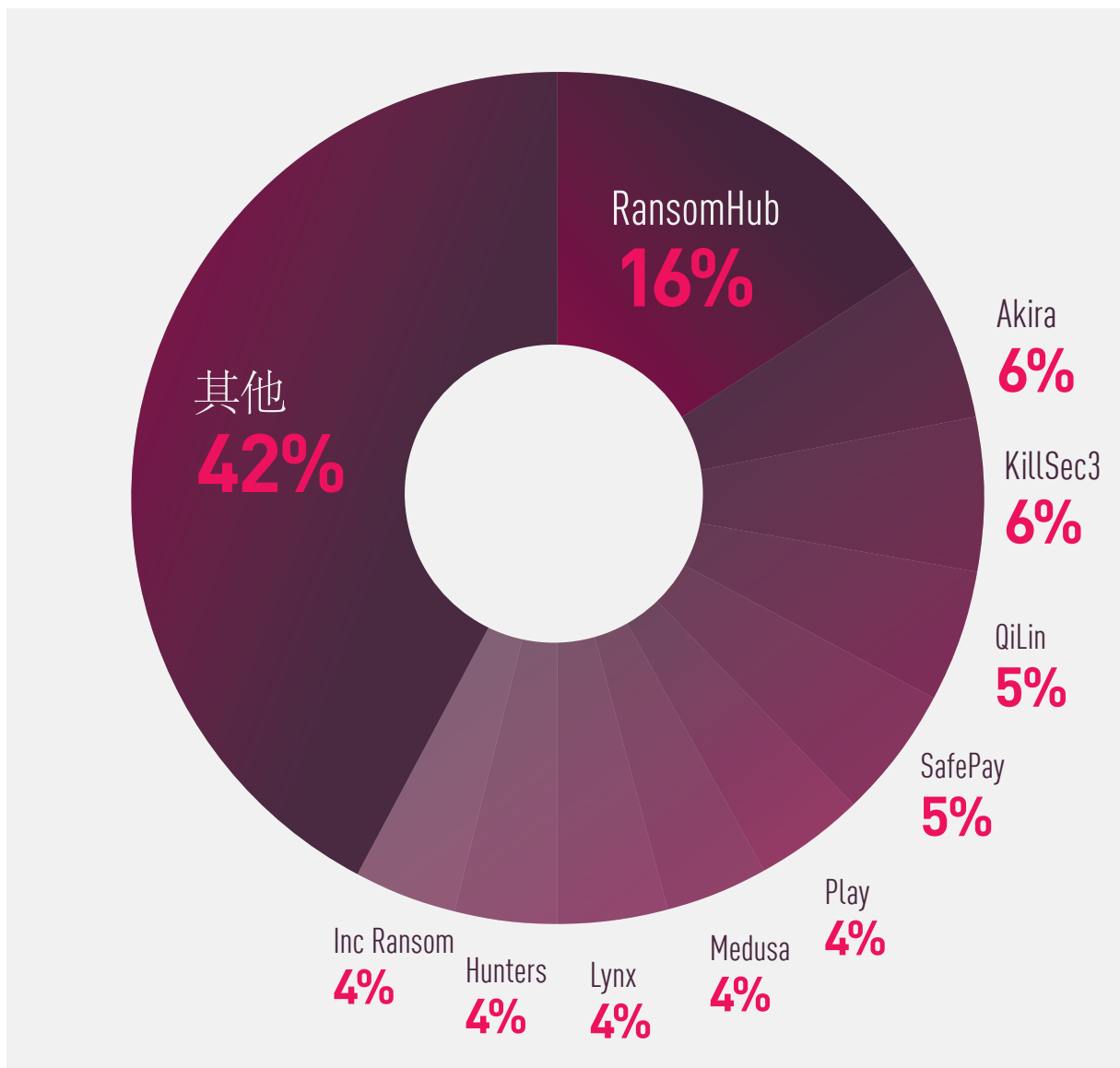


图 7 - 2024 年 11 月，按攻击者划分的数据泄露站点受害者。

医疗保健行业遭受攻击

勒索软件团体转向以医疗保健组织为目标，突显了先前既定的“道德”准则的逐渐衰落。在新冠疫情的最初几个月，许多 RaaS 运营商公开宣布医院和医疗提供者是禁区。然而，随着时间的推移，这些限制逐渐减弱。一些 RaaS 管理员采取了一种更微妙的方法。虽然他们不鼓励直接破坏医疗保健服务，比如对关键系统进行加密，但他们允许窃取敏感的医疗数据。附属机构随后可以通过威胁泄露患者信息来勒索受害者，并向医疗保健实体施压要求付款，而不会直接危及患者。

在针对 ALPHV 的执法行动之后，这种情况进一步恶化。该组织公开鼓励附属机构专门针对医院。到 2024 年 2 月，医疗保健和医疗部门成为 ALPHV 最主要的攻击目标，约占其报告受害者的 30%。

01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议



图 8 - ALPHV 允许附属机构“封锁医院、核电站，任何地方的任何事物。”（来源）。

医疗保健行业运营的关键性和特殊性意味着，系统长时间停机会给患者带来很大的风险，这是不可接受的。正如 **Change Healthcare** 遭受的攻击所表明的那样，这大大增加了支付赎金的可能性。

医疗保健和医疗机构如今在所有公开报道的勒索软件受害者中占 **10%**，使医疗保健行业成为 **2024** 年第二大受攻击的行业，仅次于制造业。

备受瞩目的 **Change Healthcare** 攻击引起了全球的关注，而许多其它重大事件也突显了这一令人不安的趋势。**2024** 年 **2** 月，一次 **Phobos** 勒索软件攻击瞄准了罗马尼亚的医疗保健系统，此次攻击直接影响了 **25** 家医院，并由于其对 **Hipocrate** 信息系统 (HIS) 的影响，导致 **100** 多家其它设施的运营中断。由于

与互联网断开连接，医院的医疗服务变慢，患者护理延迟，运营能力大幅降低。

6 月，伦敦主要医院的关键病理服务提供商 **Synnovis** 遭到了 **Qilin (Agenda)** 勒索软件组织的攻击。此次攻击要求 **5000** 万美元的赎金，并泄露了约 **400GB** 的敏感数据。这次入侵导致超过 **6000** 次医疗预约和手术被取消。此次中断还导致了英国国家医疗服务体系 (NHS) 的献血量短缺。

许多医疗保健受害者现在成为勒索软件攻击的目标：**19%** 受到 **Bianlian** 的攻击，**23%** 受到 **INC Ransomware** 的攻击，**10%** 受到 **RansomHub** 的攻击，尽管 **RansomHub** 的政策是避开非营利组织和医院（见下图）。这突显了威胁行为者对该领域的关注日益增加。

值得注意的是，超过 **65%** 的医疗保健相关受害者位于美国，与他们在更广泛的勒索软件生态系统中的比例相比，这一比例显得过高。医疗保健业务的重要性以及承受长期中断能力的有限性，使它们成为特别有吸引力的目标。所有迹象都表明，这一令人不安的趋势将持续到 **2025** 年。



图 9 - 来自 *RansomHub DLS* 的 *RansomHub* 官方政策。



01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议

仅数据窃取这一趋势的早期采用者，如 Karakurt 和 Lapsus\$，为其他人开辟了道路。到 2024 年，一些像 BianLian 这样成熟的团体完全转向了仅 DXF 勒索并放弃了加密。同样，一个以前从事双重勒索的较老的勒索软件团体“Meow”，今年重新出现，只专注于数据销售，以不同的价格点提供被盗数据，并允许受害者“回购”他们的信息以防止公开曝光。

新的参与者也已出现，专门作为“数据销售平台”。例如，Bashe（也称为 Eraleign）于 2024 年 4 月首次出现，纯粹作为一个仅基于数据窃取的勒索平台运营。它提供了一个专门的数据泄露站点 (DLS) 和一个谈判平台，不提供加密服务或其它工具。



图 10 - Bashe 行动政策，来自其数据泄露站点。

这种方法也为虚假的受害者索赔创造了机会。由于没有加密造成的明显干扰，威胁行为者可以更轻松地重复利用之前泄露的数据，并虚假声称对新的攻击负责。这种策略使追踪勒索软件活动和识别真正的肇事者变得更复杂，因为多个团体都声称对同一受害者负责。

仅数据窃取勒索的兴起标志着网络安全重点的关键转变。组织现在必须专注于通过利用先进的监测和检测系统，加强数据泄露预防 (DLP) 策略，以便更早地识别和减轻潜在的违规行为。随着仅数据窃取攻击的财务和运营激励不断增加，今年这一趋势可能会持续下去，因为越来越多的勒索软件团体采用这些策略来简化操作并逃避检测。

应对不断演变的勒索软件形势

2024 年的勒索软件形势反映了一个动态且日益复杂的威胁环境。针对主要团体的执法成功为新的参与者打开了大门，RansomHub 成为其中最突出的一个。同时，针对医疗保健组织攻击的道德界限受到侵蚀，突显了威胁行为者日益残酷无情。此外，从基于加密的勒索到 DXF 的战略转变带来了新的挑战，要求组织调整其防御策略，专注于数据保护、监测和快速威胁检测。

“

每年，勒索软件的环境都变得越来越复杂。虽然执法部门成功地取缔了较大的勒索软件即服务 (RaaS) 团体，但今年又出现了新的团体。此外，从基于加密的勒索到数据勒索的转变带来了新的挑战。然而，有一件事始终不变，那就是企业对适应这个趋势并加强数据保护、监测和快速威胁检测的迫切需要。

”

OMER DEMBINSKY

数据研究集团经理

01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议



从信息窃取软件日志到全面入侵： 信息窃取软件在成熟网络犯罪生态系统中的影响力

随着大型僵尸网络和银行恶意软件的衰落，信息窃取软件已成为新的大型威胁，如今通过大规模活动进行分发。在最大的地下犯罪市场上快速搜索会发现，目前有超过 1000 万条信息窃取软件的日志可供购买。这些日志包含被盗的用户凭证、认证令牌和敏感数据。网络犯罪分子可以将其用作强大的工具，从个人那里窃取资金、进行身份窃取或入侵全球的计算机网络。

在我们审视 2024 年的网络态势时，信息窃取软件成为了焦点。这不仅是由于其方法和策略的演变，还因为更广泛的犯罪生态系统已经成熟和专业化，使得这些威胁更具效力。信息窃取软件之所以获得了强大的力量，是因为它们能够高效管理、快速处理和出售大量日志。它们是全面入侵企业网络的第一步。信息窃取软件传播的一个关键方面在于，它主要依靠“广撒网碰运气”的方法，而非直接针对企业网络。尽管采取了这种策略，但其主要目标之一是获取用于访问 BYOD（自带设备）上企业资源的凭证。Check Point 旗下的 Cyberint 公司报告称，信息窃取软件感染的设备中超过 70% 是个人设备，而非企业或托管设备。

定义信息窃取软件

信息窃取软件，常被称为“窃取软件”，是一种被设计用来从受感染的系统中秘密提取敏感数据的恶意软件，主要针对浏览器数据。它们还可以从受感染的机器中窃取文件并截取屏幕截图。窃取软件通过钓鱼邮件或恶意下载进行传播。一旦它们侵入计算机，就可以获取广泛的有价值信息，这些信息可用于进一步的网络犯罪或欺诈活动，包括用户名和密码、财务细节、系统配置、浏览器 Cookie 和加密货币钱包。信息窃取软件在暗网上作为恶意软件即服务 (MaaS) 进行销售，购买者会得到客户支持、定期更新和详细文档，降低了潜在网络犯罪分子的入门门槛。



图 11 - 一个暗网论坛帖子推广出售 Lumma 信息窃取软件。

01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议

信息窃取软件市场

信息窃取软件市场强劲且竞争激烈，其定价反映了产品的复杂程度以及开发者提供的支持水平。例如，RedLine Stealer 每月约 150 美元，StealC 约 200 美元，Lumma 的价格约为 250 美元。运营这些恶意软件服务的威胁行为者，通常被称为“附属机构”，在 MaaS 模式下购买许可证，并在各自的感染活动中使用这些窃取软件。附属机构收集的数据，即“日志”，由从个人计算机窃取的一批批信息组成。然后，这些日志在 Telegram 等平台或地下犯罪市场上出售或交易，通常每个约 10 美元。被盗的信息助长了进一步的非法活动，包括金融欺诈、身份窃取和进一步的网络攻击，从而使更广泛的网络犯罪生态系统得以延续。



图 12 - 从一台法国电脑窃取的 Lumma Stealer 日志在市场上出售。

会话令牌和 Cookie 是信息窃取软件获取的最理想的数据类型之一。这些元素特别有价值，因为它们无需登录凭证即可立即访问用户帐户。获取“新鲜”或最近被盗的日志至关重要，因为活动会话 Cookie 具有时间敏感性。如果及时获取并出售，它们可以劫持正在进行的会话，并绕过许多安全系统所依赖的多因素身份验证 (MFA) 机制。许多网络犯罪分子经常分析从信息窃取软件那里获得的数据，以发现企业帐户的凭证。这些凭证可以在企业网络内提供一个初始立足点，或者授予对关键资源的访问权限。目标通常包括 VPN 帐户、Microsoft 365 帐户、企业消息系统等凭证和令牌。

为应对这一重大安全风险，谷歌于 7 月推出了应用绑定加密。然而，到 9 月，几个信息窃取软件已经采用了相应的技术来绕过这一保护并解密敏感的被盗数据。

对窃取信息快速利用的需求突显了信息窃取软件供应商相互竞争的另一个关键领域：被盗数据的有效展示和分类。他们开发了先进的操作面板和下载机制，为附属机构提供快速、清晰的访问日志的途径。一些系统提供将日志自动传输到 Telegram 频道的功能，能够近乎实时地利用实时会话令牌。有效的用户界面不仅便于快速访问，还能自动解析并突出显示高价值的凭证，提高了恶意软件对附属机构的效率和吸引力。



图 13 - StealC 面板视图。

支持这些恶意活动的基础设施通常是全面的，并由 MaaS 供应商自己维护。这种基础设施可以包括面板认证机制、提供额外插件和更新的命令和控制 (C2) 服务器，以及用于存储和下载被盗数据的安全位置。对广泛基础设施的依赖有时可能成为恶意软件的致命弱点，因为执法机构可以瞄准并夺取这些资源来破坏 MaaS 运营。

信息窃取软件的分发

信息窃取活动由从开发者那里购买许可证并独立开展感染活动的附属机构推动。为了传播恶意软件，他们使用创新的方法，包括钓鱼邮件、恶意广告、分发假冒或破解软件、欺骗性广告



01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议

和模仿合法类似加密货币服务、人工智能工具和组件应用程序等平台的伪造网站。附属机构还可能利用 GitHub 等平台托管恶意存储库，正如在使用欺诈帐户传播流行的信息窃取软件的活动中所看到的那样。其它策略包括针对寻求破解软件的用户钓鱼模板、虚假验证码页面（旨在诱使用户下载恶意软件）以及恶意谷歌广告（将用户重定向到伪造的下载网站）。与专注于创建和更新恶意软件的开发者不同，附属机构完全决定了分发方式，从而导致了各种各样的创新感染活动。

货币化与网络犯罪生态系统

要了解信息窃取软件的全部影响，我们必须研究它们在更广泛的网络犯罪生态系统中的作用。许多信息窃取软件的运营商依赖客户和有效的分发渠道来将他们窃取的数据货币化。地下市场和 Telegram 频道提供了即时的平台，卖家可以在那里提供他们窃取的数据，买家可以有效地搜索符合其目标的特定日志。

初始访问代理 (IAB) 利用这些信息在企业网络中获得初步立足点。通过被盗凭证获得的这些访问权限非常有价值，并且可以

进一步货币化。在许多情况下，IAB 在其它论坛上转售对精心挑选的目标的访问权限，吸引热衷于利用这些机会的勒索软件附属机构。然后，这些附属机构部署勒索软件（通常从勒索软件即服务 (RaaS) 提供商处获得）来实施攻击。



图 14 - 提供公司网络访问权限的广告。

成功的勒索软件攻击所获取的赎金为整个勒索软件生态系统提供了动力。被盗的个人数据为网络犯罪分子提供了其它有利可图的途径。个人身份信息 (PII)、财务细节和信用卡号码可用于身份窃取、欺诈和未经授权的交易，从而导致商业电子邮件泄露 (BEC)。所有这些活动都依赖于一个成熟且运作良好的犯罪基础设施，该基础设施为被盗数据的交换、销售和利用提供了便利。

90% 的被入侵的公司此前其企业凭证曾在窃取软件日志中泄露

从员工家庭电脑窃取的凭证和会话 Cookie 可用于入侵企业网络。一项研究显示，90% 的被入侵公司在被入侵前其企业凭证已在窃取者日志中泄露。这一统计数据突显了信息窃取软件在促成更重大网络攻击方面所起的关键作用，并强调了在更广泛的网络安全情景下应对这一威胁的重要性。

今年早些时候，Snowflake 大型数据泄露事件暴露了来自超过 165 家组织的敏感信息，包括 Advance Auto Parts、Ticketmaster 和 Santander Bank，影响了数百万客户。此次泄



01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议

露很可能始于信息窃取软件提取并在网上出售的凭证。

对实际使用的信息窃取软件的分析

对在平台上出售的日志进行分析揭示了在收集的数据方面，哪些信息窃取软件最为高产。2022 年首次被报道的 Lumma Stealer 目前是最突出的信息窃取软件，其可供出售的日志数量

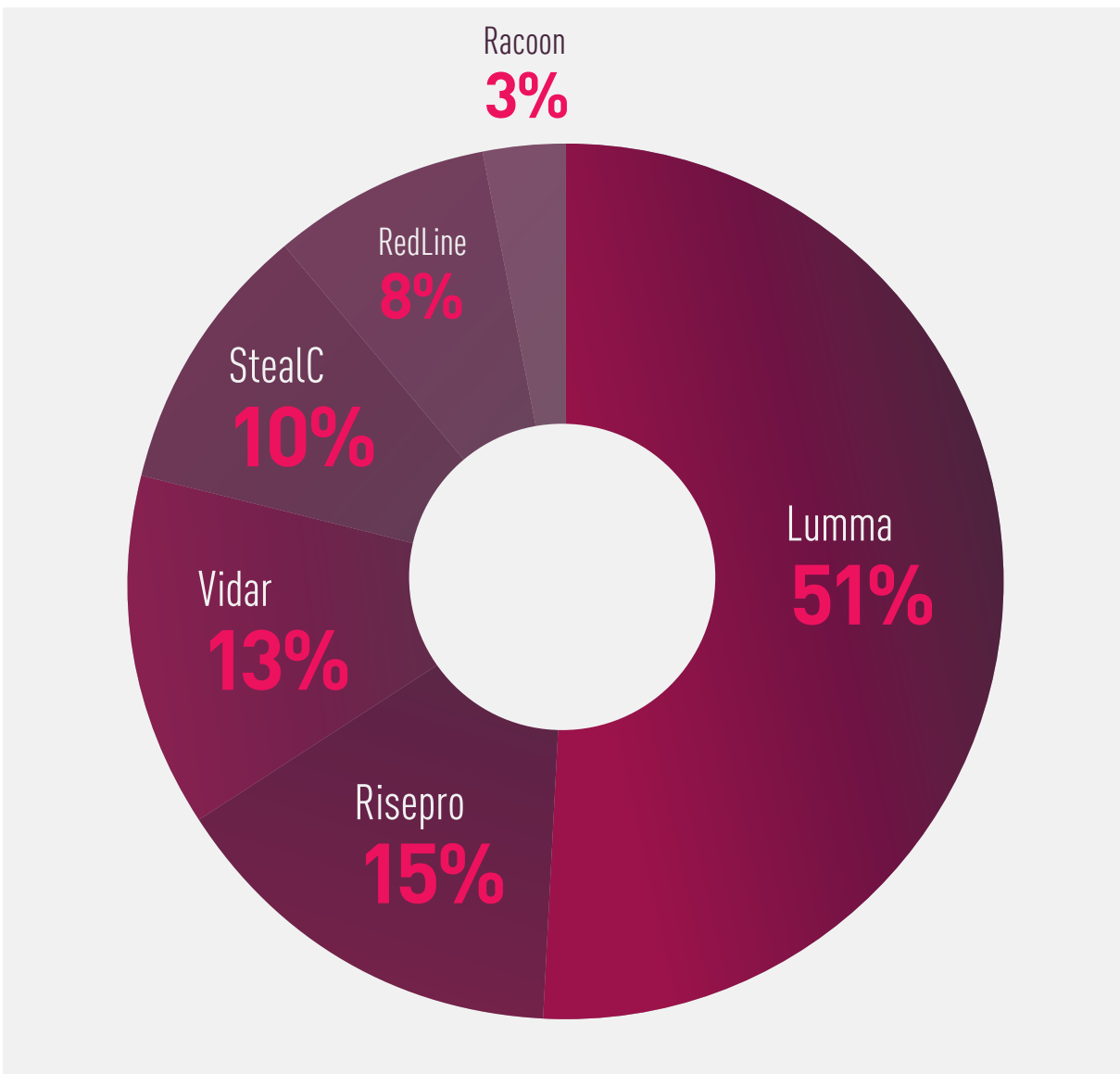


图 15 - 信息窃取软件家族在市场上的日志（2024 年 11 月）。

最多。RisePro、Vidar 和 StealC 紧随其后。这些数据表明，这些恶意软件家族在近期的活动中特别有效，或者拥有广泛的分发渠道。

对 Check Point 网关数据的分析所获得的见解揭示了关于信息窃取软件活动的不同视角。在这些数据集中，AgentTesla 成为

最活跃的信息窃取软件，紧随其后的是 FormBook（详细统计数据将在下一章提供）。这些数据源之间的差异可归因于所分析的受害者类型的不同。Check Point 数据主要侧重于企业实体，而市场上的数据涵盖了更广泛的受害者，其中大多数是个人设备用户。

Check Point 旗下的 Cyberint 公司的进一步数据分析突出了从受感染机器中窃取的顶级 URL 凭证。正如预期的那样，其中许多 URL 属于主要的互联网服务和社交媒体平台，而其它经常访问的网站包括 Roblox、Discord、Twitch 和 EpicGames。

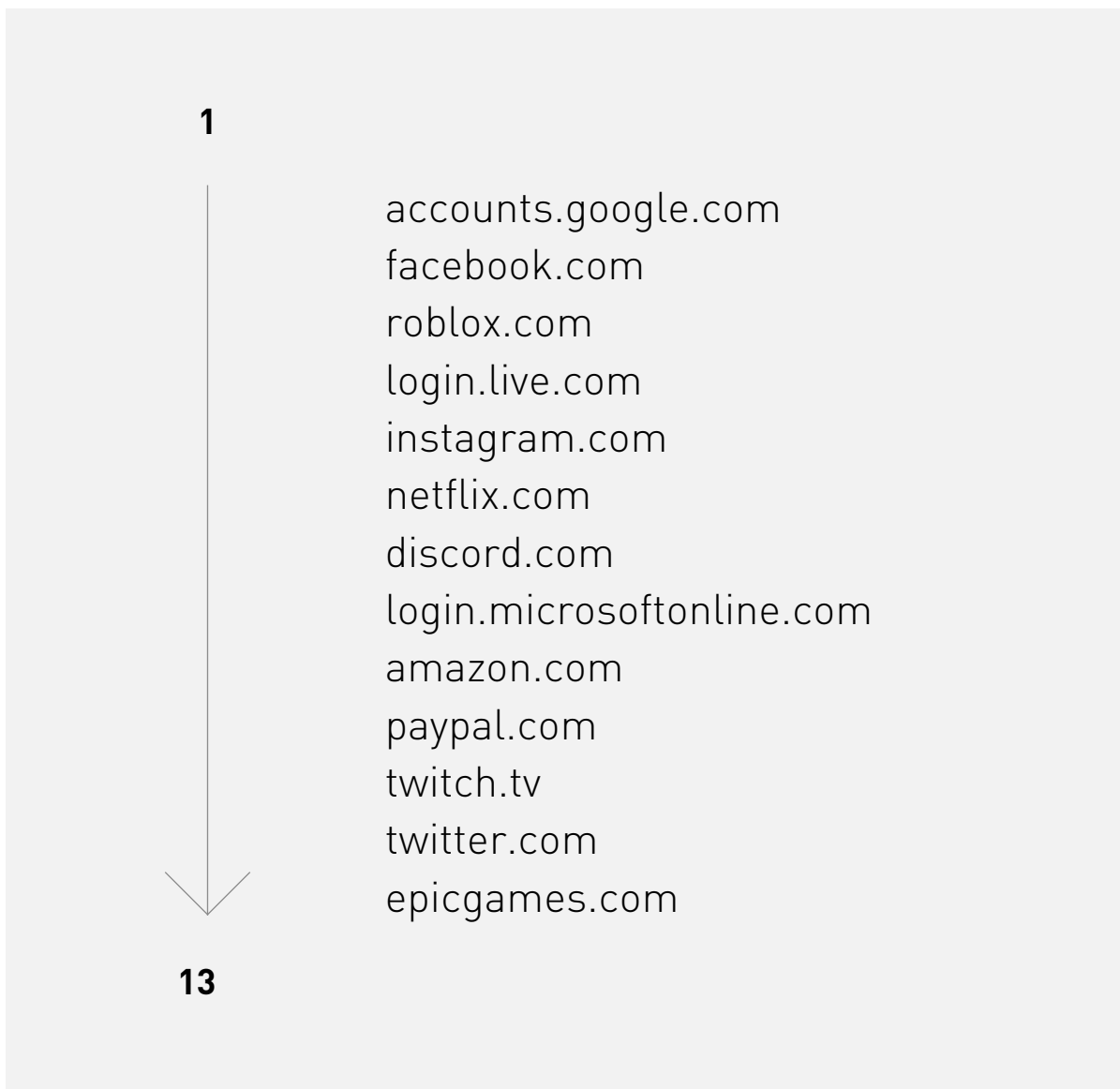


图 16 - 根据 Check Point 旗下的 Cyberint 公司的数据，出现在信息窃取软件数据中的热门 URL。

这表明“游戏玩家”可能更容易受到信息窃取软件的感染，可能是由于这些社区的互联网访问习惯和防护措施不太严格。

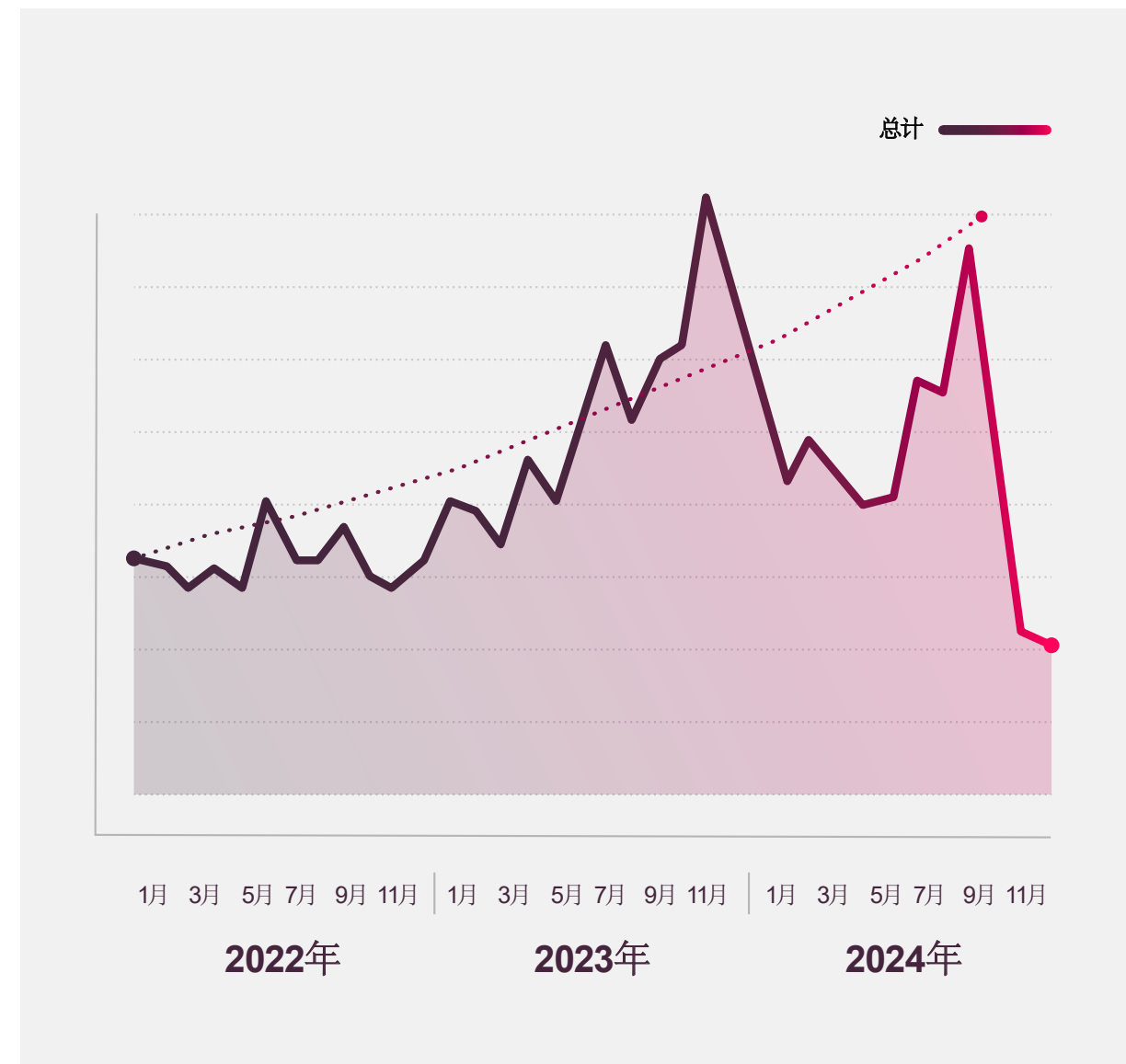


图 17 - 2022-2024 年在追踪的 Telegram 频道上发现的 RedLine 日志（Check Point 旗下公司 Cyberint）。

另一个重要的观察结果是特定恶意软件家族的增长轨迹。例如，RedLine Stealer 的流行程度在过去三年里增长了四倍多。

信息窃取软件的增加可归因于僵尸网络受欢迎程度的下降。5 月，一项名为“Endgame”的联合行动针对用于分发恶意软件的僵尸网络基础设施，重点关注 IcedID、Smokeloader、Pikabot、Bumblebee、SystemBC 和 Trickbot 等组织。由于“Endgame”行动，超过 100 台服务器被拆除，这些网络犯罪分子使用的 2000 多个域名被查封。这些僵尸网络此前在恶意软件分发中发挥着核心作用，它们的瓦解极大地影响了信息窃取软件的生态系统，间接导致了信息窃取软件的兴起。

信息窃取软件的流行并未被国际执法联盟忽视。两个密切相关的信息窃取软件家族，RedLine 和 Meta，成为了一项被称为“Magnus”的重大执法行动的重点。在 10 月，这次行动导致了与这些恶意软件变种相关的多个服务器和域名被查封。

01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议

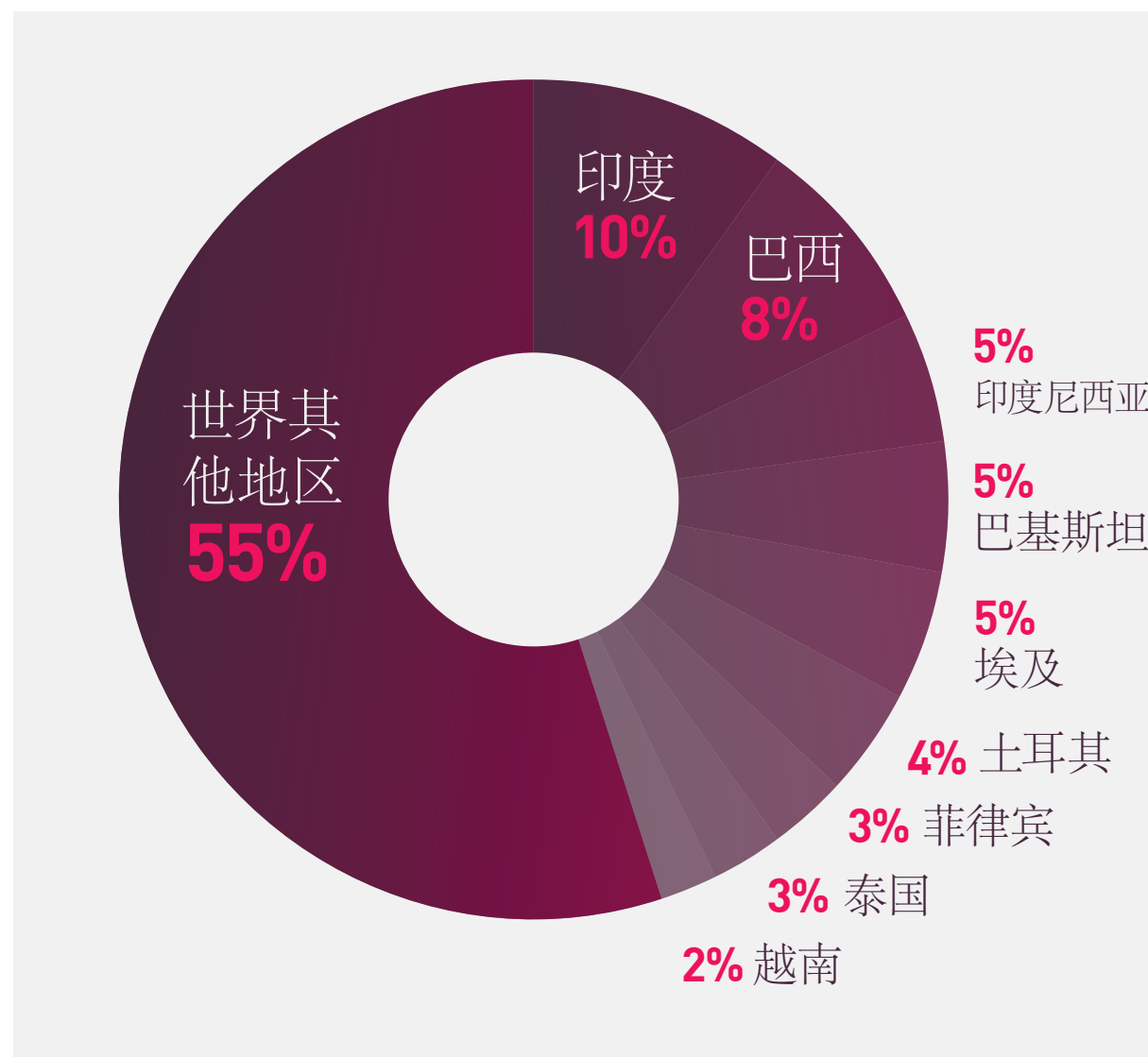


图 18 - 按原产国划分的日志。

对出售的日志进行地理分析也得出了重要的见解。市场上的很大一部分日志来自印度和巴西。

尽管在过去一年中，信息窃取软件技术没有发生巨大的演变，但该恶意软件运行的环境已经发生了巨大的变化。信息窃取软件现在在网络攻击领域占据了突出的位置。信息窃取软件产品及其生成日志的市场逐渐成熟，使得 IAB 能够有效地搜索和利用有价值的凭证，最终能够入侵企业网络。

如何对抗信息窃取软件：在远程工作时代加强企业安全

随着远程工作和 BYOD 政策的广泛采用，员工从个人设备访问

企业资产，将企业网络扩展到个人家庭环境，潜在的企业攻击面已经扩大。日志的快速交付和可搜索性使 IAB 能够迅速识别企业网络的潜在入口点，通常利用在个人设备上发现的被盗有效会话 Cookie 绕过 MFA 机制。

为了对抗这些不断演变的威胁，企业必须扩展其安全措施以覆盖扩大的攻击面，包括员工访问点。组织应该积极寻找公司相关物品在犯罪市场上出售的迹象，以抢先预防潜在的违规行为。通过拓宽保护策略并保持警惕，公司可以加强对现代信息窃取软件所构成的复杂且相互关联的威胁的防御。

“

随着大型僵尸网络的衰落，信息窃取软件已成为一个重大且广泛的威胁。它们为网络犯罪分子提供了窃取凭证和会话令牌的有效途径，导致金融欺诈和身份窃取，并成为入侵企业网络的入口点。随着公司越来越多地采用远程办公和自带设备 (BYOD) 政策，实施保护策略至关重要。

”

SERGEY SHYKEVICH

威胁情报集团经理



01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 勒索软件生态系统

06 信息窃取软件的崛起

07 2025 年行业预测

08 CISO 建议



云：不断扩大的攻击面

2024 年，云基础设施已成为大多数组织IT 框架中不可或缺的一部分。现在，各种规模的公司都利用云所提供的可扩展性和灵活性来支持其运营需求，如电子邮件服务、开发运营、数据存储和托管生产服务。云服务使组织能够迅速部署和扩展环境以满足其需求。与此同时，这种广泛的采用带来了一系列新的安全漏洞，愈发遭到威胁行为者的利用。

云安全管理的复杂性

云基础设施管理的复杂性增加了出现重大漏洞的可能性，并且很难通过简单的补丁来解决。迅速发展的生态系统和众多的云提供商，每个都提供数十种服务、术语和安全机制，造成了企业对云基础设施的安全管理越来越难以驾驭。因此，管理员常常淹没在有效保护其环境所需的大量设置和配置中。这导致资源暴露在网上或形成可渗透的环境，从而为网络攻击者的攻击行为提供了更多的可能。

这种管理复杂性的例子之一是各式非人类身份（服务帐户、API 密钥、内置用户等），事实证明很难保证此类身份的安全。2024 年 1 月，当一个高级的国家威胁组织“Midnight Blizzard”通过配置错误的 OAuth 应用程序和服务原则突破了微软的生产环境时，微软未能确保其自身的 Azure 环境安全。这使攻击者能够从测试环境转向生产环境，并访问内部系统、源代码和微软高管的电子邮件。

已知的配置错误和不良的安全实践仍是导致大规模数据泄露的重要因素。例如，在某东南亚国家，包括执法和军事人员在内的数百万人的 500GB 个人信息和生物识别数据在一个配置错误的 S3 存储桶中被曝光。微软的 S3 存储桶替代品，Azure Blob 存储容器，也容易出现配置错误。富士通的一名员工公开曝光了大量敏感数据，包括私人客户信息、电子邮件、AWS 密钥和明文密码。宝马同样也遭遇了存储容器暴露的问题，泄露了访问私有存储桶的密钥和其它云服务的凭证。

在不良的 API 安全实践领域，Rabbit R1（一款由人工智能驱动的个人助理设备）的开发者被通知在其代码库中发现了用于第三方服务的硬编码 API 密钥。这些密钥权限过大，实质上赋予了读取每个客户所有聊天回复的能力，有可能泄露敏感信息。

01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 勒索软件生态系统

06 信息窃取软件的崛起

07 2025 年行业预测

08 CISO 建议

一些组织缺乏强大的身份验证和访问控制，特别是云服务缺乏多因素身份验证 (MFA)，导致今年发生了一起重大的数据丢失事件。攻击者瞄准了云数据仓库平台 Snowflake，使用通过各种信息窃取软件获取的用户名和密码。这使他们能够访问至少 165 家公司的 Snowflake 帐户，窃取敏感数据，并发出勒索要求。

混合环境的危害

通过身份和访问管理 (IAM) 提供商（如 Microsoft Entra ID）将本地资源与云服务集成已成为标准做法。这些配置旨在简化 IAM 并实现单点登录 (SSO) 身份验证。然而，鉴于这些集成能够促进双向横向移动，它们也已成为网络攻击的主要目标。虽然在云和本地系统之间分配数据和资源可以使组织受益，但攻击者也可以利用相同的途径来部署破坏性攻击、窃取敏感数据或在组织内建立后门。

使用基于云的电子邮件服务（如 Microsoft 365）的公司发现，本地网络受到攻击也会暴露其云资产。当攻击者控制了本地环境时，他们可以通过多种途径转向云环境，例如 Azure AD Connect 服务器（通过 Microsoft Entra Connect Sync 用户）或混合用户帐户。例如，在 2024 年，受经济利益驱动的威胁行为者 Storm-0501 发起了多阶段攻击，破坏了混合云环境，从本地移动到云，并在部署了后门帐户之后，最终在整个网络上部署勒索软件。2023 年，威胁组织 Mango Sandstorm（又名 Mercury）和 Storm-1084 也使用了相同的策略，攻击者利用转向云环境来转储电子邮件对话、发送电子邮件，并对云资产部署破坏性攻击。

在另一个案例中，一个名为 UNC3944（又名 Scattered Spider）的受经济利益驱动的威胁行为者利用具有高度特权的 Okta SSO 帐户，从入侵本地基础设施扩展到多个云和 SaaS

应用程序，包括 vCenter、CyberArk、SalesForce、Azure、CrowdStrike、AWS 和 GCP。然后，攻击者可以对 Okta 网络门户进行侦察检查，以识别可用的应用程序，对这些应用程序进行角色分配，从而在多个云提供商和受害者的资产之间移动。

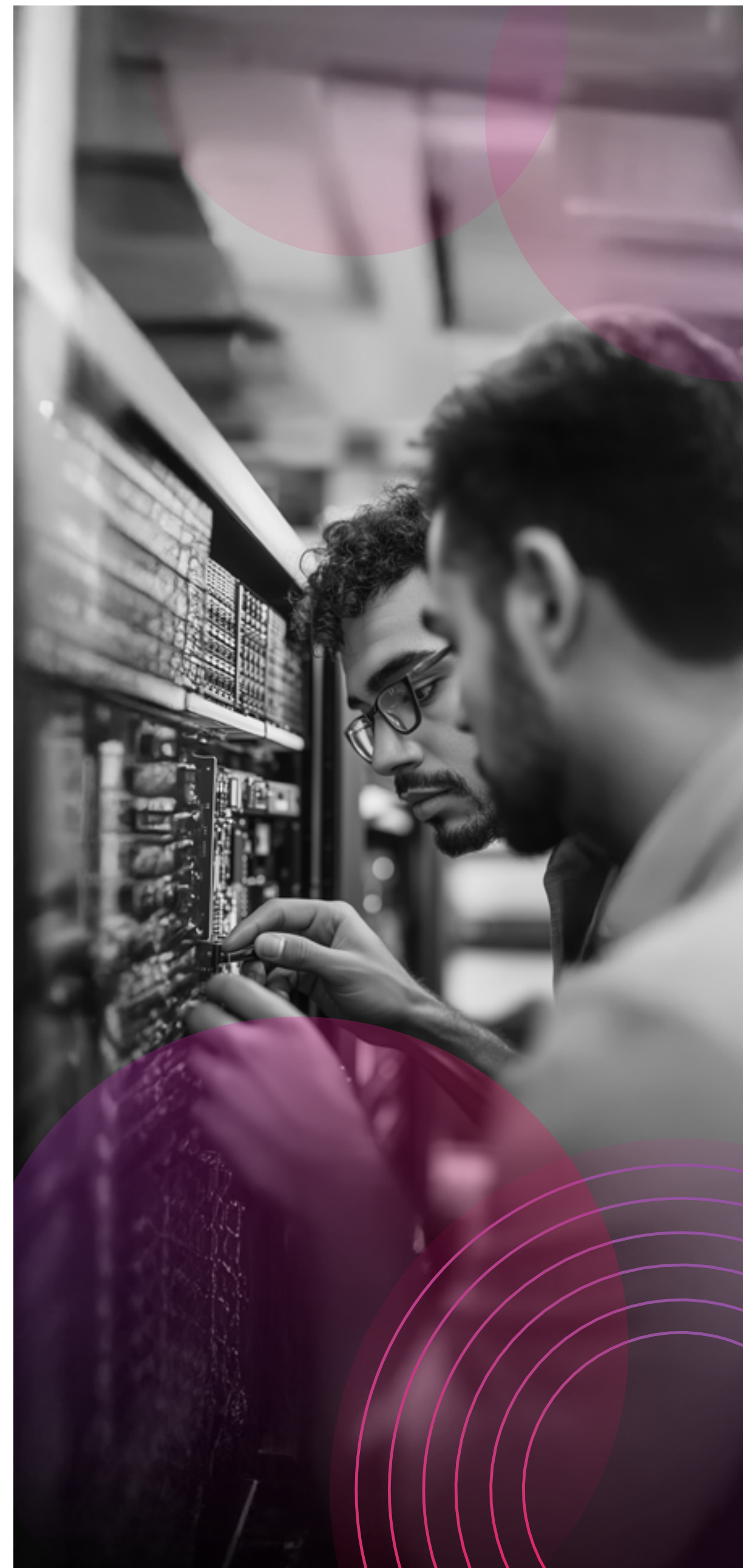
SSO 帐户遭受攻击

确保 SSO 帐户的安全已成为一项日益令人担忧和艰巨的任务。威胁行为者，尤其是高级威胁组织，正在对 SSO 提供商和云服务进行大规模的凭证填充和“低频缓慢”的暴力破解攻击。2024 年 4 月，Okta 的研究人员观察到针对其服务的一次重大凭证填充操作，攻击者使用住宅代理服务和其它匿名化工具来避免被检测。同样，微软的研究人员报告了一个高级的组织，该组织利用数千个被入侵的 SOHO 设备对微软 SSO 后的帐户执行低容量的密码喷洒攻击，每个用户帐户每天仅尝试一两个密码。

由于企业依赖外部 SSO 提供商来防范暴力破解攻击和其它恶意技术，他们也信任提供商的日志和以全局可见性来检测可疑活动。这种依赖引发了对第三方安全实践可靠性的担忧，这在微软 9 月份的报告中有所体现，即由于系统问题，一些客户仅收到了部分日志收集。

人工智能的普及

人工智能也影响着云，因为所有主要的云服务提供商 (CSP) 都将生成式人工智能 (GenAI) 解决方案作为一种服务提供给企业。出于各种原因，公司选择 CSP 的大型语言模型 (LLM) 解决方案，而不是直接通过 API 使用像 ChatGPT 这样的 GenAI 服务。一方面，他们可以构建、训练和部署针对其特定业务需求定制的模式，或者使用检索增强生成 (RAG) 来整合其专有的知识库和数据集。另一个原因是数据隐私和保护；通过利用基于 CSP 的解决方案，公司对其数据有更大的控制权，确保聊天内容不被用于训练公共模型。



01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 勒索软件生态系统

06 信息窃取软件的崛起

07 2025 年行业预测

08 CISO 建议

自然，威胁行为者会想方设法利用这些新技术谋取自身的经济利益。直到最近，攻击者主要专注于劫持云资源，在单个易受攻击的服务器或 **Kubernetes** 集群上进行加密货币劫持（加密货币挖矿）。今年，攻击者发现了一个新的机会，称为 **LLM 劫持**。在云帐户遭到入侵后，攻击者会控制现有的托管 **LLM** 模型或试图部署新的模型。在一个**实例**中，攻击者使用 **LLM** 代理将这些 **LLM** 的访问权限转售给第三方。在另一个**案例**中，攻击者结合 **LLM 越狱**（一种去除对被禁止聊天主题限制的技术）来出售未经审查的不适合工作场所的角色来扮演聊天机器人角色。

由于微软和 **OpenAI** “发现”一些威胁组织滥用 **ChatGPT** 来研究高级主题、创建工具和寻找漏洞，这些威胁行为者可能会转向私有 **LLM** 实例以提高操作安全性。

云基础设施中的安全挑战

今年的事件突显了因广泛采用云基础设施而出现的对关键安全挑战。复杂的管理、错误配置以及混合环境中的漏洞已导致了重大的违规事件。随着云技术的不断发展，那些试图利用它们的网络攻击者也将不断变化其策略。积极主动的措施对于保护日益复杂的云环境至关重要。

“

随着云服务的不断增长，云的攻击面也在不断扩大。最近的事件突出表明，需要在混合云和多云环境中进行持续的态势管理和主动的威胁预防，以检测和阻止复杂的攻击

”



MICHAEL ABRAMZON
威胁情报与研究架构师

01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- **边缘设备和 ORB**

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议

边缘设备和 ORB 不断演变的威胁

在过去的一年里，网络犯罪分子和受国家支持的攻击者都大大增加了对边缘设备的利用，将其作为初始访问载体。边缘设备，如路由器、防火墙和 VPN 设备，由于缺乏专门的安全解决方案，对网络攻击者特别具有吸引力。它们经常被利用来建立通常被称为操作中继盒 (ORB) 的匿名化基础设施。ORB 代表了一种网络基础设施，网络威胁行为者用它来对各种设备（其中许多已被攻破）之间的通信进行匿名化和中继，创建躲避检测的隐蔽通道。

传统上，边缘设备一直是受国家支持的行为者的主要关注点。然而，网络犯罪集团也在愈发将这些资产作为目标，采用类似的策略来获取经济利益。

2024 年，影响边缘设备的已披露零日漏洞数量显著增加，有十几个零日漏洞专门针对不同供应商的设备。这些漏洞的 CVSS 风险评分达到 8 分或更高，突显了其严重程度和潜在影响。

一个显著的发展是用作 ORB 的复杂僵尸网络的兴起。复杂的僵尸网络攻击者利用零日漏洞和已知漏洞，创建了一个可扩展、具有全球影响力的持久攻击基础设施。通过这些设备，给公共和私营部门实体带来了重大风险。

另有通过 ORB 的行为者通过不同的网络开展活动以隐藏其行为。主要针对报废 (EoL) 设备，使归属认定工作变得复杂。

除了与国家有关联的攻击者之外，以经济利益为动机的攻击者也使用由受攻击的 IoT 和 EoL 设备驱动的代理服务。以一个名为 TheMoon 的传统僵尸网络为基础建立的 Faceless 代理网络，包含了超过 40,000 个受攻击的设备。网络犯罪分子使用这些老旧的路由器作为匿名化节点，以掩盖数据窃取和凭证填充等恶意活动。对 EoL 设备的依赖突显了一个主要风险：成千上万不受支持的设备仍然容易受到攻击，这不啻成为攻击者提供了一种规避常规防御的弹性基础设施。

01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议

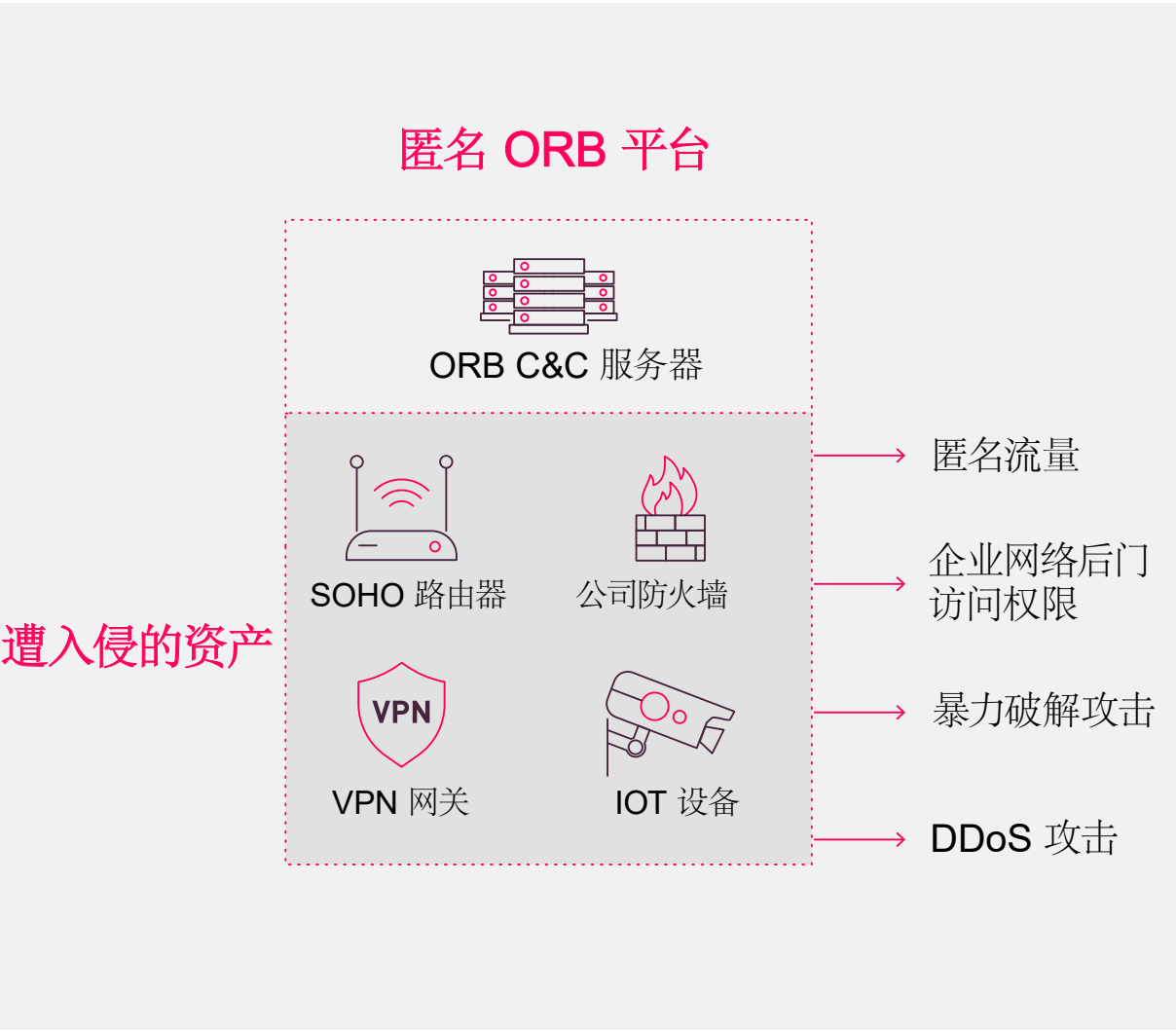


图 19 – ORB 基础设施概述。

今年，随着攻击者继续将其用于更广泛的网络渗透，企业边缘设备面临的零日漏洞利用日益增多。2024 年初，在 Ivanti Connect Secure 和 Palo Alto Networks 的 PAN-OS GlobalProtect 中发现了高严重性漏洞，允许远程代码执行和多因素绕过。国家行为者和勒索软件组织都利用这些设备作为访问和破坏敏感环境的切入点。由于这些边缘设备在主网络流中起着关键作用，不容易进行补丁修复，因此边缘设备中的此类零日漏洞利用会产生重大后果。对边缘设备进行补丁修复可能会导致网络服务暂时关闭，从而带来相当大的运营损失和其它后果。

一些攻击者已经将利用边缘设备的漏洞作为一种攻击方法。Magnet Goblin 是一个以经济利益为动机的攻击者，于 2024 年首次出现，专注于迅速利用广泛使用的边缘设备中新披露的漏洞。他们的活动针对 Ivanti Connect Secure VPN 以及

Magento 和 Qlik Sense 等流行软件来部署定制恶意软件。Magnet Goblin 的工具包包括 NerbianRAT，一种跨平台的远程访问木马 (RAT)，以及 MiniNerbian，一种 Linux 后门。该攻击者对迅速利用边缘设备漏洞的重视突显了针对这些关键组件的以经济利益为动机的攻击的趋势越来越明显和广泛，他们使用诸如 WARPWIRE（一种窃取凭证的 JavaScript）之类的工具来实时访问敏感数据。

Check Point 的 SSLVPN 设备也通过被确定为 CVE-2024-24919 的路径遍历漏洞成为攻击目标。这种利用手段使攻击者能够访问和读取 SSLVPN 设备上的文件，包括敏感的密码哈希值和配置文件。当这些设备配置较弱的认证方法（如用户名和密码访问）时，它们容易遭受未经授权的数据读取。这次攻击表明了不同威胁行为者对边缘设备不断变化的关注重点，他们能够迅速利用任何新出现的漏洞。

网络犯罪分子在利用边缘设备方面有所改进，而受国家支持的行为者继续展示其技术优势。他们利用零日漏洞部署为特定设

2024 年披露的重大边缘设备漏洞

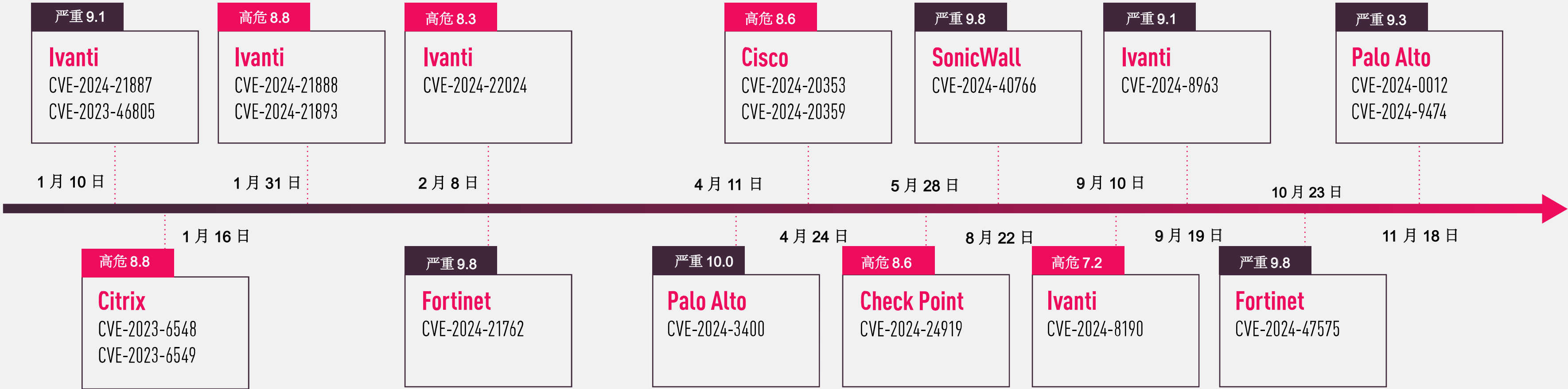


图 20 – 2024 年已披露的边缘设备漏洞的时间线。

01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- **边缘设备和 ORB**

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议

备量身定制的定制植入程序。思科的自适应安全设备 (ASA) 在一场名为 [ArcaneDoor](#) 的复杂行动中成为目标。利用 ASA 的弱点，此行动使国家行为者能够渗透政府和工业网络，获取敏感信息，并建立长期的间谍能力。在整个行动中，威胁行为者利用了为受影响设备定制的独特植入程序，这表明他们进行了大量的研究和开发工作。

发现了许多针对各种安全产品的定制植入程序。其中一项代号为“[Pacific Rim](#)”的行动表明威胁行为者多年来一直将 Sophos 防火墙和 VPN 网关等周边设备作为目标。“Pacific Rim”使用各种策略来利用面向互联网的服务中的漏洞，包括 CVE-2020-12271 和 CVE-2022-1040，并得以访问关键网络点。一旦这些设备受到攻击，它们就会成为 ORB 网络的一部分，该网络支持躲避检测的隐蔽命令和控制 (C2) 通道。攻击者在其操作中使用了先进技术，如 rootkit 植入程序和模糊化的热修复程序，以保持持久性并隐藏其在受攻击设备上的存在。这使得该行动能够从边缘设备转向内部网络资产，重点关注印太地区的高价值目标。“Pacific Rim”的持续和战略性方法突显了边缘设备的脆弱性，特别是在难以实现全面监控和及时补丁修复的部门。

虽然随着时间的推移，这些复杂的后门程序变得越来越常见，但需要注意的是，网络生态系统中仍然存在许多来自未受保护的边缘设备的“经典”威胁。2024 年 9 月，[CloudFlare](#) 开始抵御一场持续数月的 DDoS 攻击活动，据披露，该活动所报告的攻击量超过以往任何组织。这些高数据包率的攻击似乎源自多种类型的受攻击设备，包括 MikroTik 设备、DVR 和网络服务器。高比特率源自大量受攻击的家庭路由器，它们可能是通过一个严重漏洞遭到利用的。目前，这一大规模攻击尚未归咎于任何受国家支持的行为者或网络犯罪集团。

在 2024 年，由易受攻击且未受监控的边缘设备构建的大规模僵尸网络已成为高级威胁行为者武器库中不可或缺的一部分，

无论是用于匿名化、网络利用、持久化还是创纪录的 DDoS 攻击。

ORB 和诸如 Raptor Train 及 Faceless 之类的僵尸网络使用去中心化的 C2 基础设施，能够在受攻击的设备之间动态切换。这使得攻击者能够轮换节点，并有效地躲避检测。一些恶意软件变种，如 TheMoon，采用先进的躲避策略，包括仅在内存中执行和频繁切换 IP，这进一步加大了缓解工作的难度。再加上受感染设备的持续轮换，这些策略给防御者带来了重大挑战。

针对边缘设备的策略最初是国家行为者用于秘密渗透的策略，现在以经济利益为动机的攻击者利用现成的工具包也采用了这一策略。这种方法可以攻破高价值目标，同时在很长一段时间内不被发现。对边缘设备的持续攻击突显了一个关键的安全缺口。如果没有及时的补丁修复、全面的监控和强大的检测系统，公开暴露的网络设备将仍然面临相当大的风险。

“

由于有成千上万不受支持的设备面临攻击风险，威胁行为者能够利用绕过传统安全措施的基础设施。及时的补丁、全面的监控和强大的检测系统将至关重要。

”

LOTEN FINKELSTEIN

威胁情报与研究总监





全球分析

2025 年网络安全状况

01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议

按地区划分的网络攻击类别

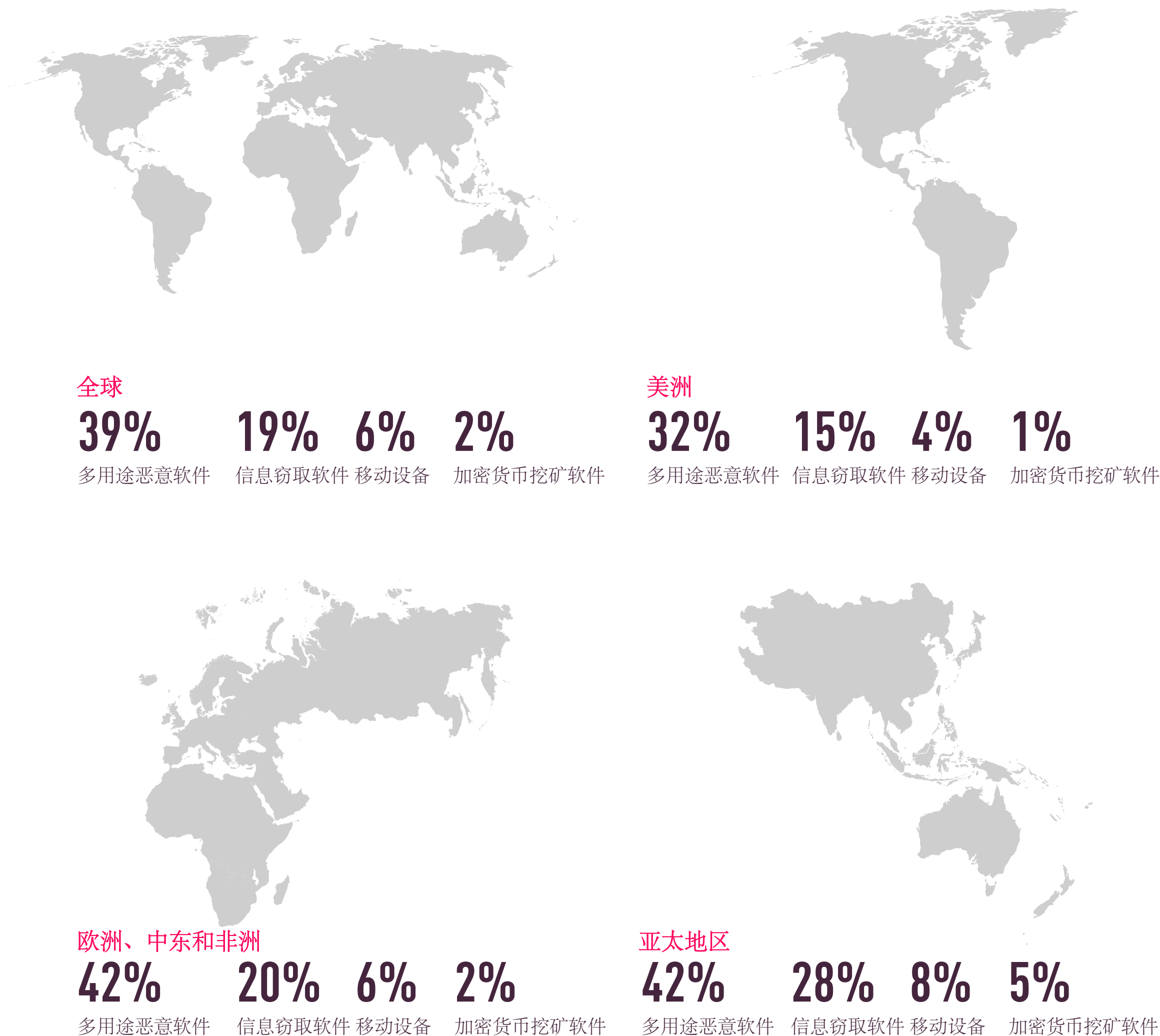


图 1 展示了根据恶意软件类型的攻击情况。这些数字不包括常规扫描，只涉及直接攻击，这使我们能够对恶意软件的类型及其意图进行分类。

在 2024 年，信息窃取软件和多用途恶意软件的攻击尝试显著增加。多用途恶意软件（RAT、僵尸网络和银行木马）经常用于攻击的初始阶段，以投放其它工具并扩大攻击者对被攻破系统的控制。因此，它是最常见的恶意软件类型也就不足为奇了，2024 年有 39% 的组织受其影响。与 2023 年只有 31% 的组织面临类似攻击尝试相比，这一数字与 2023 年相比，同比增加了 25%。



信息窃取软件的感染尝试也显著增加，受影响的组织比例从 2023 年的 12% 增加到 2024 年的 19%，同比增加了 58%。信息窃取软件攻击的增加，通常是在大规模活动中分发，而不是针对特定受害者，这反映了信息窃取软件有一个成熟的生态系统，以及对包含凭证、会话 Cookie 和其它个人信息的被盗信息窃取软件日志的需求不断增加。多种恶意活动都会使用信息窃取软件，从通过被盗的金融凭证直接进行欺诈，到利用被盗的会话 Cookie 入侵企业网络等。关于信息窃取软件生态系统的最新发展情况和更多细节在“趋势”章节中提供，并且在本章的后面将提供专门的数据部分。

在系统所有者不知情的情况下安装的加密货币挖矿攻击显著下降，受影响的组织比例从 9% 降至仅 2%。我们所见到的大多数加密货币挖矿程序都以门罗币为目标，而今年门罗币的挖矿难度（挖掘门罗币所需的计算工作量）几乎翻了一番，从 1 月份的平均 260G 上升到 12 月份的近 450G。这极大地降低了其盈利能力。关于加密货币挖矿程序的更多详细信息将在专门的部分中介绍。

图 1 - 2024 年按恶意软件类型划分的受影响组织所占百分比。

01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

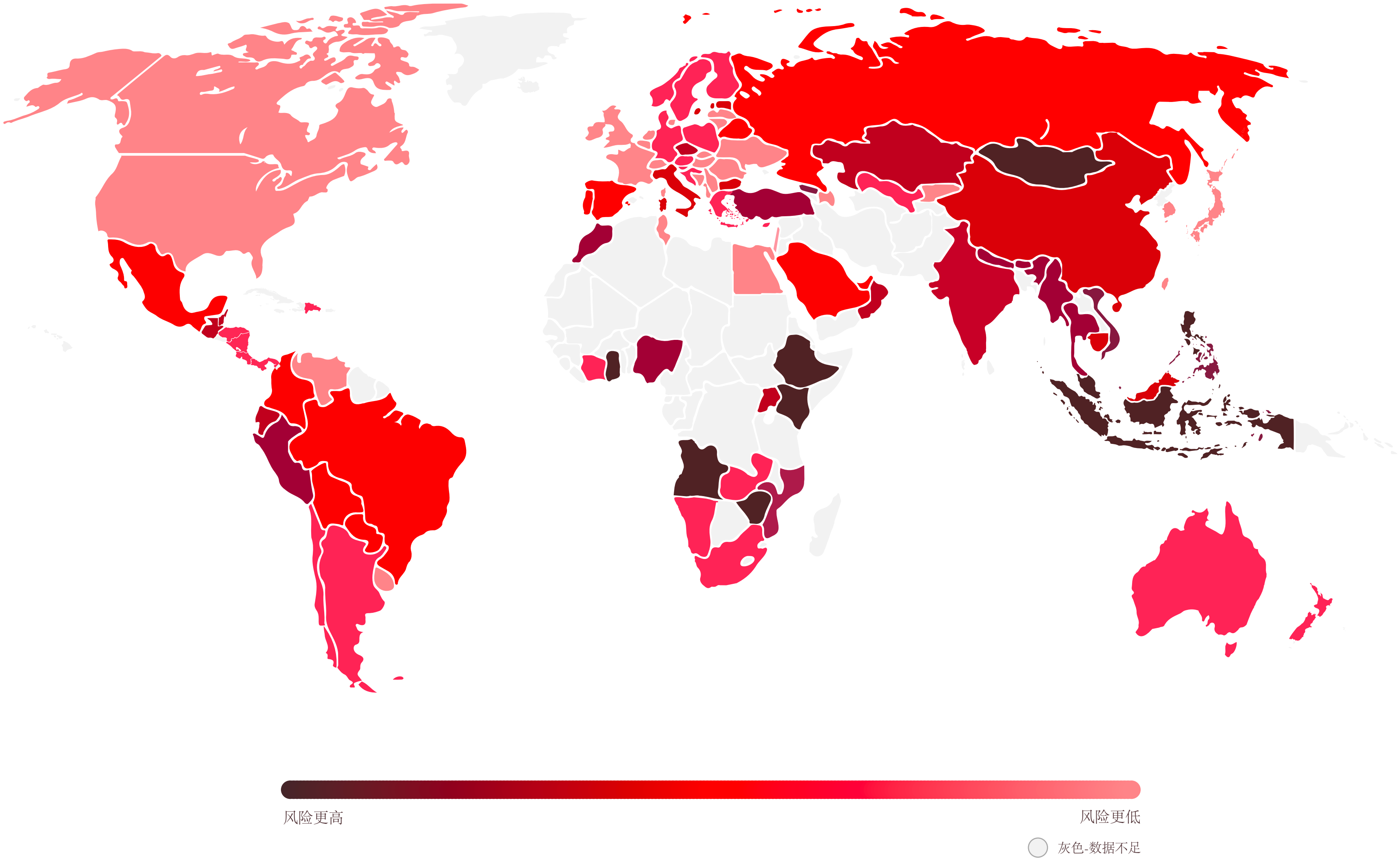
05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议

全球威胁指数地图



- 01 引言
- 02 2024 年网络安全事件
- 03 网络安全趋势
 - 网络战争 - 2024 版
 - 勒索软件生态系统
 - 信息窃取软件的崛起
 - 云的复杂性
 - 边缘设备和 ORB
- 04 全球分析
- 05 备受瞩目的漏洞
- 06 事件响应视角
- 07 2025 年行业预测
- 08 CISO 建议

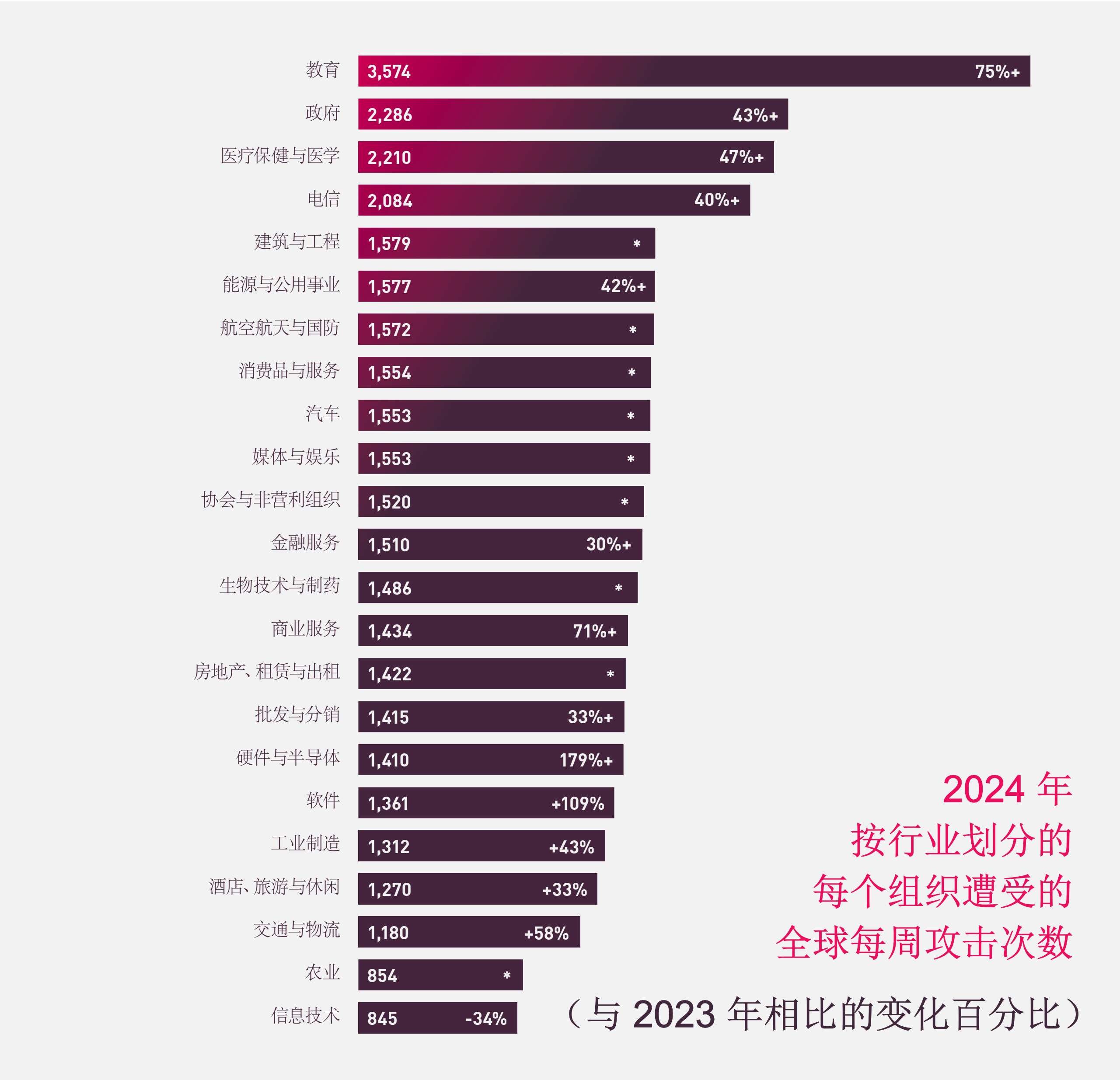


图 3 - 2024 年按行业划分的每个组织遭受的全球每周平均攻击次数 [与 2023 年相比的变化百分比]。
[*] 新引入的行业，不在之前的报告中。

每个组织遭受的攻击次数

在过去的一年里，全球针对组织的攻击总数显著增加，每个组织每周遭受的平均攻击次数达到 1673 次。这比 2023 年高出 44%。图 3 说明了按行业划分的每个组织每周平均遭受的攻击次数。2024 年，大多数行业每周遭受的攻击次数都有显著增加。教育部门遭受的攻击量最高，同比 (YoY) 增长 75%，每周遭受的平均攻击次数超过 3574 次。教育机构成为专门针对个人信息收集的目标。这种持续上升的攻击率影响到大学、中小学以及教育部门和服务机构。

医疗保健部门每周遭受的平均攻击次数也增加了 47%。网络犯罪分子愈发放弃了他们之前自我约束的不针对医疗保健服务行业进行攻击的禁令。医疗部门特别容易受到长期服务中断的影响（如前面的“勒索软件”部分所述），并且其所持有的患者数据具有高度敏感性。

技术供应链领域，包括软件、硬件、半导体公司，遭受的网络攻击的大幅增加。值得注意的是，硬件和半导体行业的平均每周攻击次数增长最为显著，高达 179%，总数现已超过 1400 次。这一激增可归因于全球对硬件需求的不断增长以及对人工智能技术的高度关注。作为现代基础设施和创新的关键组成部分，这些行业已成为网络犯罪分子为获取经济利益、进行间谍活动或造成破坏而寻求利用供应链漏洞的主要目标。

2024 年 按行业划分的 每个组织遭受的 全球每周攻击次数

（与 2023 年相比的变化百分比）

在过去的一年里，全球针对组织的攻击总体显著增加，每个组织每周平均遭受攻击的次数达到 1673 次。这比 2023 年高出 44%

- 01 引言
- 02 2024 年网络安全事件
- 03 网络安全趋势
 - 网络战争 - 2024 版
 - 勒索软件生态系统
 - 信息窃取软件的崛起
 - 云的复杂性
 - 边缘设备和 ORB

04 全球分析

- 05 备受瞩目的漏洞
- 06 事件响应视角
- 07 2025 年行业预测
- 08 CISO 建议

攻击向量

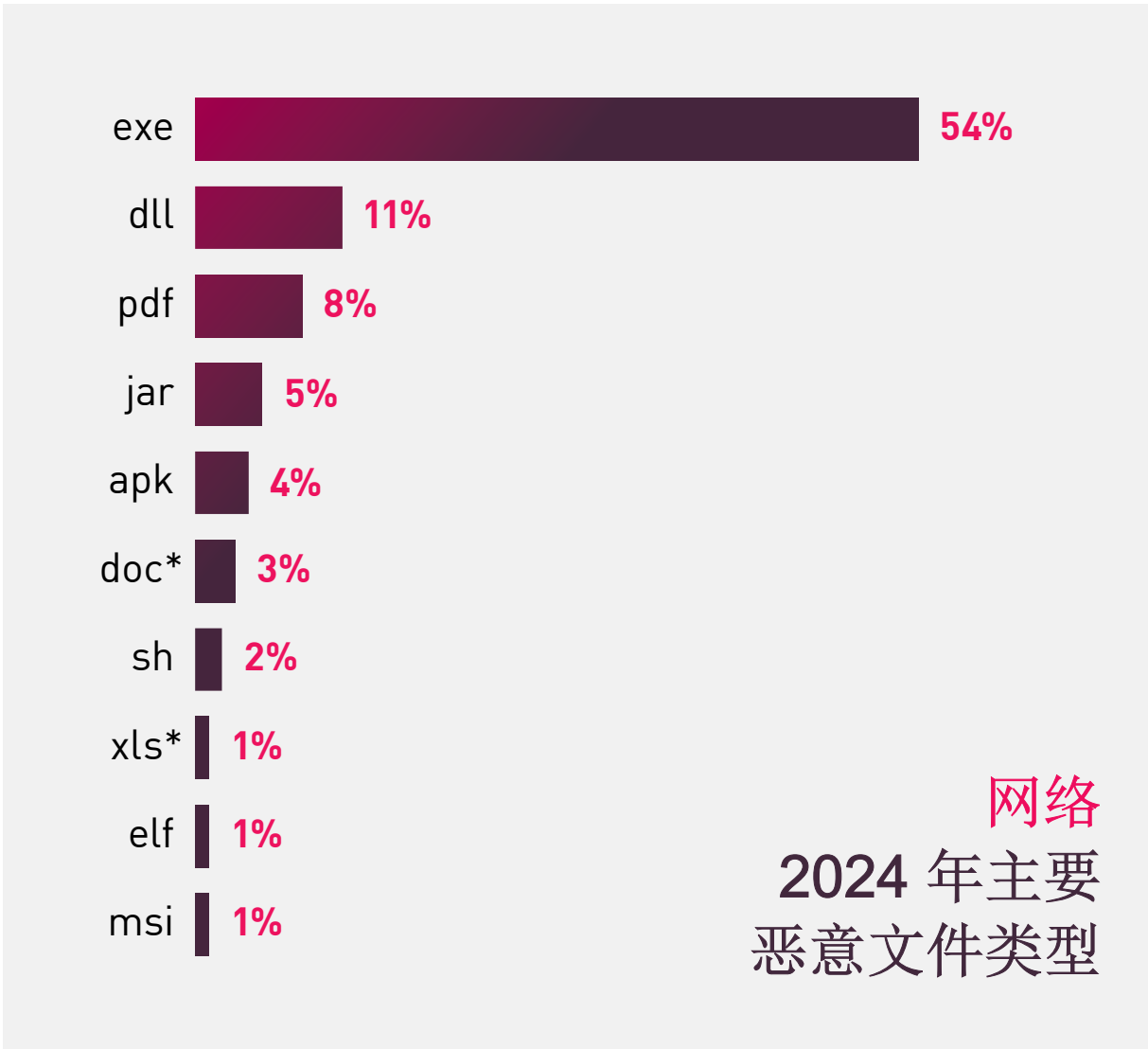


图 4 - 网络 – 2024 年主要恶意文件类型。
xls* 包括常见的 Office Excel 文件，如 .xls、.xlsx、.xslm 等
doc* 包括常见的 Office Word 文件，如 .doc、.docx、.docm 和 .dot

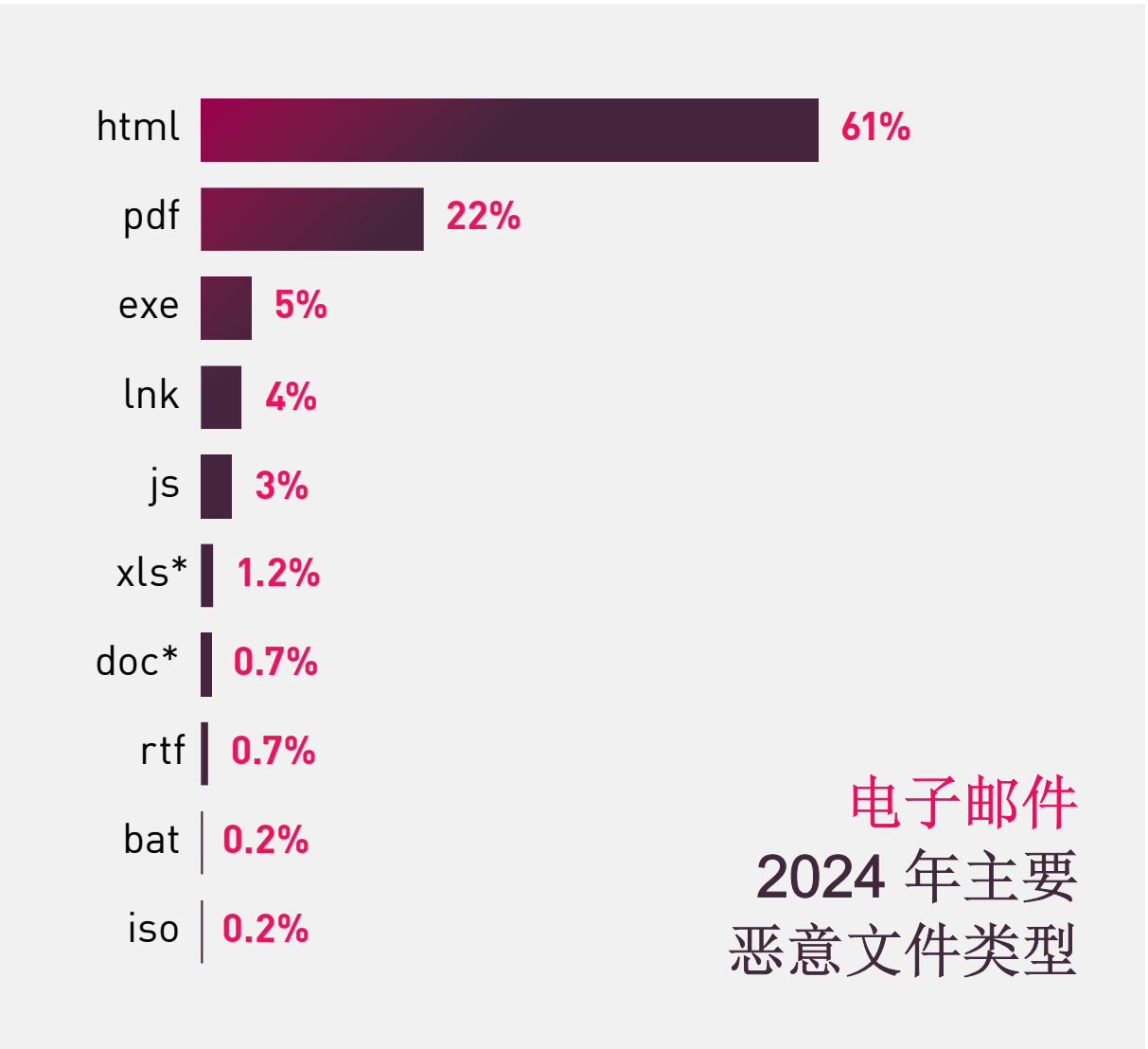


图 5 - 电子邮件 – 2024 年主要恶意文件类型。
xls* 包括常见的 Office Excel 文件，如 .xls、.xlsx、.xslm 等
doc* 包括常见的 Office Word 文件，如 .doc、.docx、.docm 和 .dot

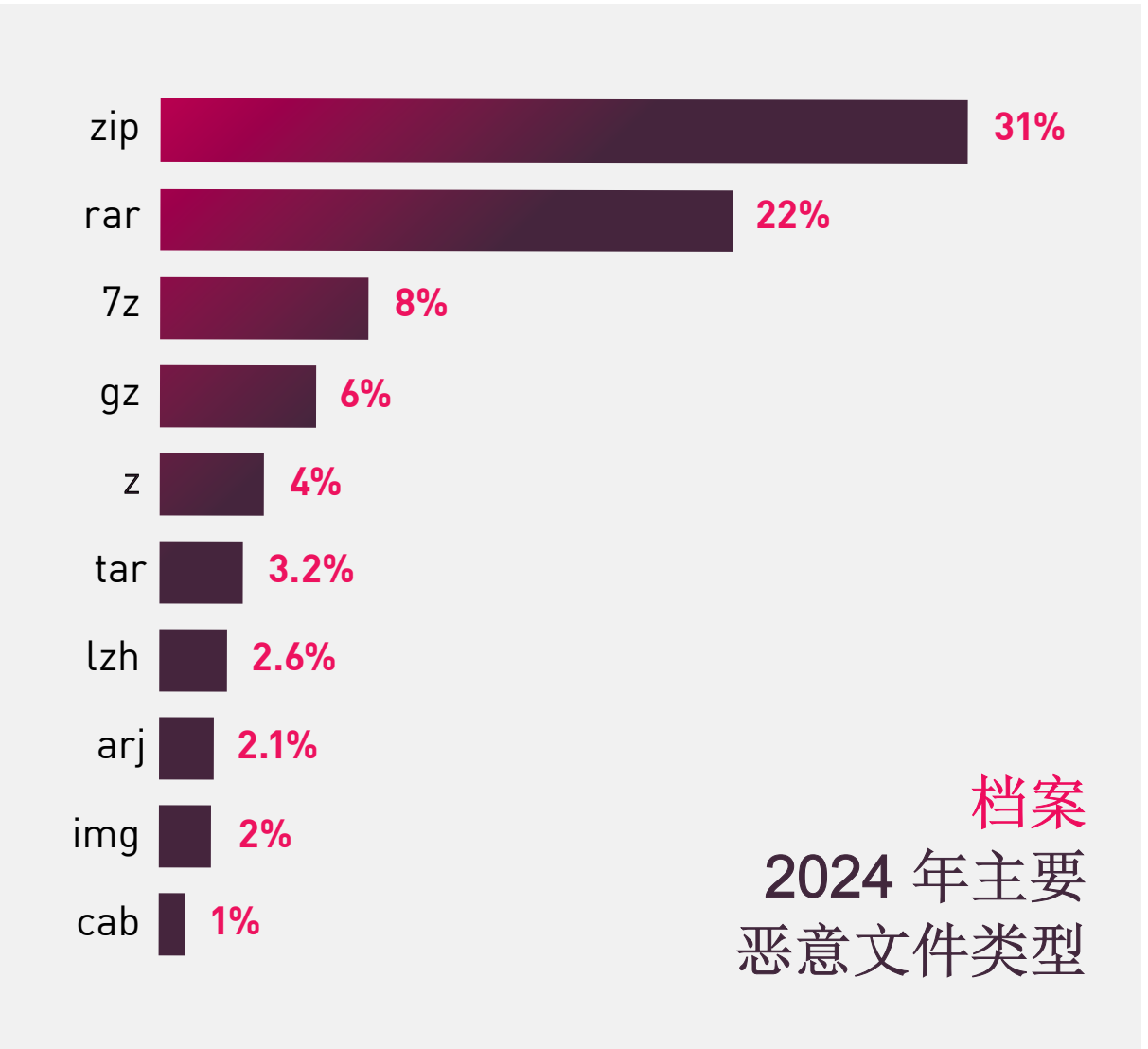


图 6 - 2024 年电子邮件和网络中的主要恶意档案文件类型。

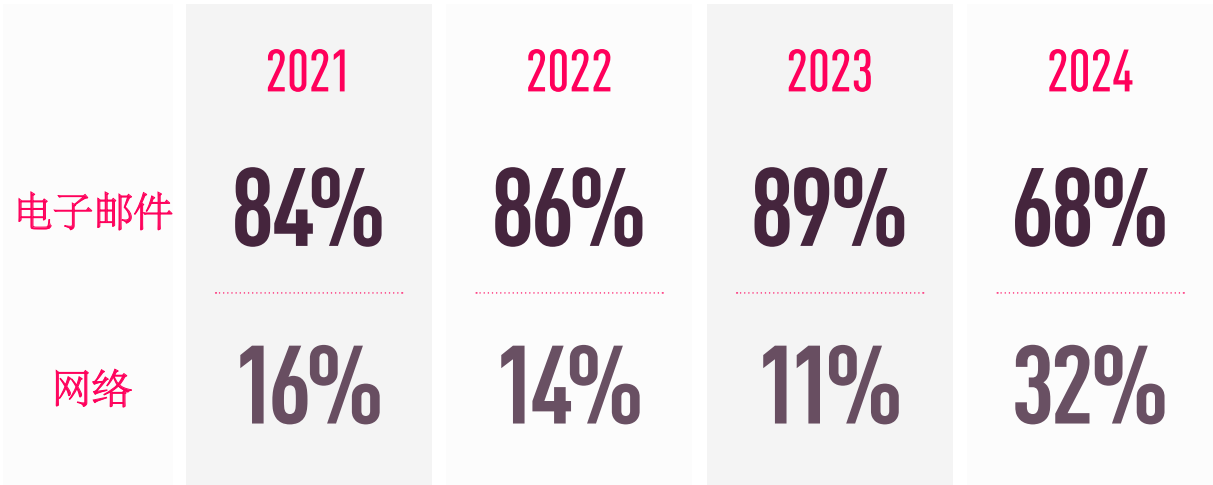


图 7 - 发送协议 — 2021 至 2024 年电子邮件与网络攻击向量。

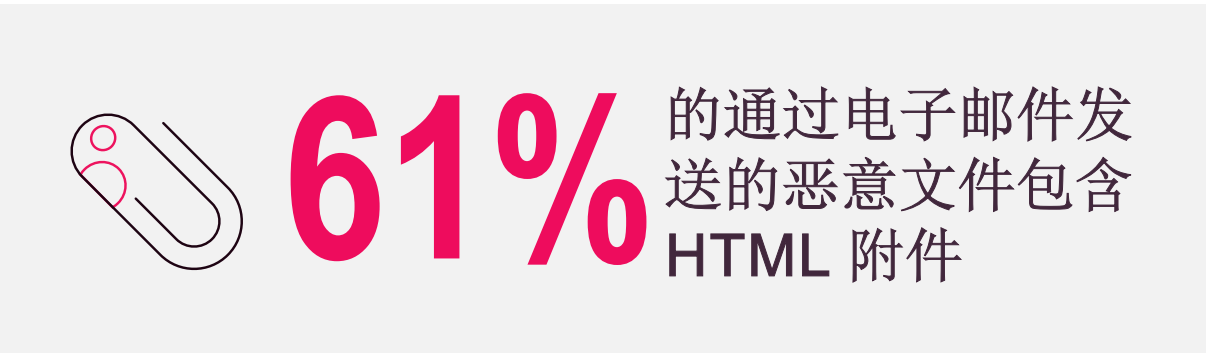
基于电子邮件的攻击仍然是主要的初始攻击向量，68% 的攻击源自电子邮件。尽管网络传递的攻击显著增加 (32%)，但这种情况仍在持续，这主要归因于基于受感染网站的恶意软件分发框架（如 *FakeUpdates*）依然占据着主导地位。

Office 文档中恶意宏攻击的减少导致了策略的转变：大多数恶意



电子邮件现在包含 HTML 文件或 PDF 文档。HTML 文件的恶意使用包括网络钓鱼和凭证窃取，通常通过复制合法的登录页面来实现。其它用例包括更高级的技术，如 HTML 走私、重定向到恶意网站、浏览器漏洞利用和其它方法。值得注意的是，61% 通过电子邮件传递的恶意文件包含 HTML 附件。

恶意 PDF 文件是另一种常见的攻击向量，在 22% 的恶意电子邮件中都能发现。这些通常涉及在文档中嵌入 JavaScript 代码



或嵌入式链接，这既可以触发恶意软件下载，也可以将受害者重定向到恶意网站。在某些情况下，PDF 文件会利用过时的 PDF 阅读器软件中的漏洞在受害者的机器上执行代码。

恶意档案文件在网络攻击活动中也已成为一种常见的攻击向量，比如 ZIP、RAR、7z 等格式都经常被利用。在这些格式中，ZIP 文件最为常见，占恶意档案文件的 31%，其次是 RAR 文件占 22%，7z 文件占 8%。档案文件对于躲避检测特别有效，因为

01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议

它们能压缩恶意有效载荷并混淆其内容，使安全解决方案更难对其进行分析。

当攻击者使用有密码保护的档案时，安全机制面临着一个显著的挑战。如果没有密码，就无法扫描这些档案中的恶意内容，而密码通常包含在电子邮件的正文中或单独共享。通过对档案内容进行加密，威胁行为者试图绕过自动防御。一旦解压，这些档案可以直接将恶意软件传送到受害者的系统中。攻击者经常使用多阶段传递，初始的档案文件包含看似无害的文档或脚本，当执行时，会从远程服务器下载实际的恶意有效载荷。档案文件使用的增加突显了网络犯罪分子不断演变的策略，以利用电子邮件安全中的漏洞，并利用用户的信任来成功实施攻击。

恶意 DLL 文件（动态链接库），通常在压缩档案中传递，常用于 **DLL 侧载**或 **DLL 劫持**技术。在这些情况下，攻击者通过将恶意 DLL 文件放置在与受信任的可执行文件相同的目录中来利用易受攻击的合法应用程序。当应用程序运行时，它会加载恶意 DLL 而不是预期的 DLL，从而允许攻击者执行任意代码。这种技术对于躲避检测特别有效，因为合法应用程序充当了恶意有效载荷和 DLL 的受信任载体。

网络传递攻击通常依靠隐蔽式下载、通过被入侵的网站或欺骗性广告来传递这些文件，这也突出了网络过滤、安全软件定期更新和提高用户意识以减少此类威胁的重要性。网络传递的恶意文件呈上升趋势，利用 **EXE**、**DLL** 和 **PDF** 等文件格式来分发恶意软件。其中，**EXE** 文件最为普遍，占网络传递恶意文件的 **54%**。这些可执行文件经常伪装成合法软件或更新，诱使用户下载并运行它们。**DLL** 文件占这些攻击的 **11%**，而 **PDF** 文件占 **8%**。



01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议

全球

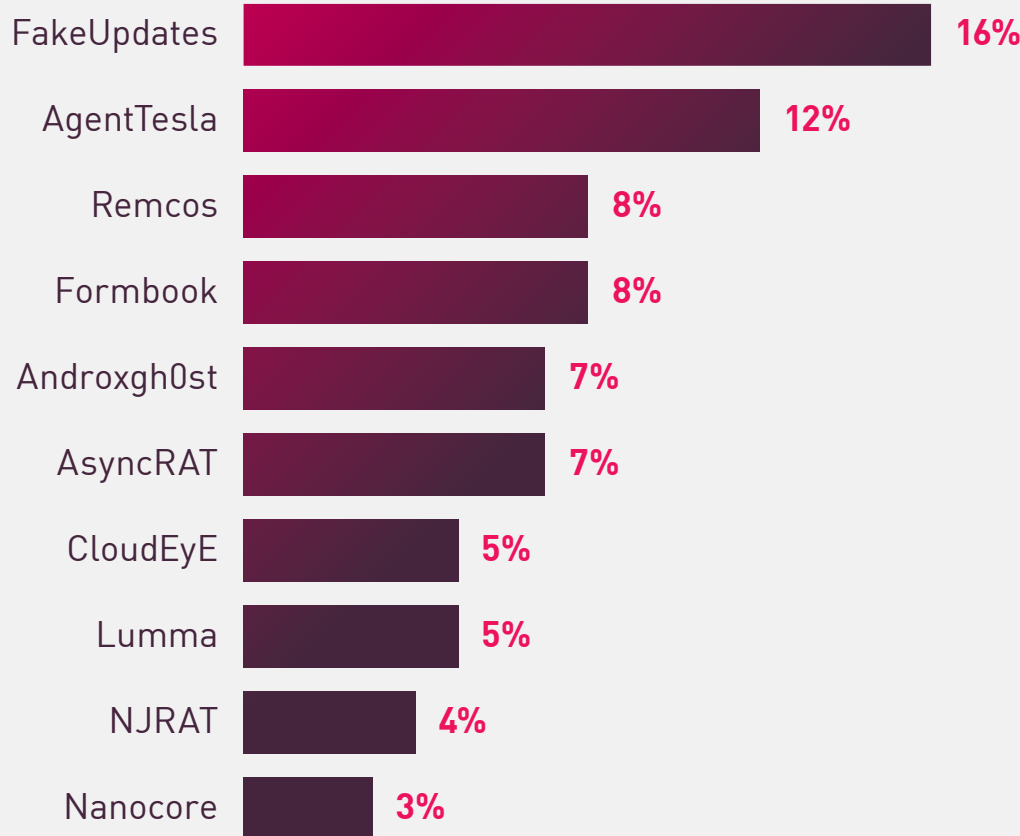


图 8 - 全球最流行的恶意软件 – 2024 年。

美洲

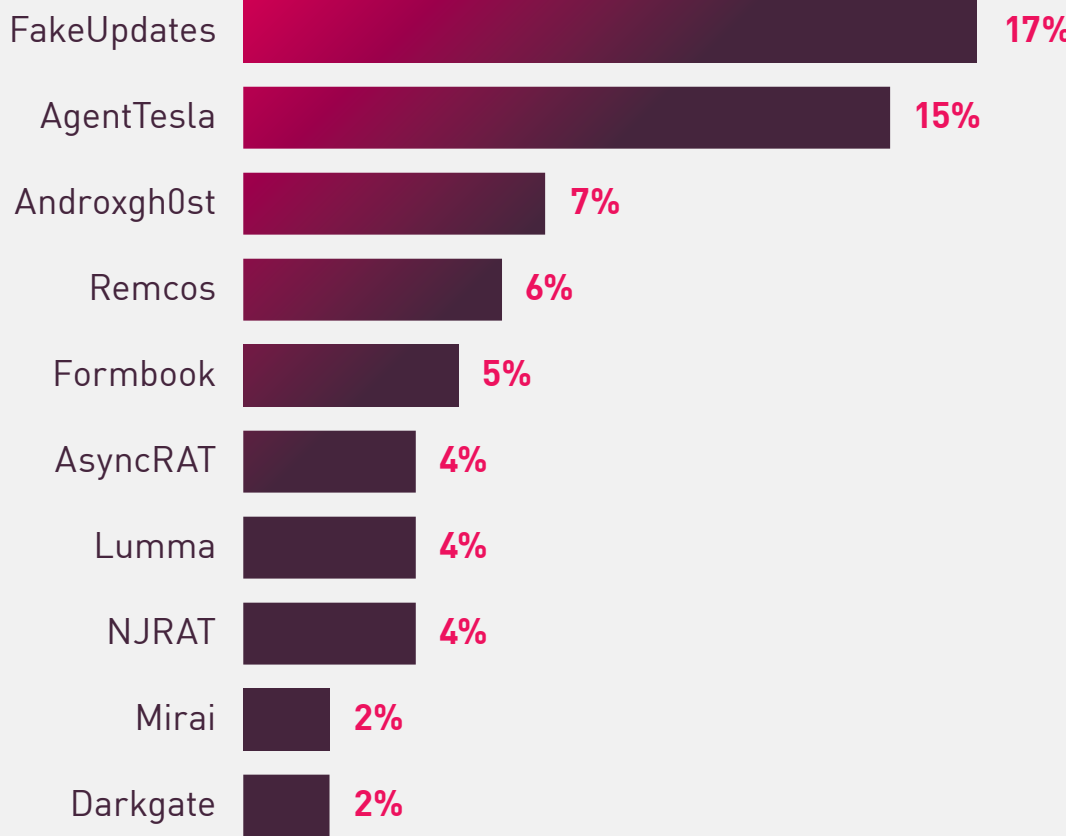


图 9 - 美洲最流行的恶意软件 – 2024 年。

欧洲、中东和非洲 (EMEA)

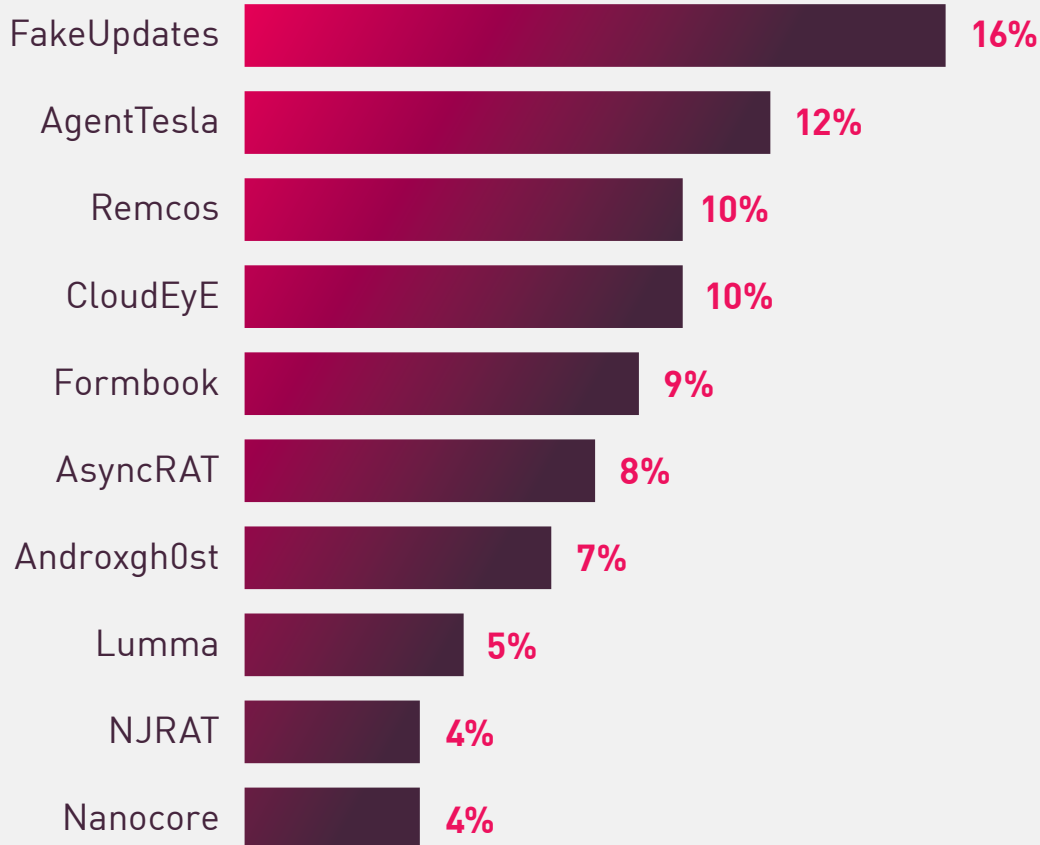


图 10 – 欧洲、中东和非洲地区最流行的恶意软件 – 2024 年。

亚太地区 (APAC)

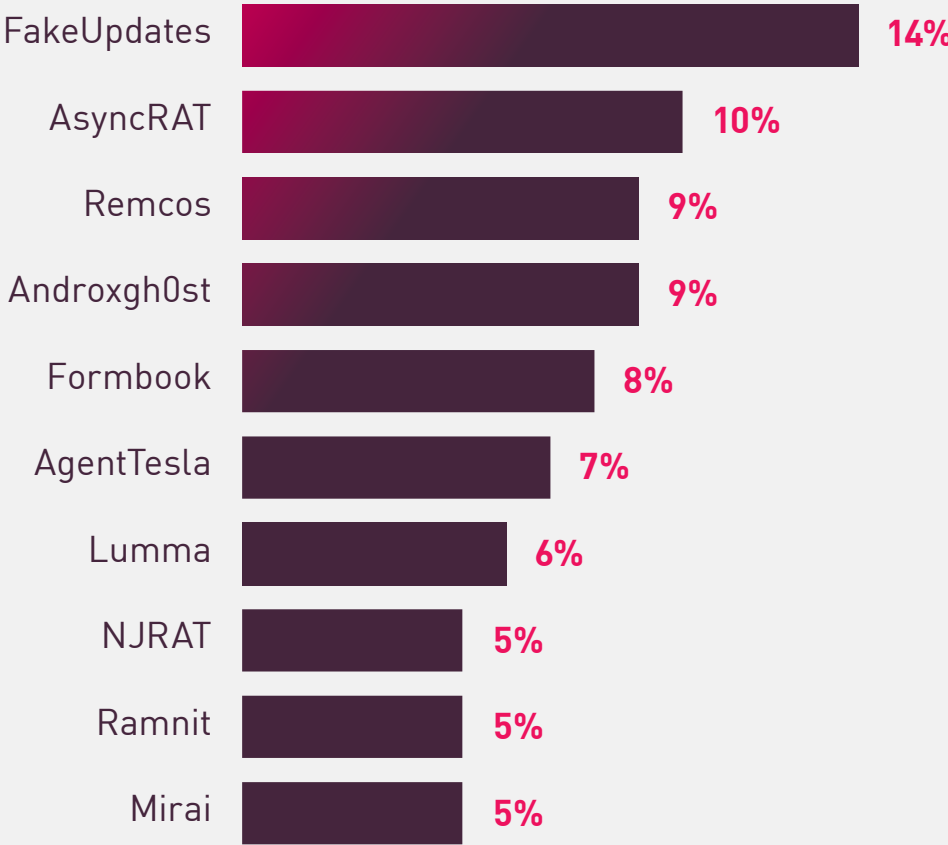


图 11 - 亚太地区最流行的恶意软件 – 2024 年。

全球恶意软件统计数据

以下各部分中呈现的数据比较均基于 2024 年 1 月至 12 月期间从“[Check Point ThreatCloud 网络威胁情报地图](#)”获取的数据。

对于以下每个区域，我们展示了 2024 年最流行的恶意软件，以及每个恶意软件家族对企业网络安全的影响的百分比。

全球主要恶意软件分析

我们的分析突出了由 Check Point 的网络保护所识别出的最常被检测到的恶意软件家族。需要注意的是，这些家族不一定是 最复杂或最危险的，但却是分布最广泛的。

FakeUpdates (SocGhosh) 在 2024 年继续位居 Check Point 最流行恶意软件排行榜的首位。这种恶意软件的运作依赖于被入侵网站的网络来分发伪装成虚假浏览器或软件更新提示的恶意软件。这些具有欺骗性的提示诱使用户下载并执行基于 JScript 的下载器，进而下载其它恶意软件。被入侵网站的网络被归因于 TA569，一个著名的初始访问代理 (IAB)，其可能按照每次安装付费 (PPI) 的模式运作。TA569 为其它经常部署勒索软件或其它恶意负载的网络犯罪分子提供系统访问权限。

Qbot 作为最久远和最多功能的恶意软件家族之一，在过去一年里排名经历了急剧的下降。此前在我们的排名中位居第二，但在 2023 年末，在由 FBI 领导的一次多国行动（该行动针对并拆除了其基础设施）之后，Qbot 的活动受到了极大的干扰。从那以后，许多之前分发 Qbot 的威胁行为者转向了其它恶意软件，包括“DarkGate”。

AgentTesla 自 2020 年以来一直在我们最常见的恶意软件列表中，专门从受感染的系统中窃取敏感信息。Check Point 研究院持续监测这一在全球活动中经常部署的信息窃取软件。AgentTesla 可以从受攻击的机器中提取各种数据，包括按键记录、网络浏览器的登录凭证和电子邮件客户端的凭证。

01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议

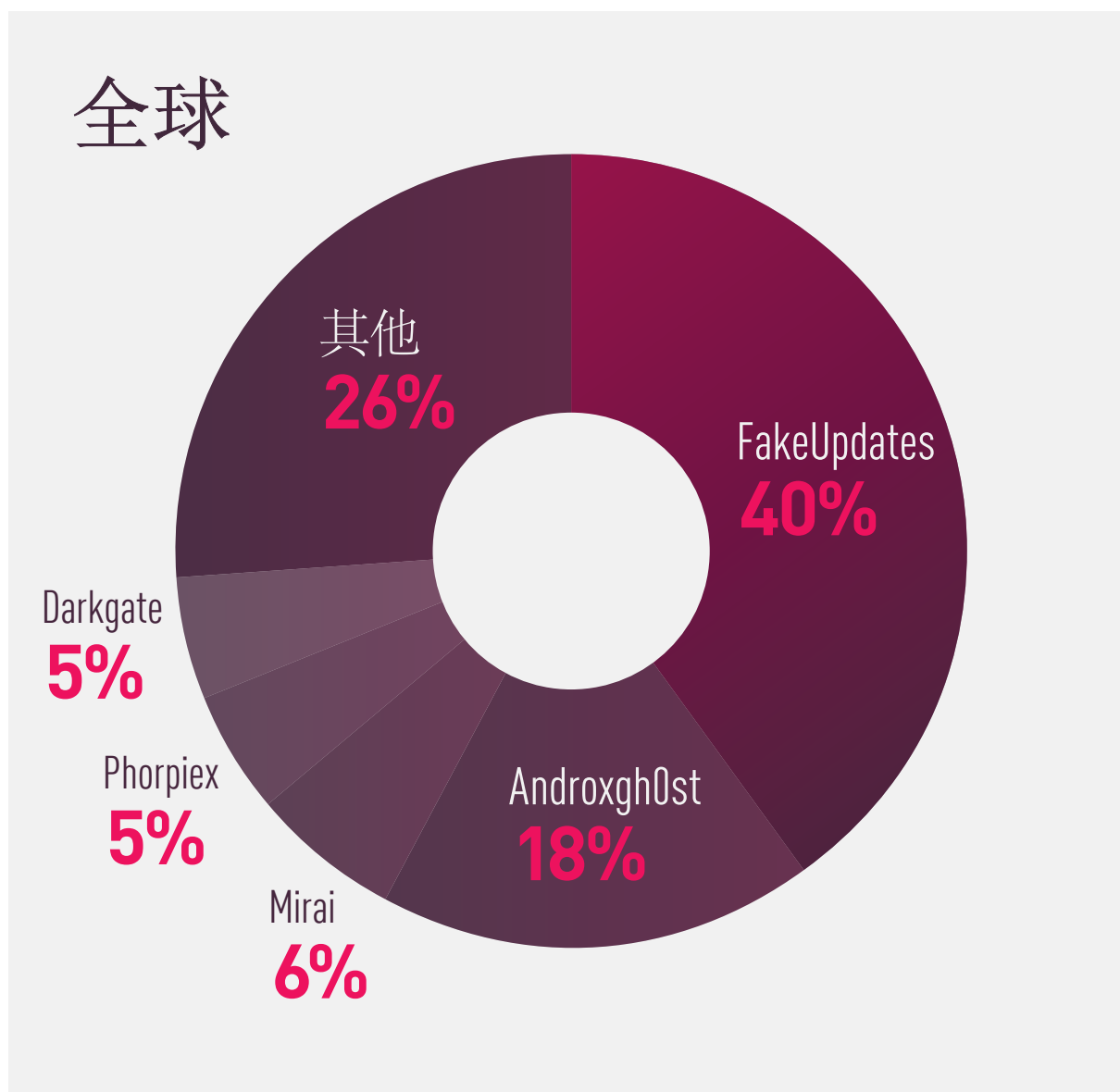


图 12 - 全球最流行的多用途恶意软件 – 2024 年。

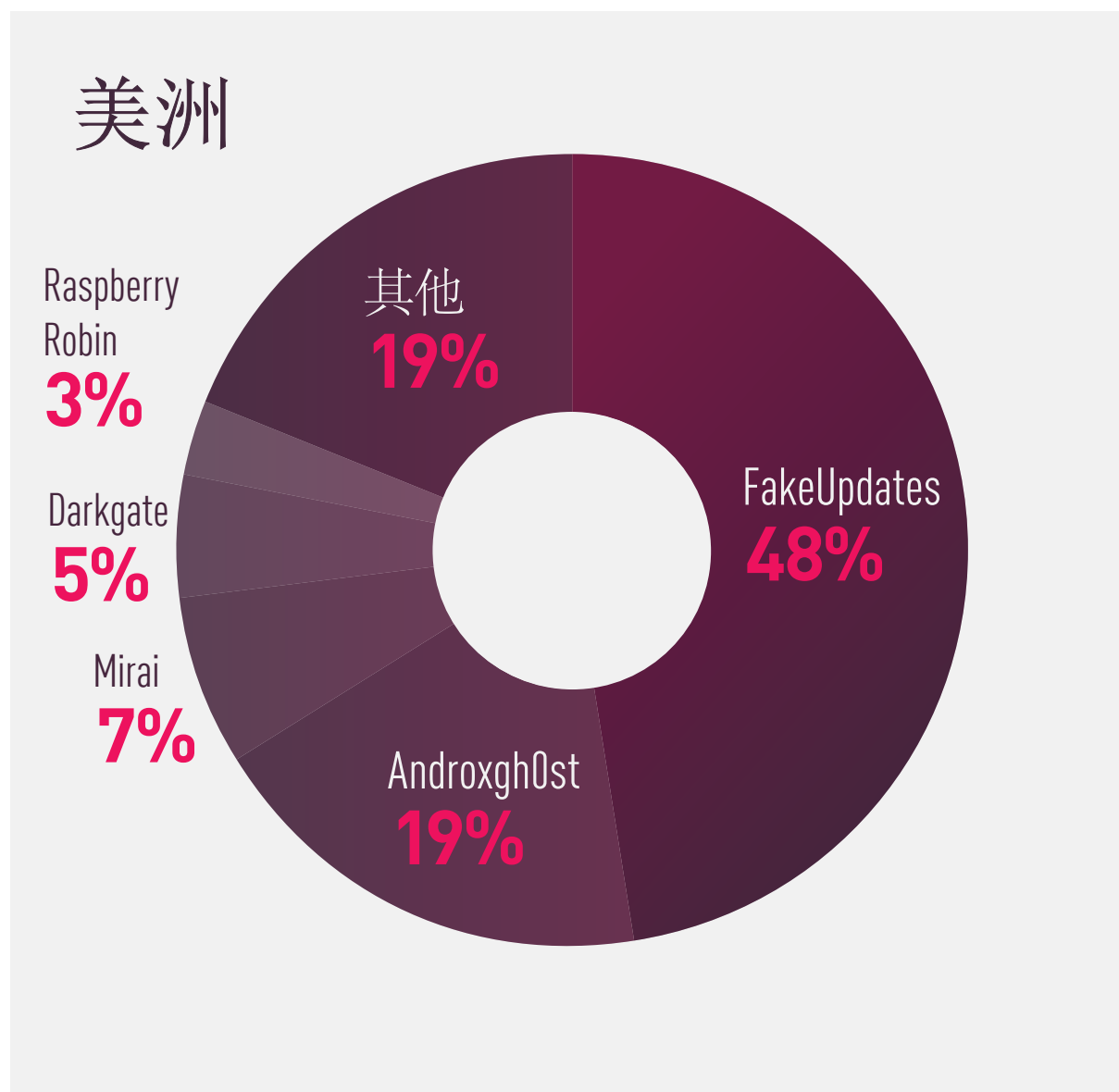


图 13 - 美洲最流行的多用途恶意软件 – 2024 年。

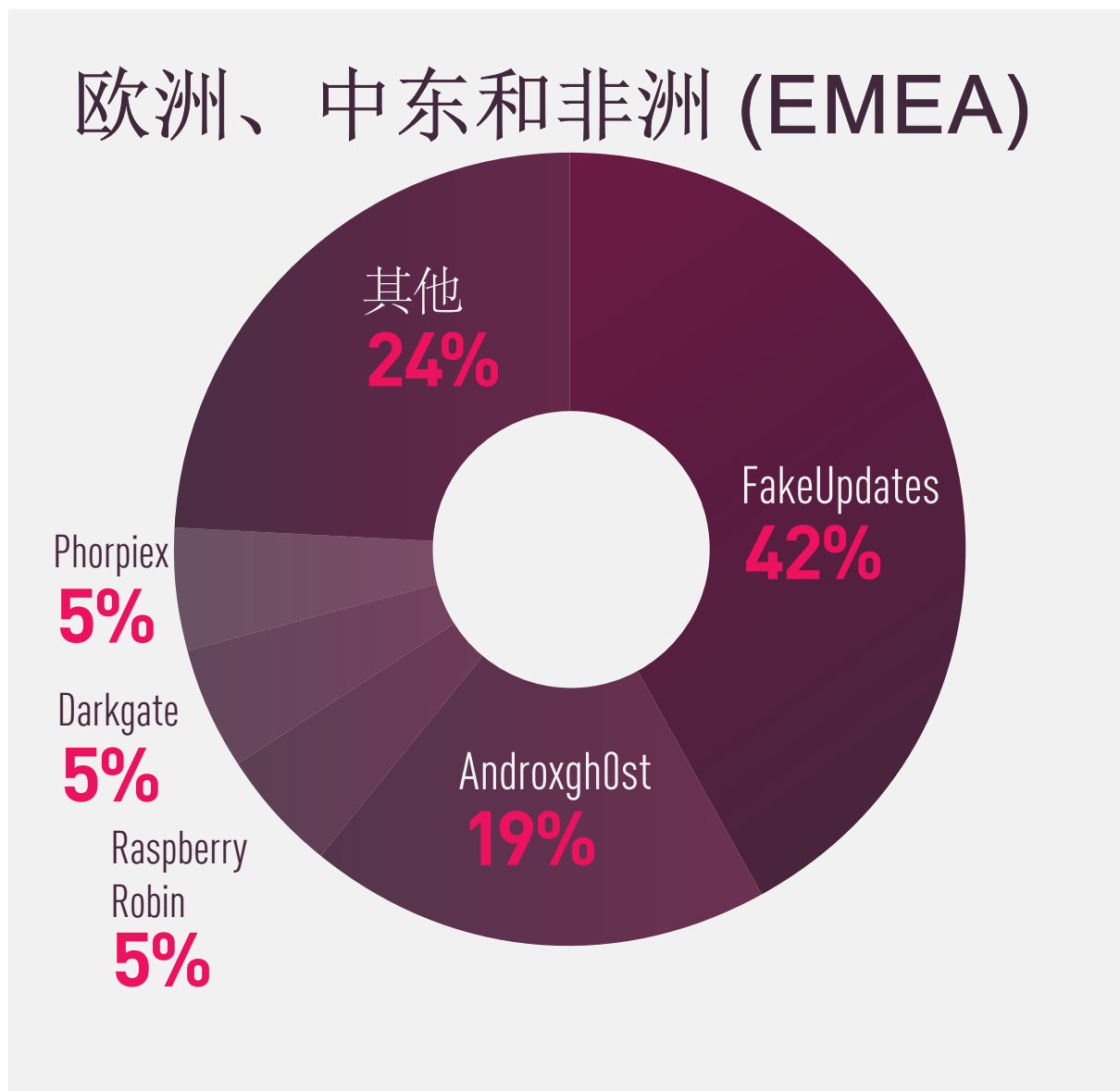


图 14 - 欧洲、中东和非洲地区最流行的多用途恶意软件 – 2024 年。

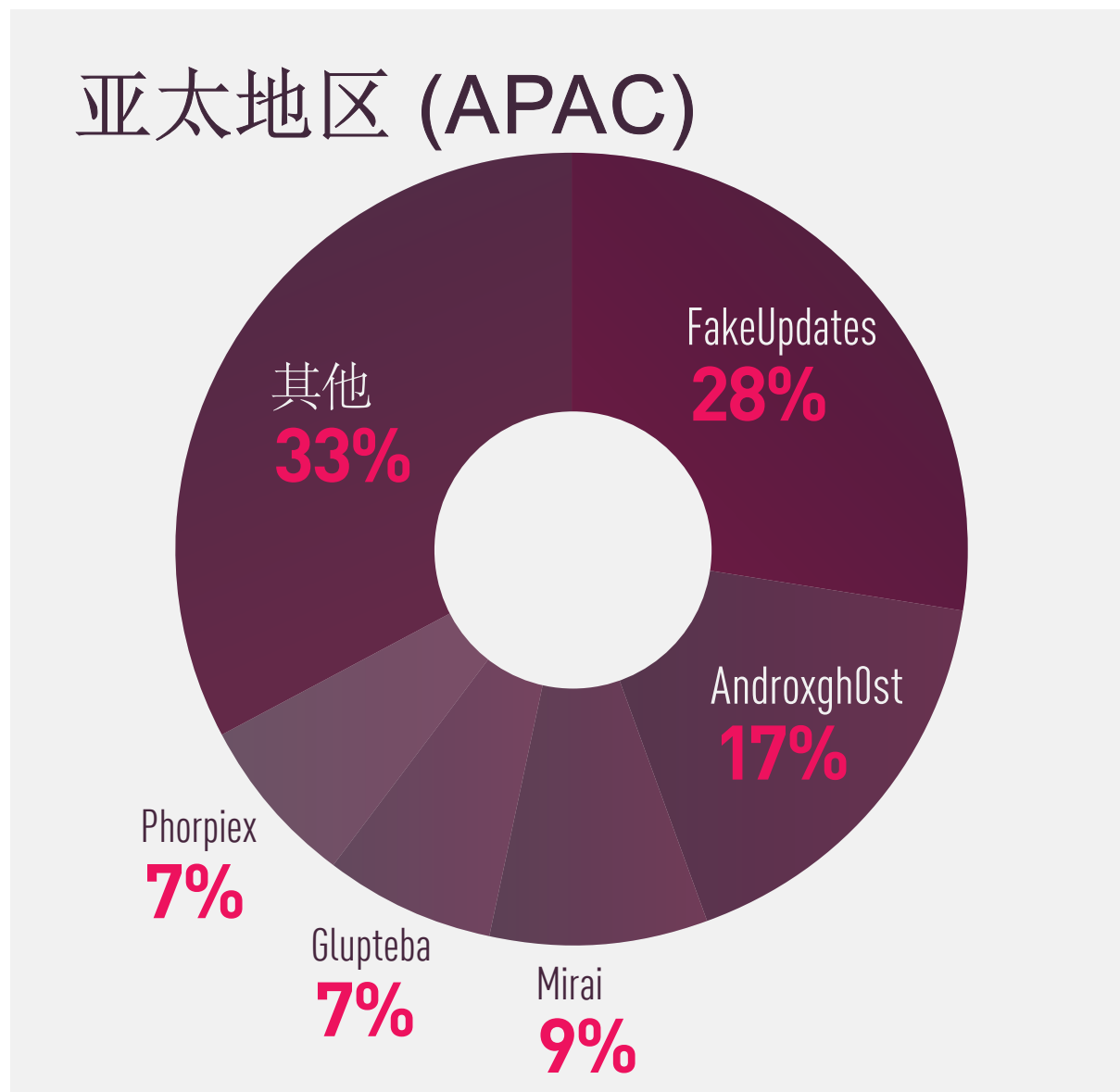


图 15 - 亚太地区最流行的多用途恶意软件 – 2024 年。

多用途恶意软件全球分析

多用途恶意软件包括远程访问木马 (RAT)、僵尸网络和银行木马 — 随着恶意软件功能的发展，这些类别在不断更新。恶意软件的分类是动态的，当它进行额外的升级后可能需要重新分类到新的类别。**Check Point** 持续监测这些发展，更新恶意软件的分类，偶尔还会重新定义整个类别，以更好地反映不断变化的威胁形势。

DarkGate 是多面性恶意软件的一个典型例子。除了其核心的 RAT、下载器和信息窃取功能外，**DarkGate** 还具备加密货币挖矿能力，这使它难以完全归入传统的恶意软件类别。然而，这种复杂性并非异常。这些类别对于理解特定攻击背后的主要意图以及识别网络犯罪生态系统中的总体趋势仍然至关重要。

全年密集的执法活动极大地重塑了网络威胁形势。2024 年 5 月，一个多国联盟执行了“终局行动”，目标是负责分发恶意软件的僵尸网络基础设施。这次行动破坏掉了与 **IcedID**、**Smoke loader**、**Pikabot**、**Bumblebee**、**SystemBC** 和 **Trickbot** 等组织相关的恶意软件分发网络。该行动拆除了 100 多台服务器，查封了 2000 多个域名，并逮捕了 4 人 — 1 人在亚美尼亚，3 人在乌克兰 — 同时还冻结了非法资产。

僵尸网络一直在恶意软件分发中起着核心作用。它们的瓦解引发了恶意软件生态系统的重大变化，包括犯罪分子明显的转向信息窃取软件，信息窃取软件通常更加分散，在个体网络犯罪分子中被广泛使用。这种分散性使通过集中执法行动来打击信息窃取软件的活动更加困难。

由于这些干扰，与去年相比，多用途恶意软件市场已经发生了很大的变化。“**Qbot**”和“**Emotet**”，这两个此前占据主导地位的恶意软件，已经被“**FakeUpdates**” (40%)、“**AndroxghOst**” (18%)、“**Phorpiex**” (5%)、“**Darkgate**” (5%) 和“**Raspberry Robin**”等恶意软件家族所取代。

01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议

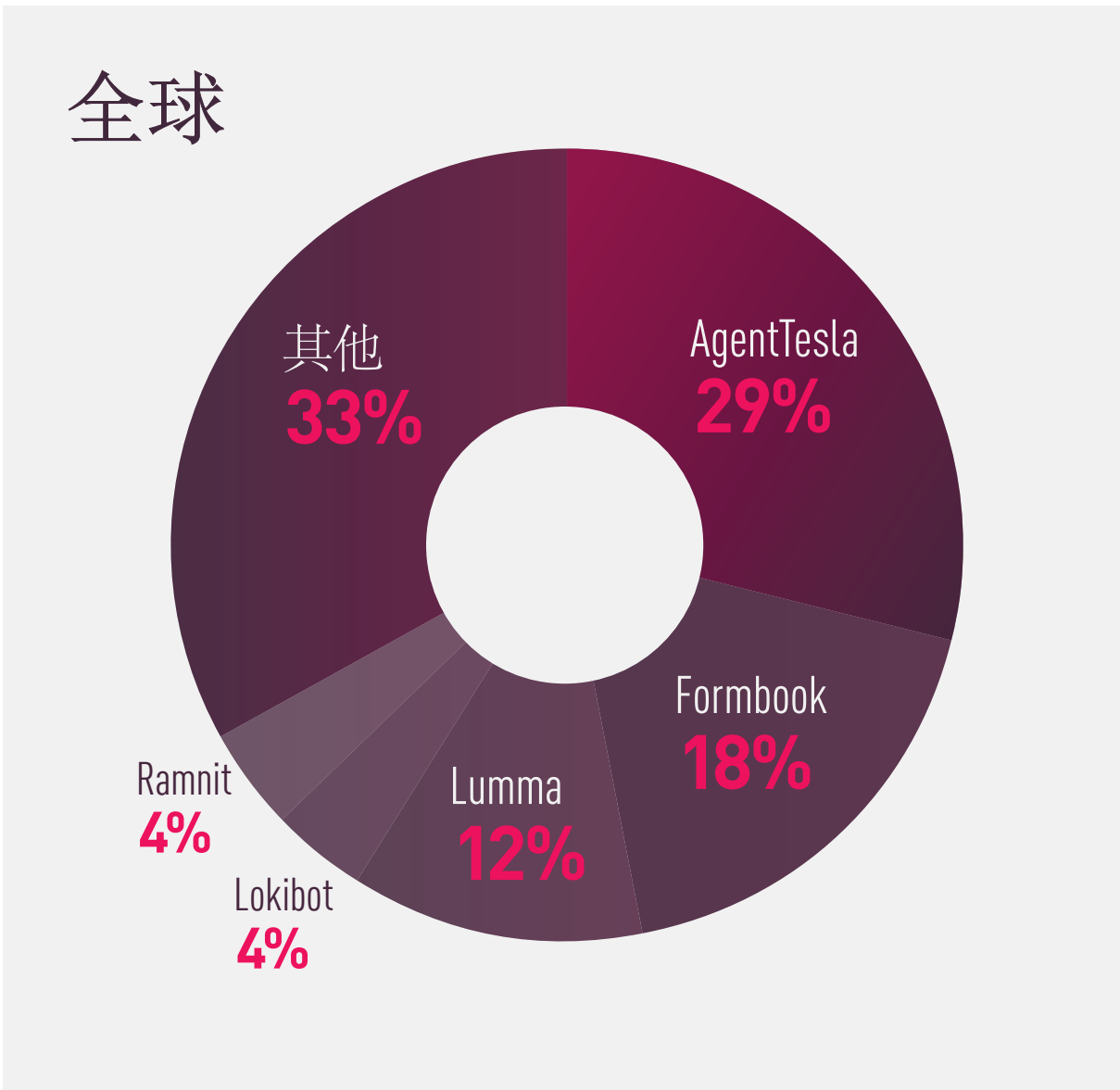


图 16 - 全球主要信息窃取恶意软件 – 2024 年。

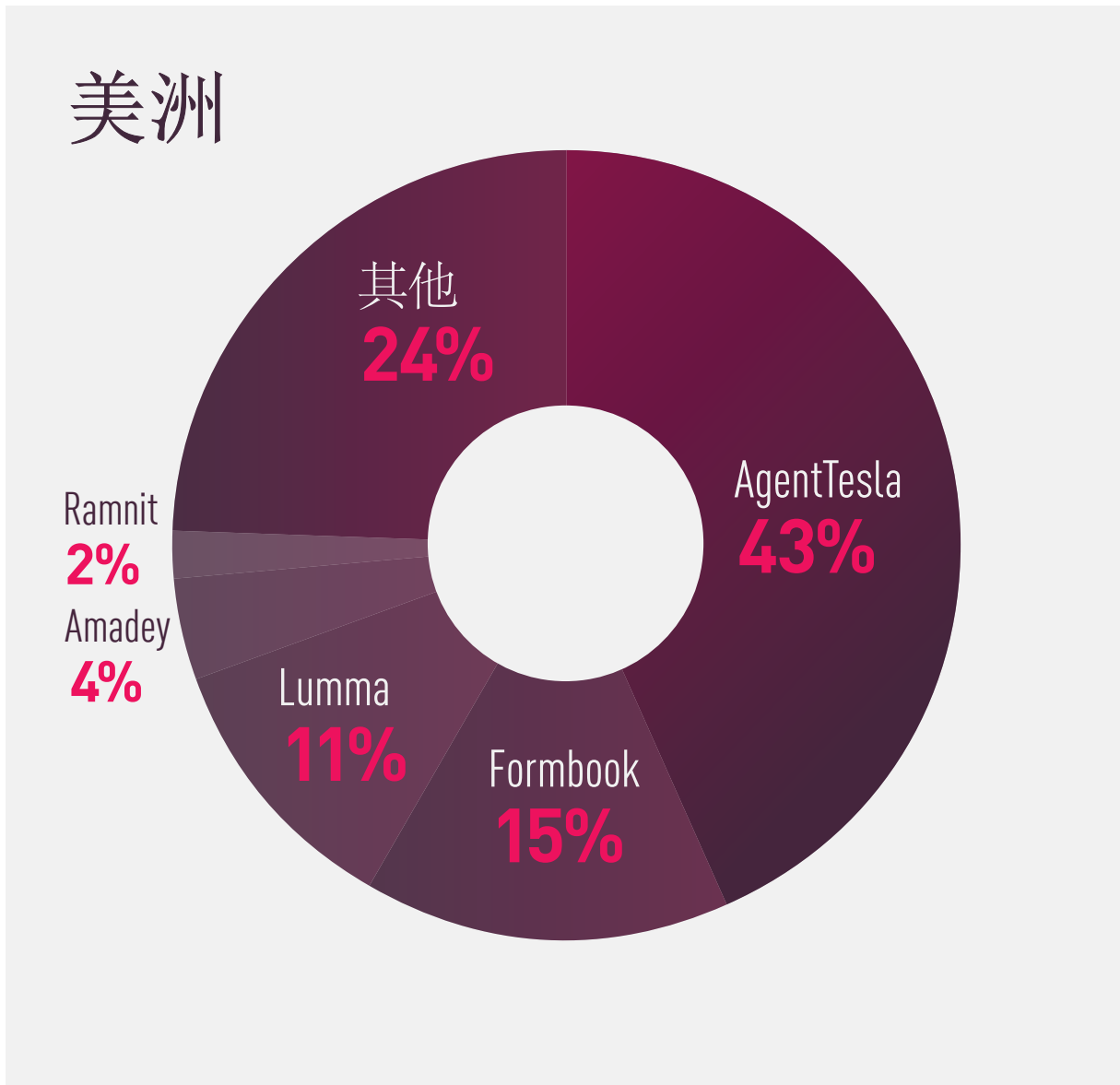


图 17 - 美洲主要信息窃取恶意软件 – 2024 年。

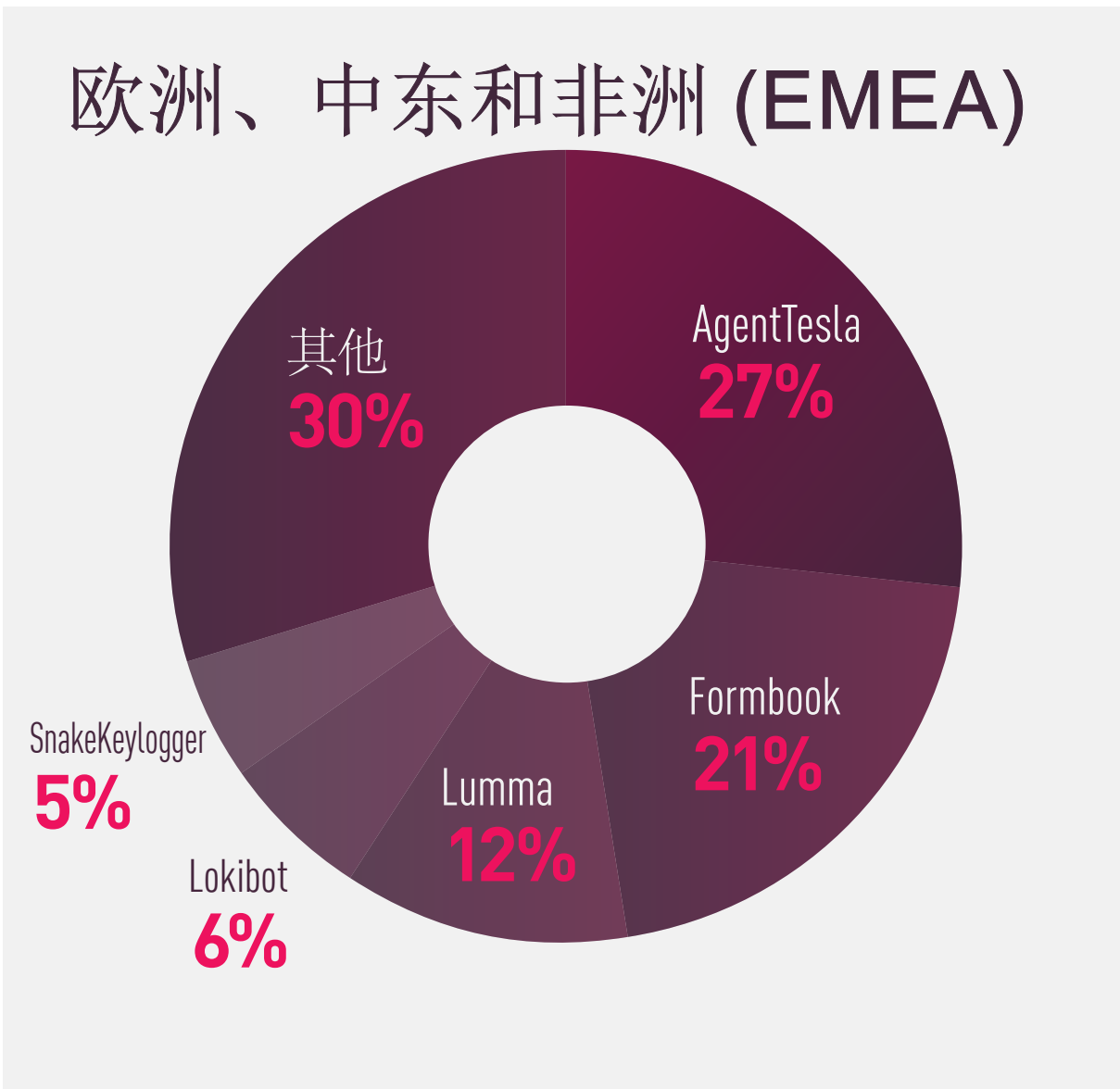


图 18 - 欧洲、中东和非洲地区主要信息窃取恶意软件 – 2024 年。

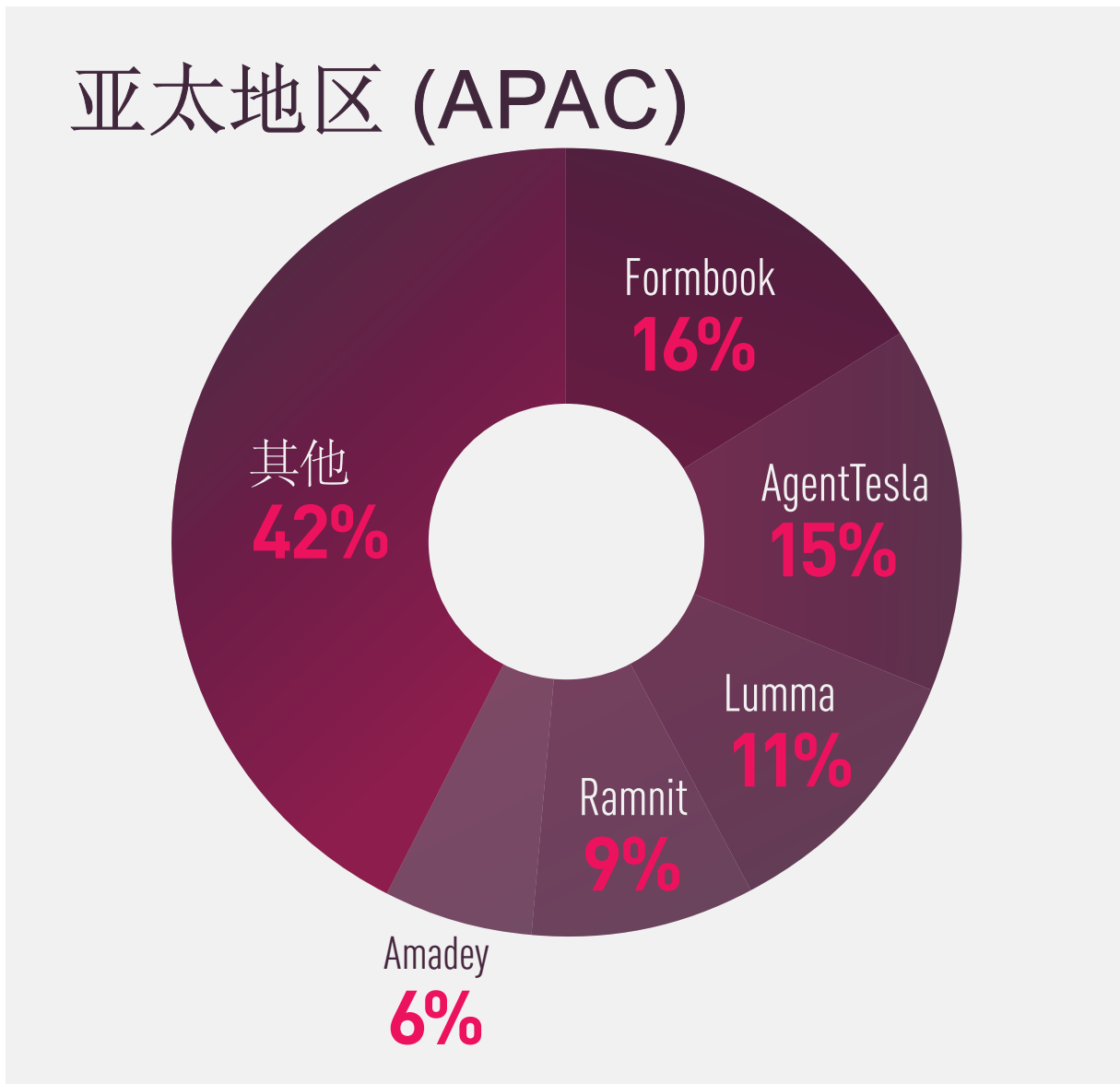


图 19 - 亚太地区主要信息窃取恶意软件 – 2024 年。

信息窃取恶意软件全球分析

在 2024 年，信息窃取恶意软件的格局继续由先前已知的、既定的威胁所主导，例如 [AgentTesla](#)，其占有所有检测的 29%，[Formbook](#) 占检测的 18%，[Lumma](#) 占检测的 12%。尽管没有出现重大的新威胁，但与上一年相比，信息窃取软件的感染尝试仍增加了 58%，并且有多种可能的原因可以解释这一现象。

执法行动打乱了传统的恶意软件分发渠道，例如 2024 年 5 月的“[终局行动](#)”，该行动针对像 [IcedID](#)、[Smokeloader](#) 和 [Trickbot](#) 这样的主要僵尸网络，拆除了 100 多台服务器，并查封了 2000 多个域名。网络犯罪分子可能正在转向信息窃取软件作为替代。此外，网络犯罪分子生态系统的成熟增加了对信息窃取软件所获取的数据（通常被称为“日志”）的需求。这些包含凭证和个人数据等敏感信息的日志通过地下市场出售给其他试图利用这些信息的网络犯罪分子。

因此，信息窃取软件在不断变化的威胁形势中发挥着越来越关键的作用。后续章节对这些趋势进行了全面分析。

Check Point 研究院所调查的“[Styx Stealer](#)”是今年出现的一种新的信息窃取软件。[Styx](#) 源自 [Phemedrone Stealer](#)，旨在窃取敏感信息，如各种浏览器中保存的密码、[Cookie](#)、自动填充数据、加密货币钱包详细信息以及像 [Telegram](#) 和 [Discord](#) 这样的消息平台的会话数据。它还收集系统信息，包括硬件详情和外部 IP 地址，并且可以在执行其有效负载之前捕获屏幕截图以评估环境。值得注意的是，[Styx Stealer](#) 具有自动启动、剪贴板监控、加密剪切、增强的沙盒逃避和反分析技术等功能。与其免费提供的老版本不同，[Styx Stealer](#) 通过订阅模式出售，价格从 75 美元的月付到 350 美元的终身订阅等模式。

01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议

全球

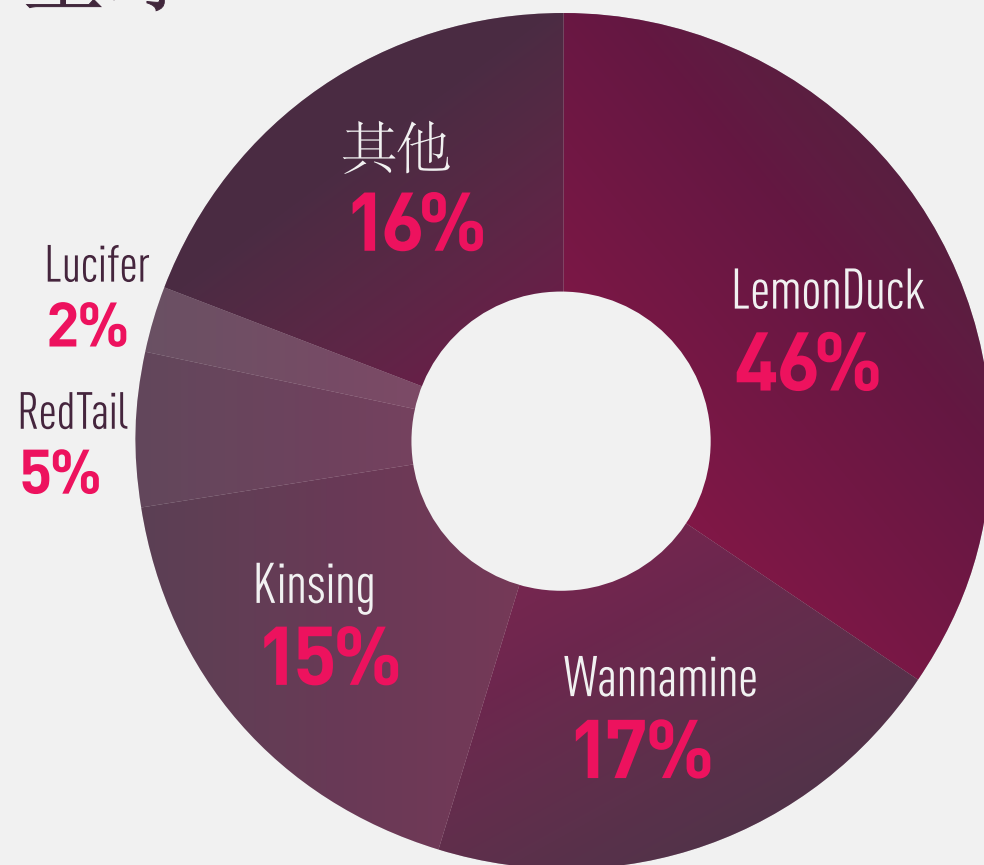


图 20 - 全球主要加密货币挖矿恶意软件 – 2024 年。

美洲

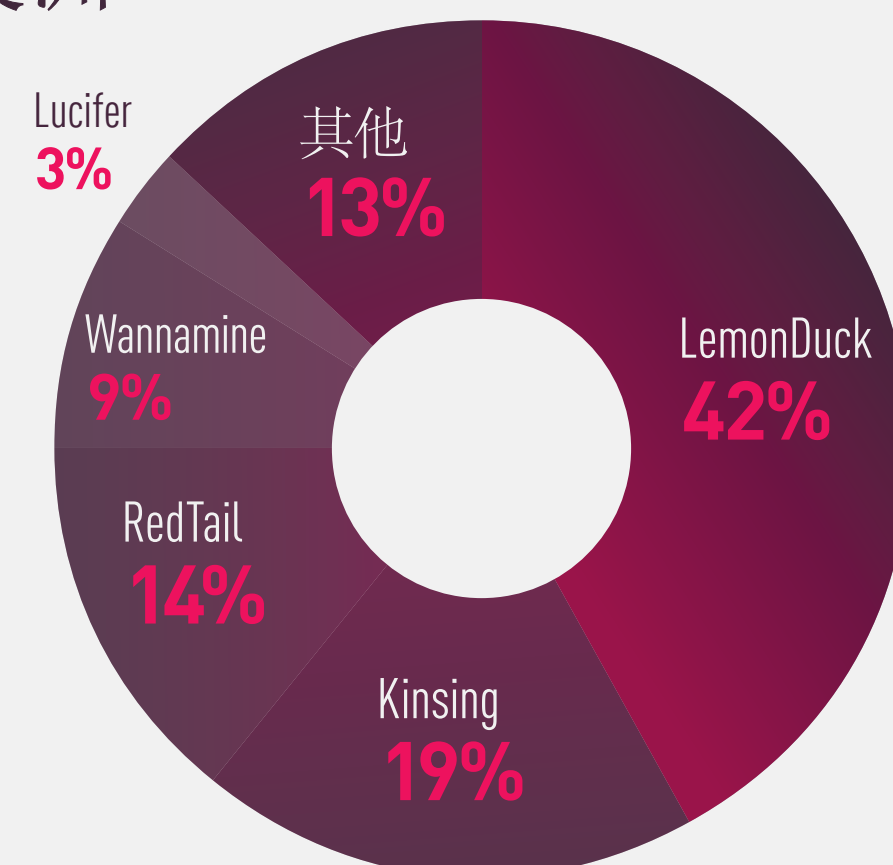


图 21 - 美洲主要加密货币挖矿恶意软件 – 2024 年。

欧洲、中东和非洲 (EMEA)

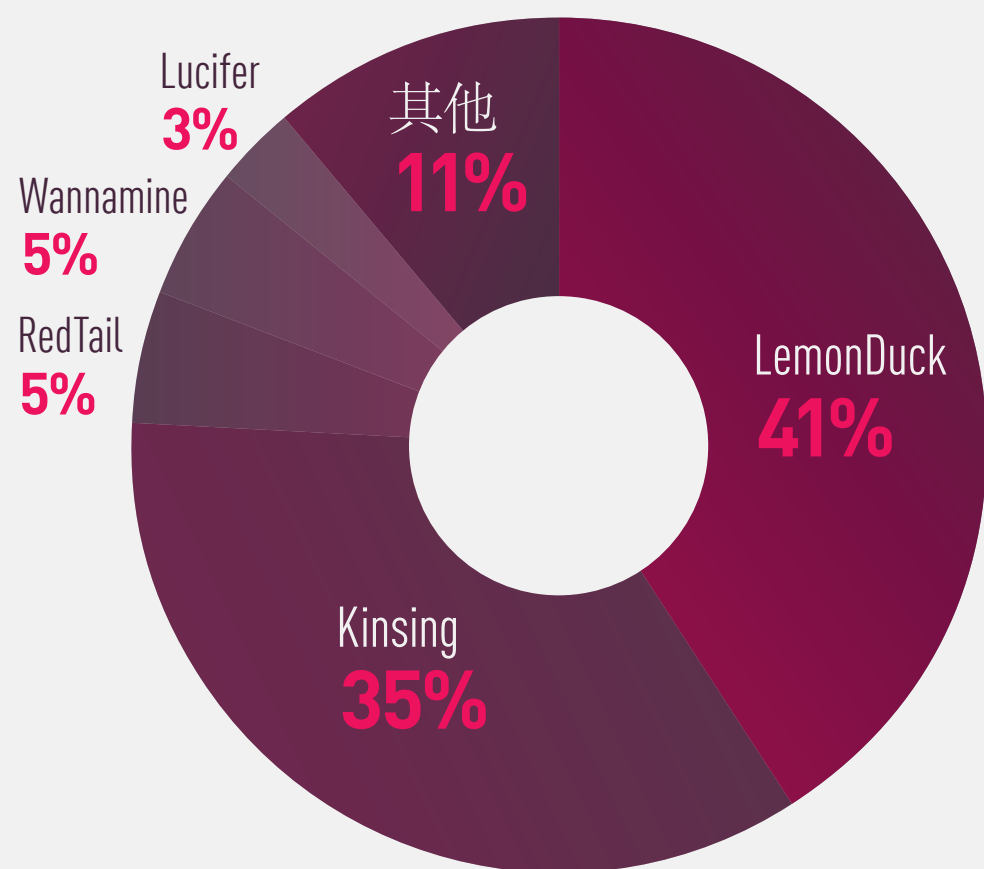


图 22 - 欧洲、中东和非洲地区主要加密货币挖矿恶意软件 – 2024 年。

亚太地区 (APAC)

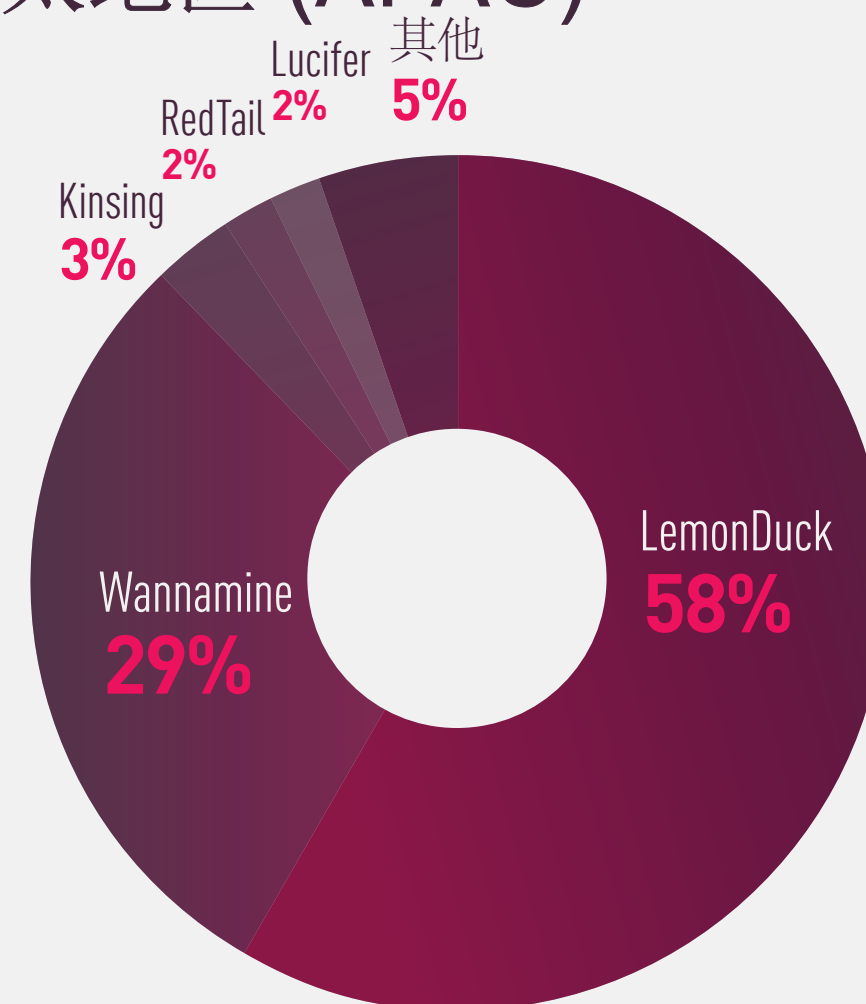


图 23 - 亚太地区主要加密货币挖矿恶意软件 – 2024 年。

加密货币挖矿程序全球分析

2024 年，加密货币领域经历了重大的监管和市场发展，从而出现了上升趋势。比特币在 12 月突破了 10 万美元大关，达到了 103,649 美元的历史新高。然而，加密货币挖矿攻击的数量有所下降，从 2023 年影响 9% 的公司降至 2024 年仅影响 2%。

非法加密货币挖矿程序专注于门罗币 (XMR)，是因为它强大的隐私功能使其交易几乎无法追踪，而且对 CPU 友好，计算要求较低。然而，门罗币的价值在全年都相对停滞不前，而其挖矿难度（挖掘门罗币所需的计算工作量）从 1 月份的平均 260G 几乎翻倍到 12 月份的近 450G。难度的急剧增加大幅降低了挖矿的盈利能力，许多非法加密货币挖矿业务规模缩减，导致加密货币挖矿攻击减少。

在 2024 年，“**LemonDuck**” 仍然是最流行的加密货币挖矿恶意软件株系之一，在所有的加密货币挖矿攻击尝试中有 46% 部署了它。**LemonDuck** 最初在 2018 年被发现，随后从一个简单的加密货币挖矿程序演变成了一种高度复杂、模块化和跨平台的恶意软件，其功能现在包括凭证窃取、自我传播和无文件的内存挖矿操作。这些新增功能使其用途广泛且难以检测。最近的活动表明，**LemonDuck** 的运营商正在积极利用服务器消息块 (SMB) 漏洞，特别是“永恒之蓝”漏洞，来渗透 Windows 系统。**LemonDuck** 活动使用了各种攻击向量，包括带有恶意附件的钓鱼邮件、针对 RDP 和 SSH 的暴力破解攻击、包含 .LNK 文件的武器化 U 盘以及其它渗透技术。

01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议

全球

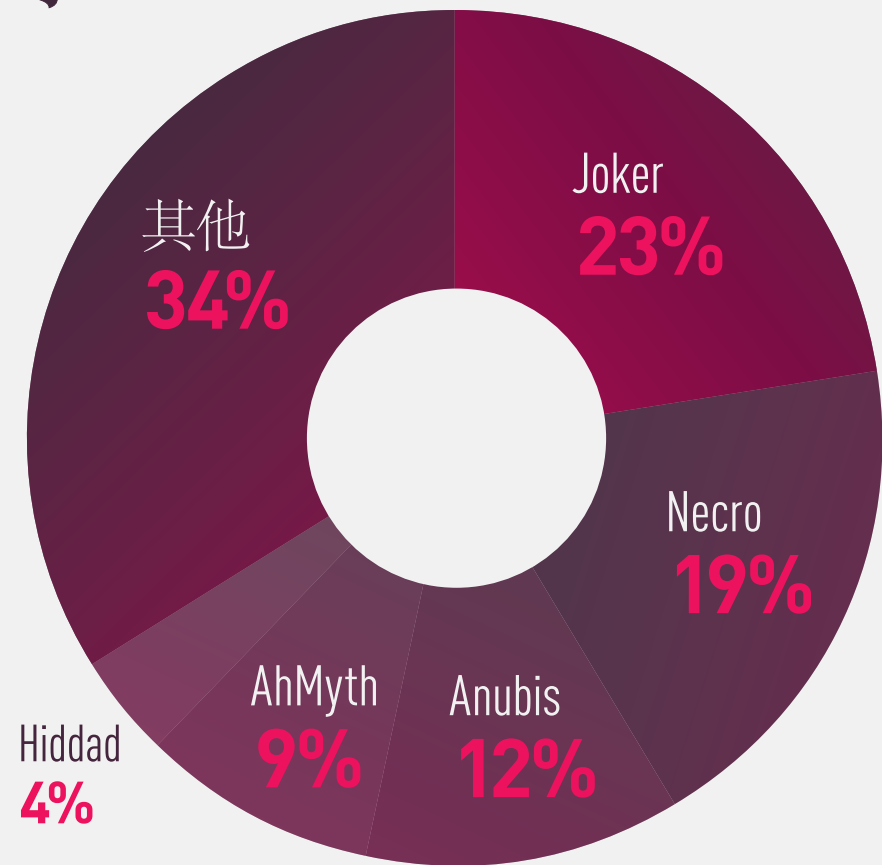


图 24 - 全球主要移动终端恶意软件 – 2024 年。

美洲

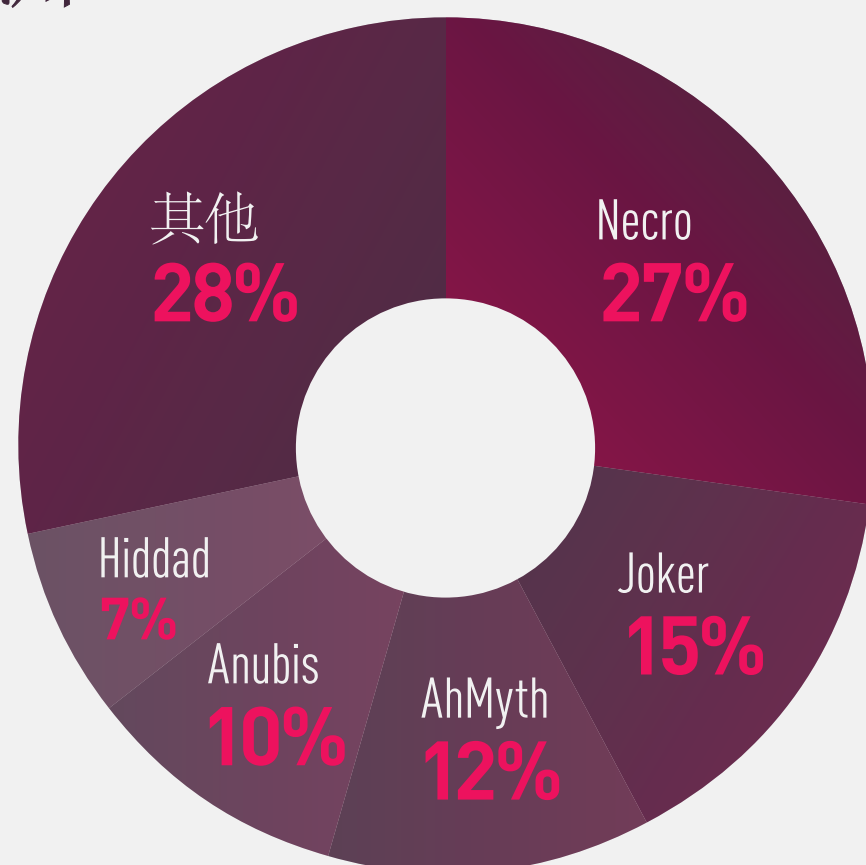


图 25 - 美洲主要移动终端恶意软件 – 2024 年。

欧洲、中东和非洲 (EMEA)

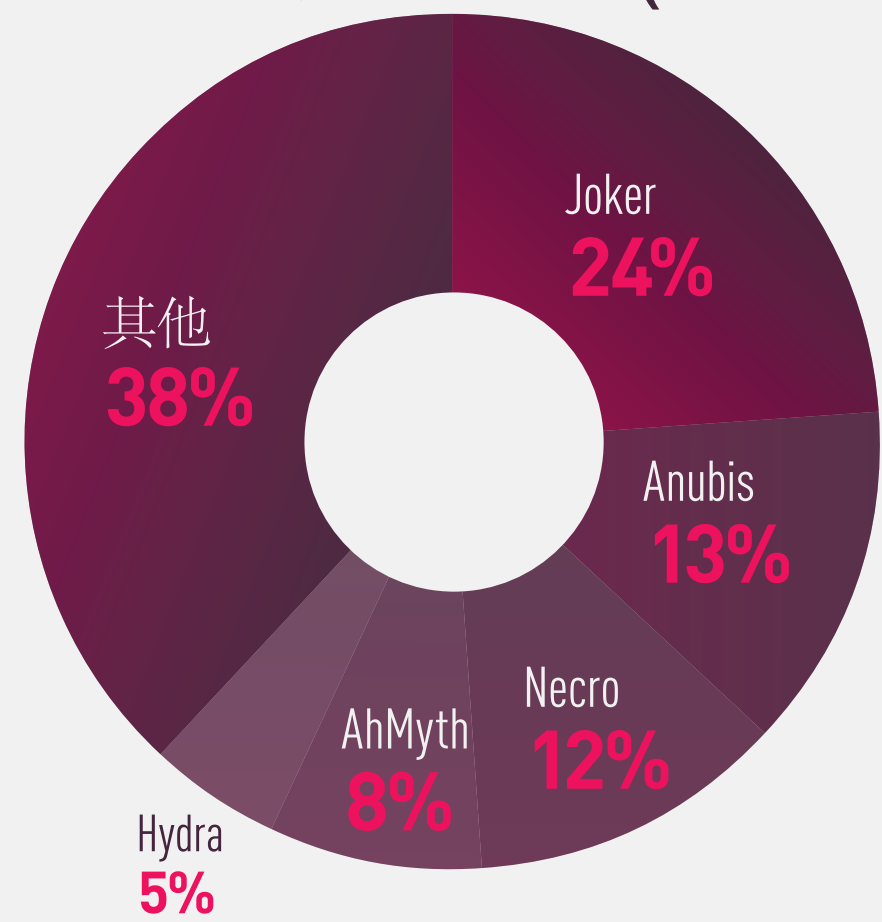


图 26 - 欧洲、中东和非洲地区主要移动终端恶意软件 – 2024 年。

亚太地区 (APAC)

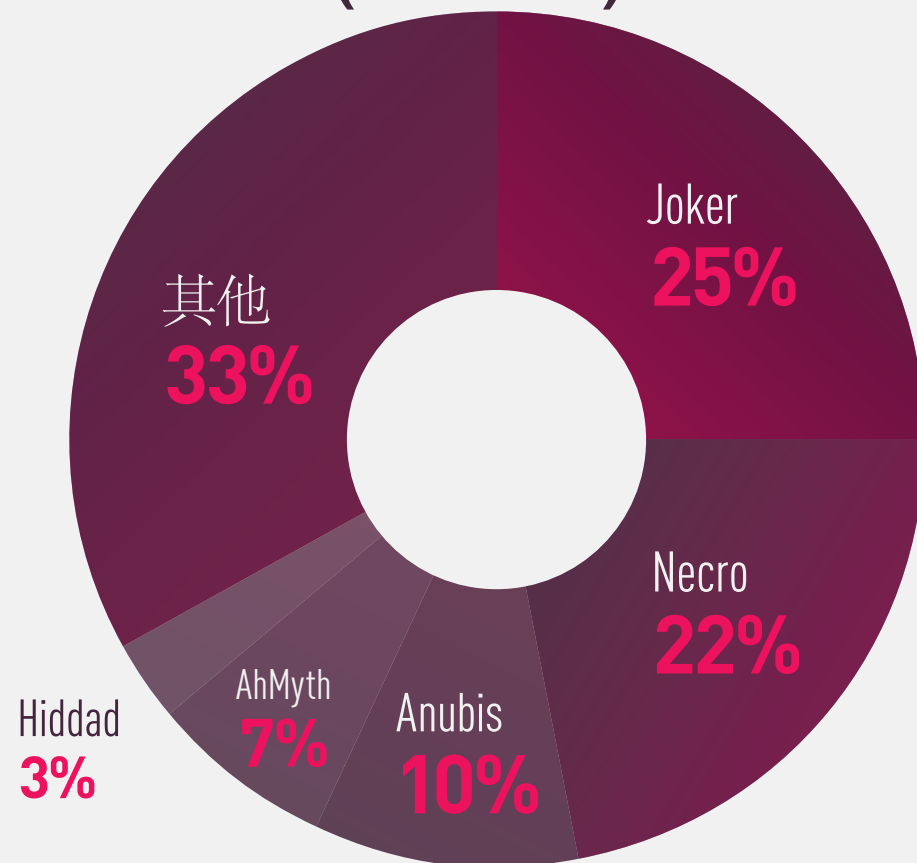


图 27 - 亚太地区主要移动终端恶意软件 – 2024 年。

移动终端恶意软件全球分析

在 2024 年，全球超过 60% 的互联网流量来自移动设备。这些设备上存储的敏感数据备受觊觎，不仅寻求经济利益的网络犯罪分子觊觎，受国家支持从事间谍活动和情报收集的行为者也在觊觎。

正如 Check Point 研究院的这份报告所揭示的，Rafel RAT 是一个开源的安卓远程访问木马，被广泛用于间谍活动。我们的调查发现，它被部署在大约 120 个不同的恶意活动中，其中许多针对的是知名组织，包括军事部门内的实体。Rafel RAT 使威胁行为者能够窃取敏感数据、联系人列表和双因素认证 (2FA) 消息，获取帐户访问权限，并绕过多因素认证机制。值得注意的是，间谍组织 APT-C-35（也称为 DoNot 团队）被发现在其行动中利用了 Rafel RAT，这突显了该恶意软件在不同类型的威胁行为者和目标中的适应性和有效性。

2024 年最流行的移动终端恶意软件 (23%) 是“Joker”，这是一种自 2017 年以来针对安卓设备的臭名昭著的恶意软件。Joker 的主要目的是通过模拟用户点击、拦截短信和通知来秘密为用户订阅高级服务。一个值得注意的案例涉及嵌入在谷歌应用商店的“美颜相机”应用中的 Joker 变体，该应用获得了超过 10 万次的下载。虽然该应用看起来合法，但它会秘密从远程命令和控制 (C2) 服务器下载额外资源，从而进行进一步的恶意活动。

在所有地区排名前三的移动终端恶意软件中，“Necro” (19%) 的上升趋势并不令人意外。Necro 首次发现于 2019 年，是一种投递型恶意软件，旨在下载并执行额外的有效负载。最近，Necro 通过谷歌应用商店中的两个恶意应用程序进行分发，总下载量达 1100 万次。除了谷歌应用商店，在非官方资源库中也发现了 Necro，嵌入到诸如 WhatsApp、Minecraft、Stumble Guys 等热门应用和游戏中。

另外两个突出的移动威胁，Anubis 和 AhMyth，由于其源代码公开可用，仍被广泛使用。Anubis 最初是作为银行木马开发的，后来发展为包括远程访问木马 (RAT) 功能、键盘记录、音频录制甚至类似勒索软件的功能。其多功能性使其成为威胁行为者针对金融机构的首选工具。AhMyth 最初是作为一个教育项目创建的，并在 GitHub 上公开，现已被纳入恶意活动中。

01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议

勒索软件

本部分展示了从 90 多个双重勒索勒索软件组织运营的 140 多个勒索软件数据泄露站点 (DLS) 中获取的数据和见解。网络犯罪分子已在数据泄露站点上发布了超过 5200 家公司的详细信息，他们利用这些平台对拒绝满足赎金要求的组织施加更大压力。支付赎金的公司通常不会出现在 DLS 上，因此未被纳入此数据集，这在一定程度上导致了与真实数据的偏差。然而，这些犯罪 DLS 上分享的信息为勒索软件的情况提供了有价值的观点。此处分析的数据涵盖了 2024 年 1 月至 12 月的时间段。

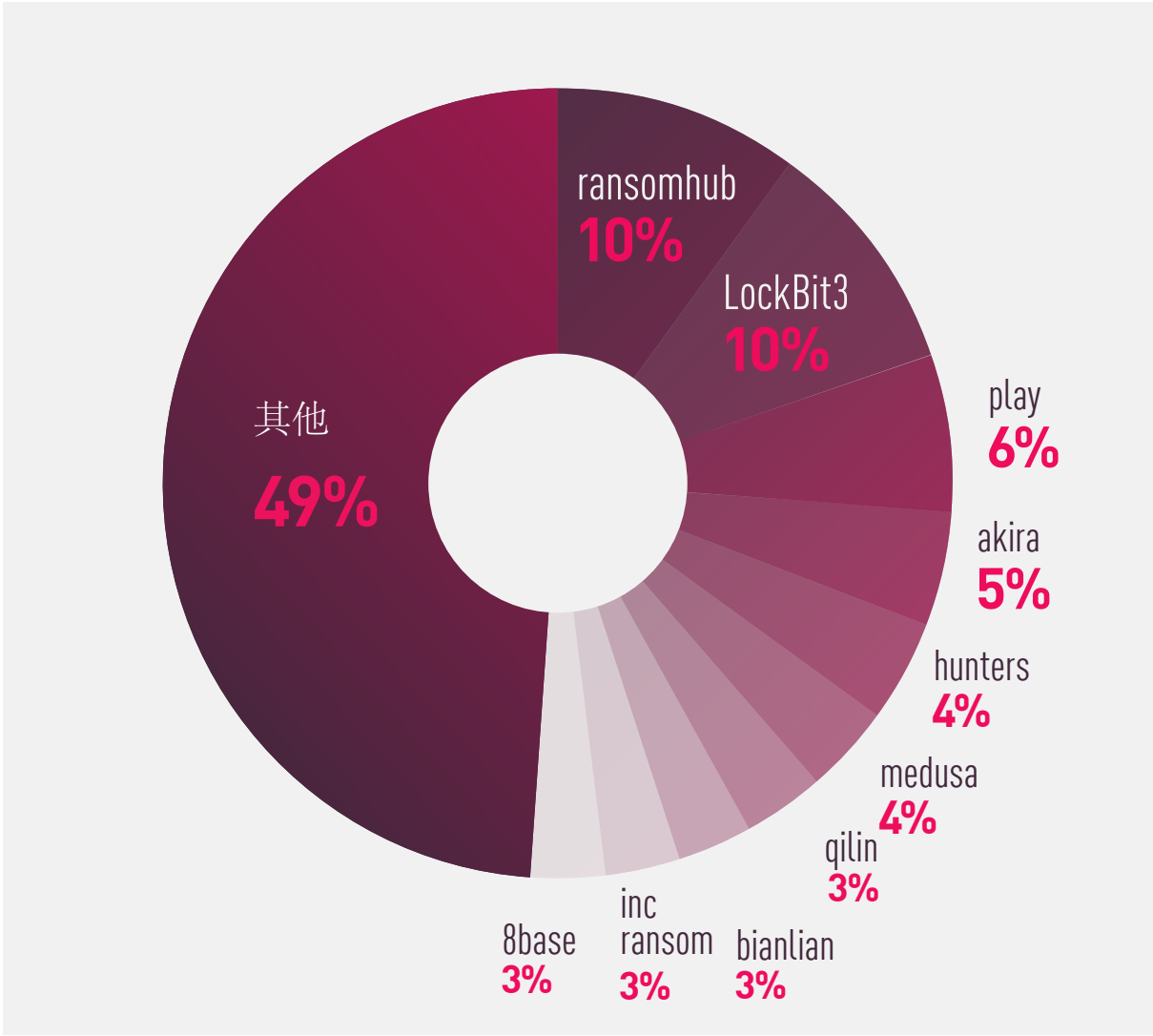


图 28 - 2024 年按公布受害者总数的百分比划分的勒索软件双重勒索集团。*

2023 年两个最主要的勒索软件攻击者在 2024 年已不再活跃。LockBit 在 2023 年受害者占比中占据 21%，ALPHV 占据 9%，它们要么停止活动，要么大幅减少了受影响的受害者的数量。

LockBit 的衰落归因于 Cronos 执法行动，而 ALPHV 的不再活跃是执法行动和与附属机构的内讧共同作用的结果。尽管 LockBit 在 2024 年似乎仍是第二活跃的勒索软件攻击者，但其大多数攻击事件发生在上半年。到 2024 年的最后几个月，LockBit 每月报告的受害者不到 5 个。然而，在 2024 年的最后一周，该组织宣布了一个新版本，LockBit 4.0。只有时间才能证明这是否标志着该犯罪组织的复苏。（更多细节可在第 03 章中找到）

这两个主要犯罪集团的衰落重塑了勒索软件的格局。勒索软件生态系统内的碎片化程度越来越高，现在每年的受害者总数中，由众多较小规模的攻击集团所造成的受害者比例越来越大。2023 年，最活跃的前 10 个勒索软件集团所造成的受害者占有所有公布受害者的比例超过 66%，而到 2024 年，它们的总比例下降到仅 51%。RansomHub 作为领先的双重勒索集团的壮大可归因于他们成功吸引了许多以前没有能力或选择不独立运作的 LockBit 和 ALPHV 附属机构。

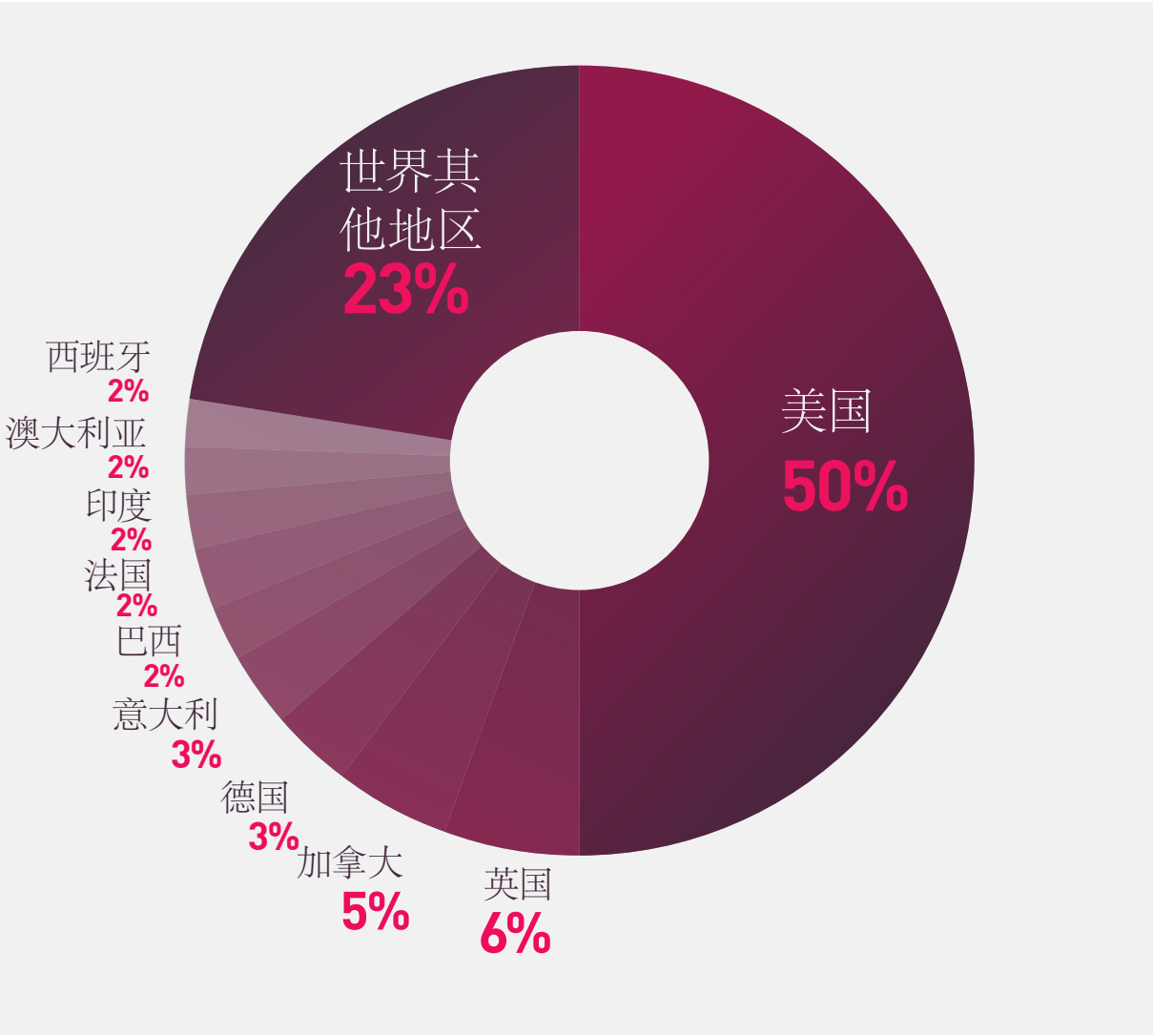


图 29 - 数据泄露站点报告的按国家/地区划分的受害者数量 - 2024 年。

就地理分布而言，今年受影响的公司有 50% 在美国，其次是英国占 6%，加拿大占 5%，德国和意大利各占 3%。

然而，当根据人口规模进行调整时，情况就有所不同了。虽然从统计数据上看，美国仍然是受针对最多的国家，但各国之间的差异变得不那么显著。许多工业化国家每 100 万居民中有 2 到 6 个企业受害者，这突出表明了勒索软件攻击在全球范围内更广泛的影响。

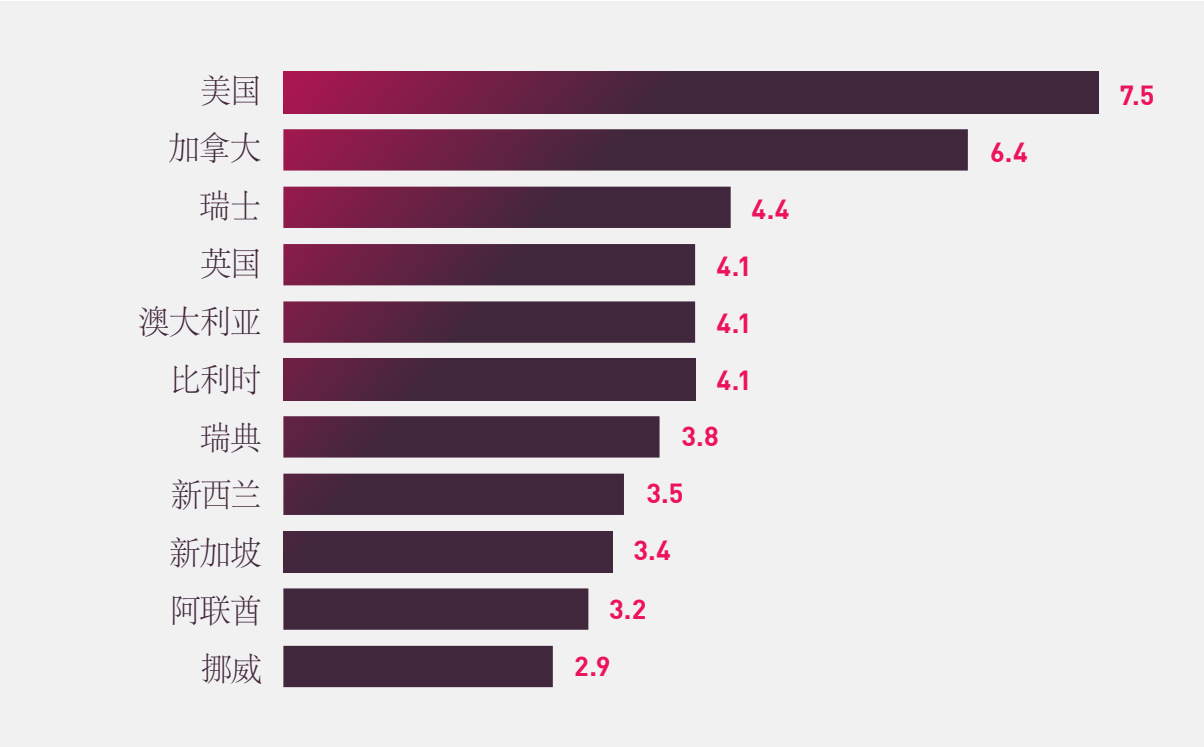


图 30 - 每个国家/地区每 100 万人口的勒索软件企业受害者数量。

在 RaaS（勒索软件即服务）模式中，附属机构独立选择受害者，导致受害者的地理分布反映了更广泛的生态系统趋势，而非 RaaS 运营商的偏好。运营商可以施加限制，例如禁止攻击前苏联加盟共和国、非营利组织或医疗保健相关组织。然而，一些团体表现出更明显的地理倾向。例如，一个被称为“RA Group”的勒索软件组织将目标重点对准德国，其公布的受害者中有超过 20% 位于德国，而 KillSec 则主要针对印度，其 30% 的受害者位于印度。

对各行业每个组织每周攻击的全球平均值的分析（图 3）表明，教育、政府和医疗保健部门是最常受攻击的目标。然而，根据 DLS 数据，具体看勒索软件勒索方面，制造业成为受影

* 数据来自 DLS，涵盖了 2024 年 1 月 1 日至 2024 年 12 月 23 日的时间段。

- 01 引言
- 02 2024 年网络安全事件
- 03 网络安全趋势
 - 网络战争 - 2024 版
 - 勒索软件生态系统
 - 信息窃取软件的崛起
 - 云的复杂性
 - 边缘设备和 ORB
- 04 全球分析
- 05 备受瞩目的漏洞
- 06 事件响应视角
- 07 2025 年行业预测
- 08 CISO 建议

响最大的行业，而政府和教育部门在受害者层级中的排名较低。这种差异可能反映了特定部门在愿意满足勒索要求方面的差异，因为政府和教育机构通常不太愿意支付，这使它们对勒索软件攻击者的吸引力较小。

2024 年，勒索软件攻击者愈发将目标对准医疗保健和医疗服务提供商，使该部门成为第二大受攻击的行业。

有关今年勒索软件发展的更多详细信息可在专门的部分中找到。

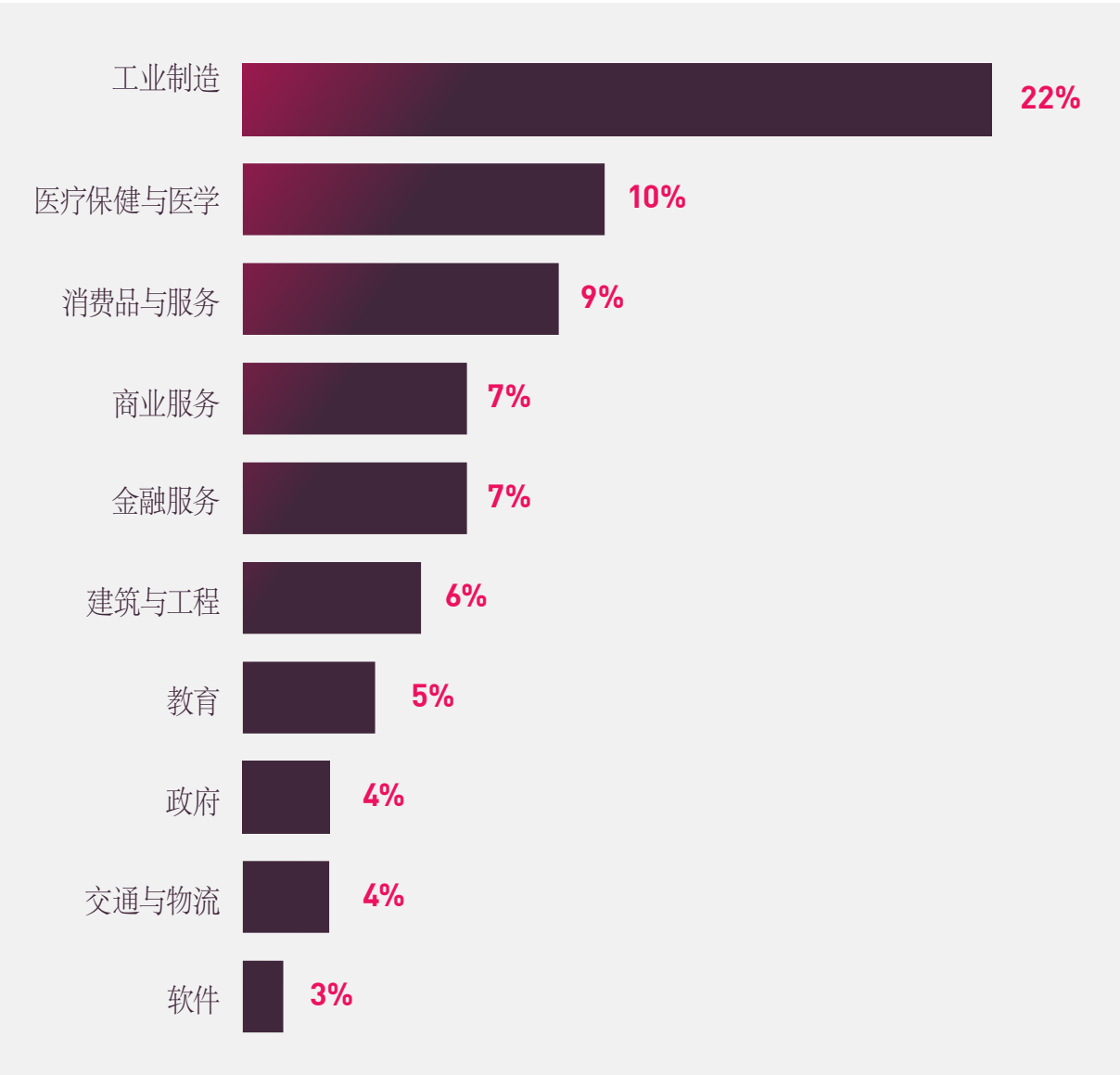


图 31 - 据 *shame* 网站报道的勒索软件受害者的行业分布 – 2024 年。





备受瞩目的 全球漏洞

2025 年网络安全状况

- 01 引言
- 02 2024 年网络安全事件
- 03 网络安全趋势
 - 网络战争 - 2024 版
 - 勒索软件生态系统
 - 信息窃取软件的崛起
 - 云的复杂性
 - 边缘设备和 ORB
- 04 全球分析
- 05 备受瞩目的漏洞
- 06 事件响应视角
- 07 2025 年行业预测
- 08 CISO 建议

以下的主要漏洞列表基于 Check Point 入侵防护系统 (IPS) 传感器网络收集的数据，并详细介绍了 Check Point 研究院 (CP<R>) 在 2024 年观察到的一些最突出和有趣的攻击技术及漏洞利用方式。

PHP CGI 参数注入 (CVE-2024-4577)

CVE-2024-4577 是 PHP 中的一个严重命令注入漏洞，具体影响在 Windows 系统上运行带有 PHP-CGI 的 Apache，并且在其发布后的一天内就遭到利用。值得注意的是，该漏洞主要影响使用中文和日语语言区域设置的 Windows 安装，不过其它安装也会受到攻击。这个问题作为 2024 年 6 月发布的补丁的一部分被披露，源于 Windows 在字符编码转换期间的“最佳匹配”行为，这可能导致 PHP CGI 模块将某些字符误解为 PHP 选项。这使得未经验证的用户能够向 PHP 二进制文件中注入参数，从而导致远程代码执行或敏感数据的暴露。

在该漏洞被披露后，很快被多个恶意行为者利用，包括用于部署勒索软件，并且我们观察到它影响了超过 25% 的公司的网络。该漏洞还被用于部署恶意软件，如 Msupedge 后门程序、Gh0st RAT、RedTail 加密货币挖矿软件和 XMRig。

IVANTI 命令注入 (CVE-2024-21887)

2024 年初，在 Ivanti 的 Connect Secure 和 Policy Secure 网关中发现了一个严重的命令注入漏洞 CVE-2024-21887。这个漏洞允许攻击者利用管理员权限在受感染的系统上执行任意命令。当与 CVE-2023-46805（一个身份验证绕过漏洞）相结合时，攻击者无需身份验证即可实现远程代码执行。这些漏洞遭到黑客积极利用，以植入网页后门、窃取敏感数据，并在受感染的设备上建立持久性的潜在攻击。

VMWARE ESXI 身份验证绕过 (CVE-2024-37085)

2024 年 6 月，博通 VMware 的 ESXi 虚拟机管理程序中一个关键的身份验证绕过漏洞被披露。此漏洞影响 ESXi 与 Active Directory (AD) 在用户管理方面的集成。具体而言，当 ESXi 主机加入到 AD 域时，它会自动向名为“ESX Admins”的域组的成员授予完全管理权限。值得注意的是，这个组在 AD 中默认不存在，并且 ESXi 在域集成时不会验证其是否存在。因此，任何具有创建组权限的域用户都可以建立并将用户分配到“ESX Admins”组，从而获得对 ESXi 主机的完全管理访问权限。此漏洞被包括 Storm-0506、Storm-1175、Octo Tempest 和 Manatee Tempest 在内的多个勒索软件运营商积极利用。在某些实例中，观察到的该漏洞被利用后又进一步的导致了 Akira 和 Black Basta 勒索软件的部署。

对攻击数据的分析显示，2024 年和 2023 年披露的漏洞分别占所有漏洞的 4% 和 15%。最近的漏洞越来越严重，更容易被利用，并且比过去更快地被威胁行为者采用。然而，威胁行为者继续针对较旧的漏洞，超过 57% 的漏洞利用尝试集中在 2020 年或更早发布的 CVE 上。这突显了一个持续存在的问题，那就是即使有补丁可用，系统多年来仍未打补丁。

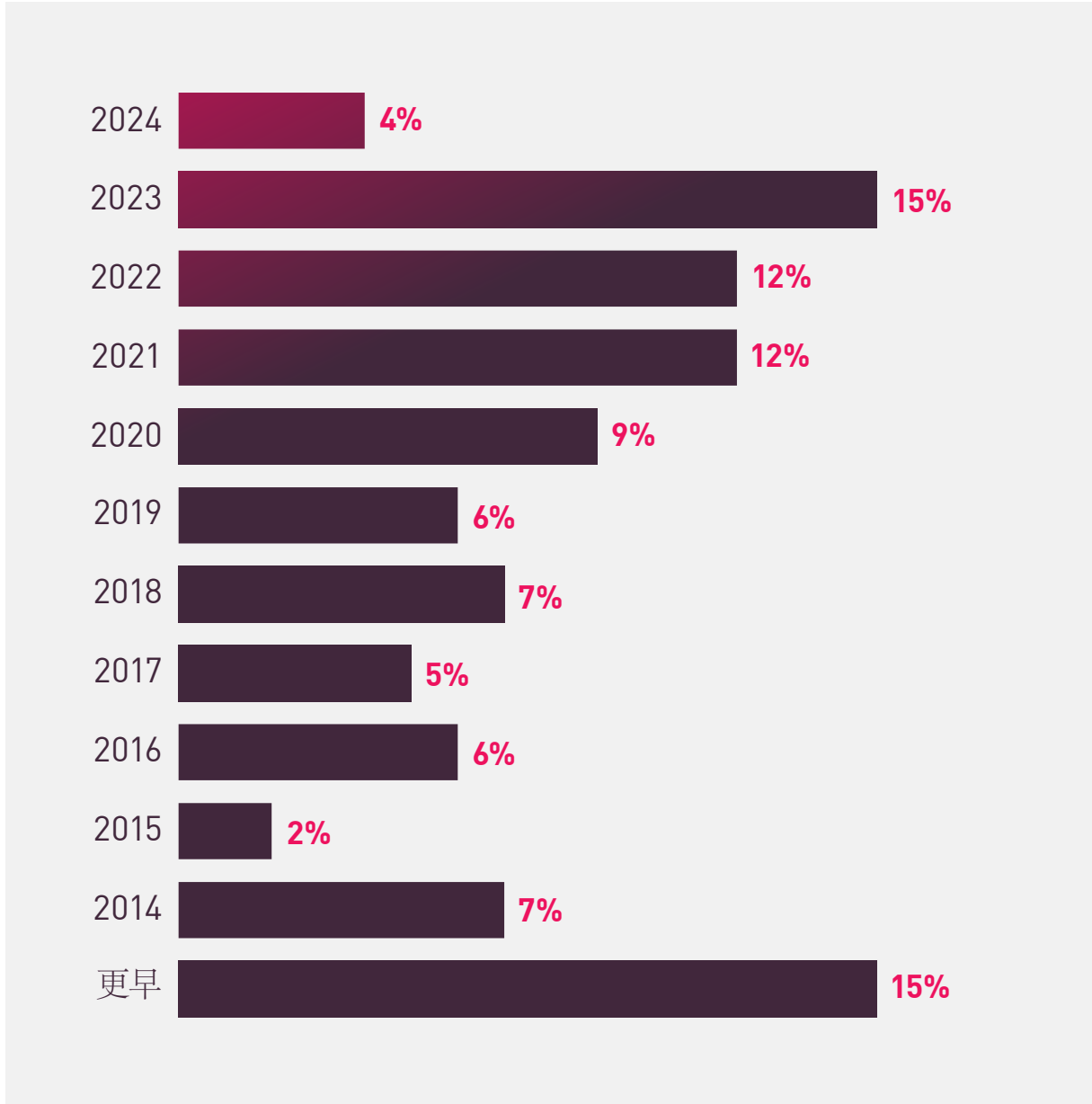
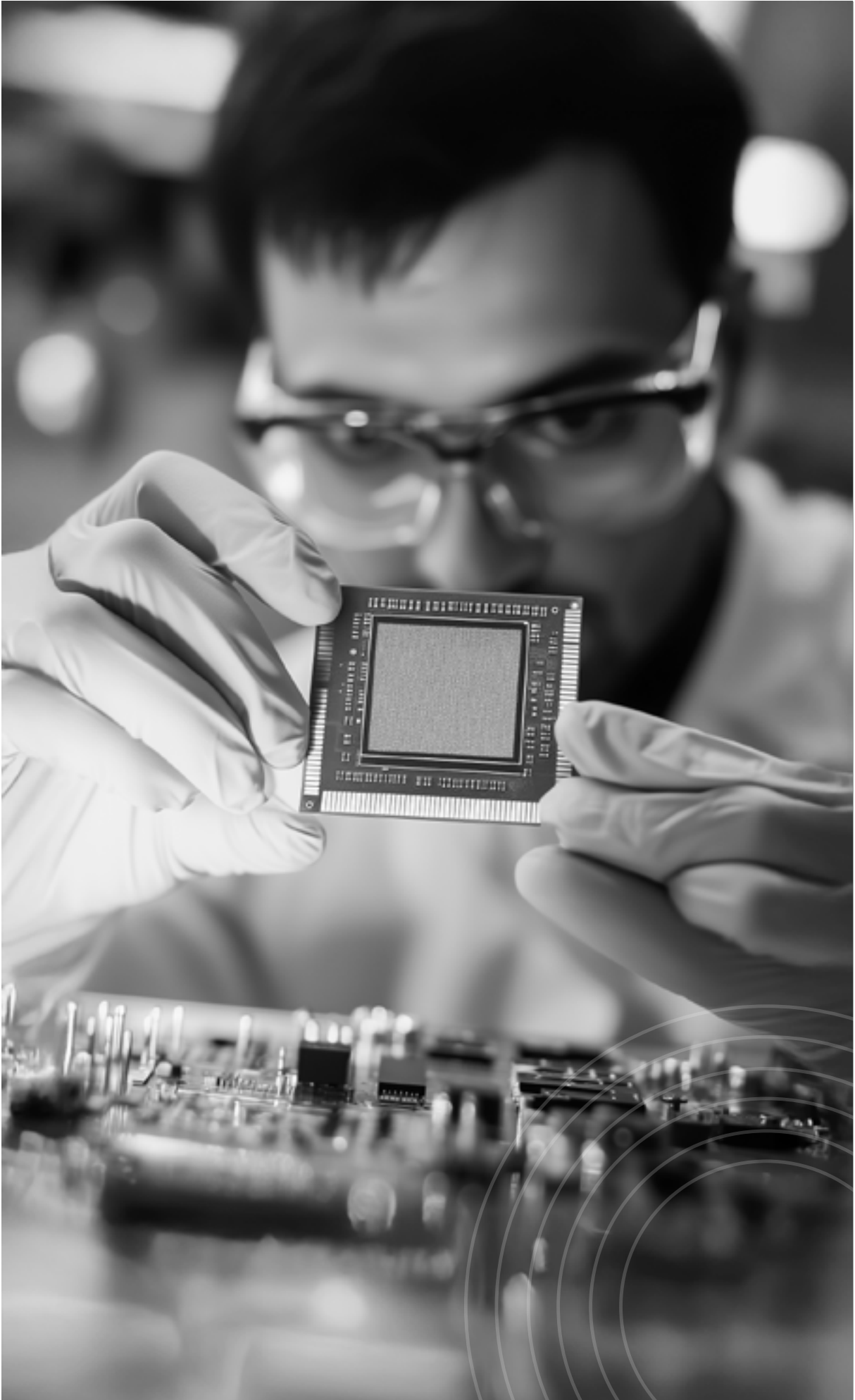


图 1 - 2024 年按漏洞披露年份划分利用漏洞进行攻击的百分比。





事件响应 视角

2025 年网络安全状况



01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议

本部分基于从广泛的 Check Point 事件响应团队 (CPIRT) 的事件调查和缓解案例中收集的经验和数据。与其它部分不同，这里呈现的数据来自触发事件报告的实际案例研究，不仅限于 Check Point 产品用户。大多数攻击成功入侵了目标，为我们提供了一个关于威胁形势和组织在主动攻击期间面临的实际挑战的不同视角。

事件触发因素

客户由于一个或多个触发因素而联系 Check Point 的事件响应团队，这些触发因素来自各种来源，例如自动安全警报、用户报告、服务中断，或从第三方、供应商或政府机构收集的情报。收集和分析这些触发因素有助于我们了解威胁是如何被发现的，哪些威胁迹象更有可能促使立即采取行动，以及如何提高事件响应的速度和效率。

安全团队的主要目标是在攻击达到涉及服务中断或数据窃取的行为发生之前尽快做出响应。**2024 年标志着安全警报首次成为事件的主要触发因素，超过服务中断成为启动事件响应的主要指标。**

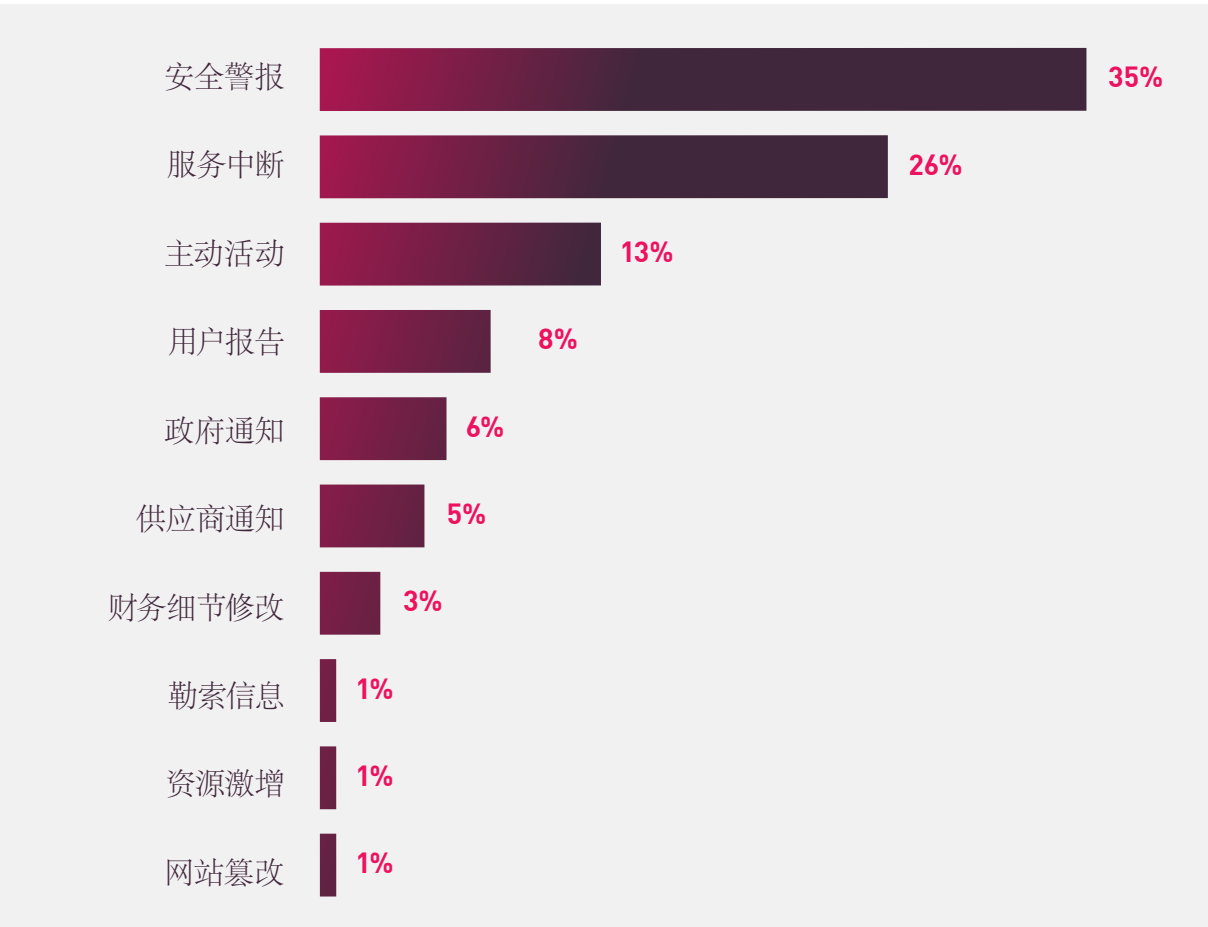


图 1 - 联系事件响应的最常见触发因素。

在今年联系 CPIRT 的案例中，**35%** 是由安全产品的警报触发的，而去年我们的案例中这一比例仅为 **20%**。这种转变表明安全团队的专业知识有了显著提高，检测和预防技术也有了进步。各组织能够愈发娴熟地识别来自安全系统的警报，以及在攻击行为升级前及时识别和阻止违规行为。

例如，CPIRT 目睹了多次勒索软件攻击尝试，这些攻击是在大规模安装诸如 Any Desk 和 Screen Connect 等远程访问工具之后、但在加密阶段开始之前被检测到。CPIRT 今年已看到多个案例，其中安全团队对安装警报迅速做出响应，并能够在部署勒索软件加密器之前缓解攻击。

另一个值得注意的增长是来自团队主动调查以及网络应急响应团队 (CERT) 或政府通知产生的警报数量。这反映出对通信异

常的认识不断提高，对情报和暗网来源的调查也比较积极，同时表明整个行业的网络安全措施得到了加强并且日益成熟。

通过专注于利用安全警报进行早期检测和采取积极措施，各组织能够更有效地应对威胁，并减少网络事件的影响。

安全警报

各组织越来越能够在威胁升级到最终攻击阶段之前识别它们。分析促使安全团队启动其事件响应流程的不同类型的警报，为团队应如何接受培训和在这些情况下运作提供了宝贵的见解。

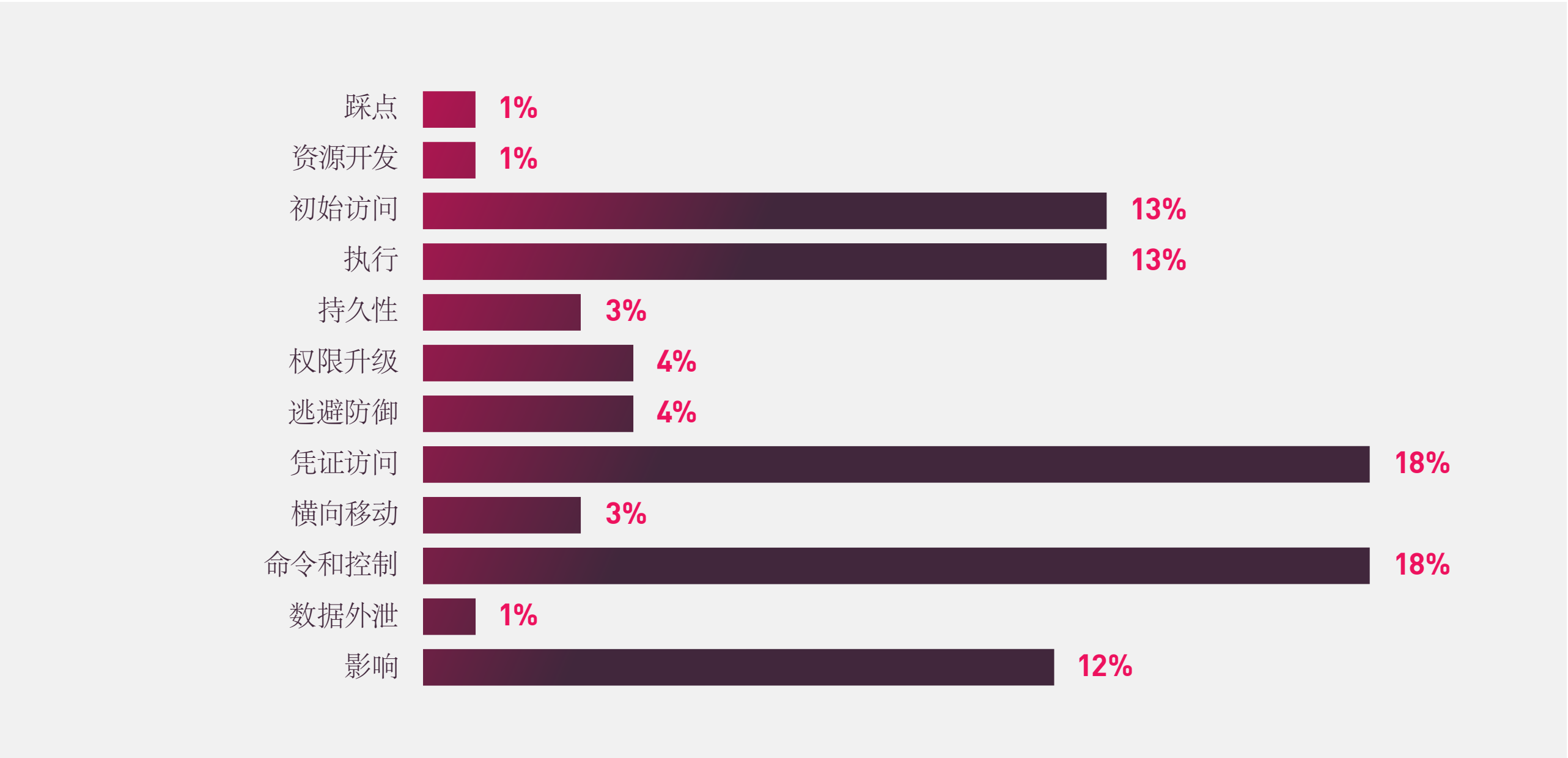


图 2 – 触发事件响应的安全警报中的攻击策略，按照 MITRE ATT&CK 矩阵排序。

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

对由 MITRE ATT&CK 策略触发的安全警报进行细分后发现，命令和控制 (C2) 通信是事件响应最常见的触发因素。与 C2 通信相关的恶意活动通常可以通过相对简单的手段被检测到，例如入侵指标 (IoC)、可疑的网络特征或异常的出站流量模式等。此外，检测这些活动的安全解决方案，如入侵防护系统 (IPS) 和防僵尸网络/防病毒 (AB/AV) 模块，在各行业中都已经得到了广泛应用。这些工具提高了对 C2 行为的可见性，并促成了此阶段的高检测率。

促使 IRT 介入的下一个最高级别的策略警报是凭证访问。虽然这种策略可能不会从安全产品中产生最高数量的警报，但在分析的许多 CPIRT 案例中，凭证访问往往是导致安全团队将警报升级为全面事件响应的策略。凭证访问尝试包括使用诸如 Mimikatz 之类的工具转储 Lsass.exe 进程，并从 DC 中窃取

NTDS.dit 文件，这些警报很少被忽视或被视为合法用户行为。因此，它们通常会触发安全团队立即采取果断行动。

服务中断

与往年一样，服务中断仍然是事件响应的一个突出触发因素。服务中断的攻击方式包括勒索软件（由加密导致服务中断，使关键资源无法访问）；阻止流量（阻止合法通信）；以及 DDoS 攻击（使系统容量不堪重负，导致合法服务不可用）。

来自政府机构和安全供应商的警报

2024 年，源于政府机构和安全供应商所发布警报的事件触发因素有所增加。

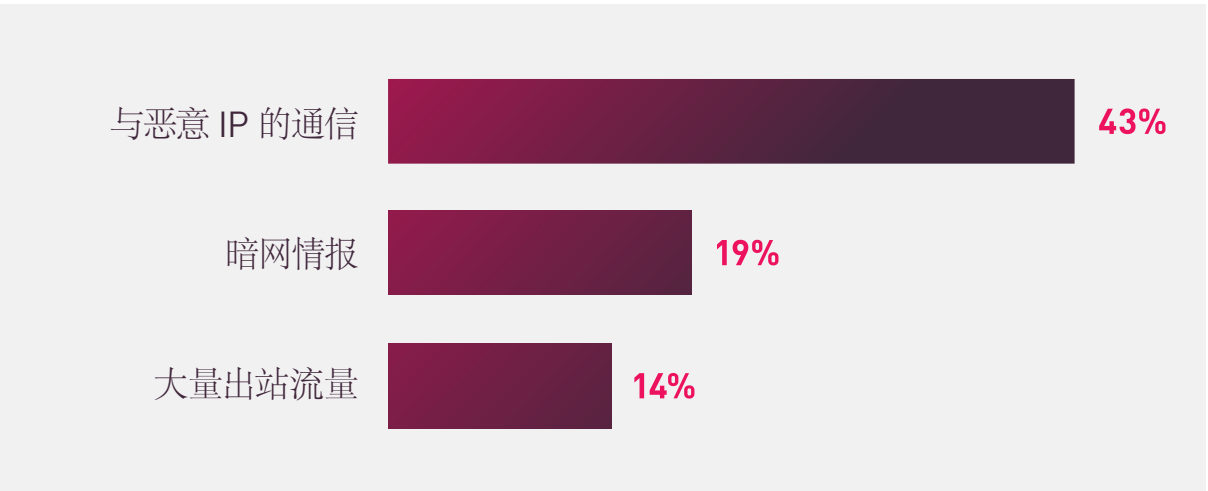


图 3 - 政府和安全供应商警报的三大原因。

许多此类警报是基于与恶意 IP 地址相关联的网络流量，通常被确定为与特定威胁行为者相关的入侵指标 (IoC)。类似的流量监测还可能导致关于向可疑目的地异常大量的出站数据传输的警报，这通常表明威胁行为者会进行窃取活动。

政府机构和安全供应商对暗网的监测是另一个关键的信息来源，可能导致潜在的安全警报。这包括有关在暗网论坛和市场上共享的泄露凭证或敏感公司数据的信息。

此类第三方警报作为关键的早期预警，使组织能够在威胁升级之前主动应对可信的外部情报。由于这些警报来自受信任的实体，并且通常在发布之前经过专业分析，因此它们非常可靠。这促使组织迅速采取行动并启动事件调查。组织不应仅仅依赖外部实体，还应定期对暗网进行主动监测，以促进早期漏洞检测。

案例研究： 对勒索软件威胁的快速响应

今年早些时候，Check Point 托管检测和响应 (MDR) 团队向北美一位客户发出了有关潜在勒索软件威胁的警报。几分钟内，该团队就检测到该组织内的多个设备上安装了 AnyDesk。分析师迅速将此认定为安全事件，并将问题上报给事件响应团队，以启动缓解和调查协议。

在多个设备上快速安装远程控制工具是勒索软件运营商的一种已知策略、技术和程序 (TTP)。正因如此，检测到这种活动立即引发了经验丰富的分析师的迅速反应。

在这个案例中，发现远程控制工具是通过组策略对象 (GPO) 分发的。在检查域控制器 (DC) 时，在一个公共文件夹中发现了一个加密器二进制文件，准备部署到该域内的所有设备上。

多亏了分析师们的快速响应，在加密器分发之前威胁就得到了缓解，从而防止了一场可能十分严重的勒索软件攻击。

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

案例研究： 对政府 CERT 关于数据泄露的警报做出响应

2024 年 10 月，一个欧洲政府的 CERT 警报触发了 CPIRT 的一个案例，表明该组织的一个 IP 地址正在向与命令和控制 (C2) 活动相关的一个 IP 传输大量数据。所提供的 IP 地址是该组织的外部 NAT IP，促使 SOC 团队和 CPIRT 调查防火墙和 DNS 日志，以确定网络上负责数据传输的特定设备。

调查显示，同时用作文件服务器的域控制器 (DC) 是数据传输的源头。在该服务器上，CPIRT 发现了归档工具和最近安装的 **FileZilla**。

CPIRT 协助客户确定可能被窃取的数据，并进行了彻底的调查，以确定威胁行为者在组织内可能建立的任何其它立足点。



用户报告

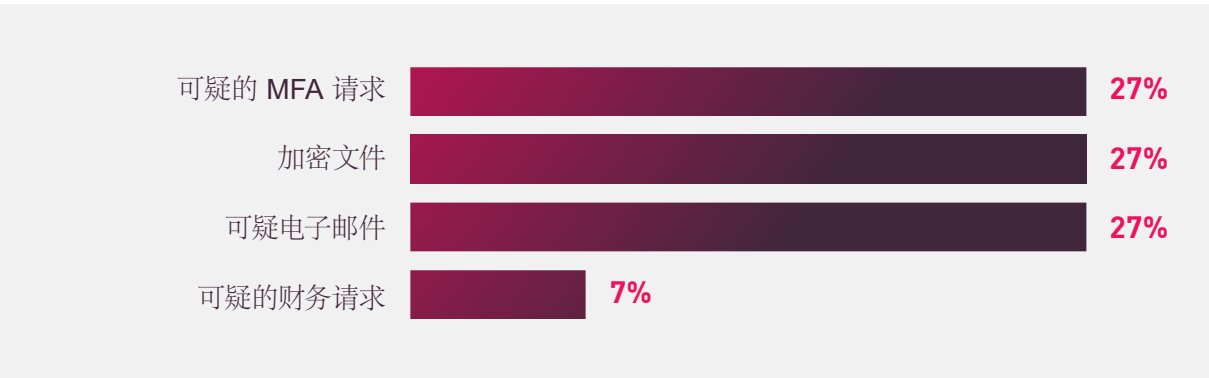


图 4 - 用户报告事件的主要原因。

用户报告通过识别其它安全机制不易检测到的恶意活动，为威胁检测提供了额外的来源。随着用户安全意识的增强，这为组织的防御策略提供了额外的保障。在 2024 年，大多数用户报告的是明显的恶意活动，例如勒索软件攻击导致的文件加密。然而，用户也在越来越多地报告他们未发起的可疑多因素身份验证 (MFA) 尝试。关于可疑电子邮件和网络钓鱼尝试的报告也经常导致检测到恶意活动。

主动威胁搜寻

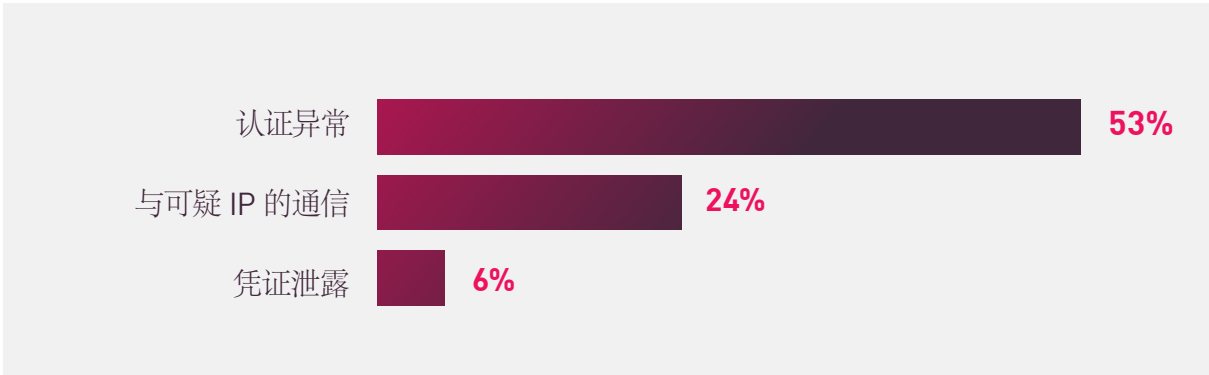


图 5 - 主动发现引发事件的因素。

过去一年，由安全团队主导的主动行动和威胁搜寻所引发的事件（而不是对系统警报的响应）有所增加。这些事件通常源于对系统日志、用户行为和不符合环境特征的网络流量的检查。熟悉自身网络拓扑结构的安全团队比外部安全产品更容易识别此类可疑活动。

需要主动关注的关键领域包括“管理员用户”的异常行为以及与常规操作流程不符的可疑流量模式，例如与组织没有业务往来的国家/地区之间的往来流量。

通过主动搜索隐藏的入侵指标，组织能够检测和缓解逃避自动化检测工具的威胁，强化分层安全方法。

攻击类型

2024 年，勒索软件继续在网络安全威胁形势中占据主导地位。在今年的事件响应案例中，最常见的勒索软件家族是 **LockBit**，其次是 **Akira** 和 **Black Basta**。

其它值得注意的威胁类型包括商业电子邮件泄露 (BEC) 和 DDoS 攻击。CPIRT 案例中有 25% 的攻击在早期阶段被识别并阻止，导致难以确定攻击的类型。

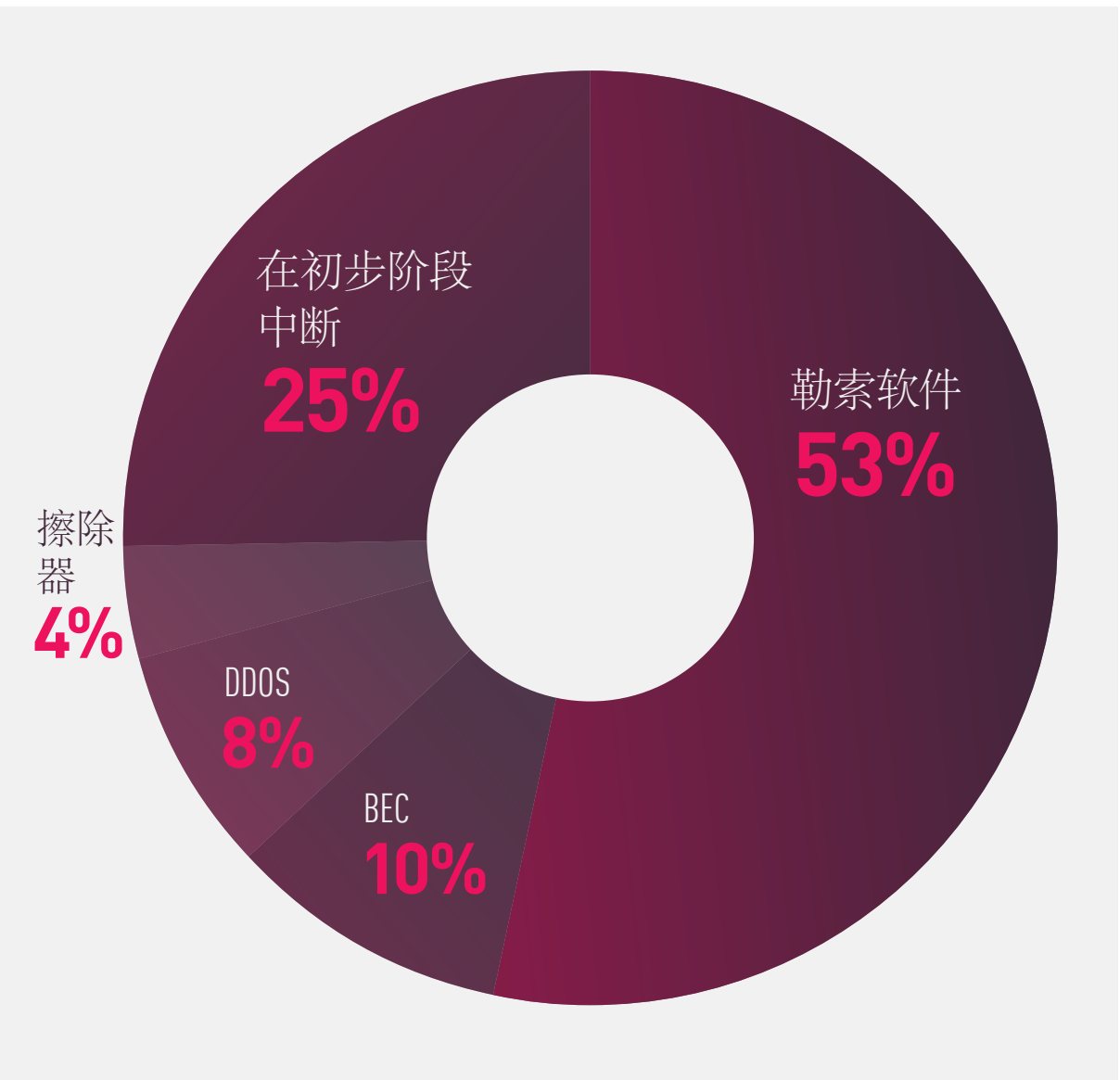


图 6 - CPIRT 2024 年案例中的主要攻击类别。

01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议

ESXI 勒索软件

在 2024 年，所调查的勒索软件攻击中有 11% 专门针对 VMware ESXi 服务器，这些服务器是许多企业基础设施的核心虚拟化环境。通过聚焦 ESXi 服务器，攻击者可以通过危害单个设备致使多个关键服务器无法访问。这种策略使他们能够在不使用加密恶意软件感染整个网络或服务器基础的情况下造成重大破坏。针对 VMware ESXi 服务器的勒索软件组织包括 Akira 勒索软件组织，该组织一直在利用 ESXi 中的两个远程代码执行 (RCE) 漏洞：CVE-2023-20867 和 CVE-2024-37085。

11%

的所调查的勒索软件攻击专门针对
VMWARE ESXI 服务器，这些服务器是
许多企业基础设施的核心虚拟化环境。

结论

CPIRT 2024 年的调查结果显示，各组织在早期威胁检测和主动安全措施方面取得了令人鼓舞的进展。安全警报已超过服务中断，成为事件响应的主要触发因素，并且在主动威胁搜寻和提高用户意识方面有了更多的参与度。这些见解强调了我们需要继续保持警惕、继续完善检测能力以及继续加强与外部情报来源合作，以增强网络安全韧性。

“

2024 年，Check Point 事件响应团队所积累的经验 and 收集的数据表明，如果组织能够优先处理安全警报并利用其中的数据，就能够更好地在威胁升级之前加以阻止，最终保护其关键资产。

”



TIM OTIS

事件响应及托管检测与
响应负责人



2025 年行业预测： 网络安全的未来

2025 年网络安全状况

01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议

云平台成为网络安全的支柱

基于云的平台正日益成为网络安全的基础，事实证明，人工智能驱动的集成化的安全平台比独立的安全工具更有效。通过将各种安全操作整合在一起，这些平台降低了操作的复杂性，使组织能够更高效、更有效地应对云端中的威胁和漏洞。像 **CNAPP**、**ASPM** 和 **DSPM** 这样的解决方案融合在一起，创建了全面的安全态势管理 (SPM) 套件。

随着诸如应用程序和数据 **SPM** 等新工具的出现，它们很可能被整合到更广泛的云原生应用程序保护平台 (**CNAPP**) 中，这有可能导致所谓的扩展安全态势管理 (**XSPM**) 的发展。在这个新类别中整合攻击面管理，展示了这些平台如何提供比简单的单点解决方案集合更多的价值，从根本上改变了组织处理漏洞的方式。

人工智能的滥用和数据泄露的风险上升

随着人工智能技术融入生活和工作的各种场所，对其被滥用的担忧也在增加。今年，员工无意中与 **ChatGPT** 或谷歌的 **Gemini** 等人工智能平台分享敏感信息而导致数据泄露的可能性是一个重大风险。员工可能会输入机密信息，如财务信息，以生成报告或分析，却常常没有意识到未经授权的个人可能会存储和访问这些数据。在组织系统内对人工智能工具建立更严格的控制，对于保持提高生产力与确保数据隐私保护之间的平衡至关重要。

人工智能驱动的金融犯罪

2024 年伊始，头条新闻报道了一些由生成式人工智能驱动的金融犯罪成功案例。网络犯罪分子认识到 **GenAI** 的潜力，并开始投资将其整合到各种技术工具中，特别是用于商业电子邮件泄露 (**BEC**) 和绕过了解你的客户 (**KYC**) 的方法。今年，这些威胁将变得更加普遍，因为网络犯罪分子正在积极致力于在这些恶意服务中实施 **GenAI**。

针对开源项目的供应链攻击不断增加

随着开源项目越来越受欢迎，它们日益成为吸引恶意行为者的目标，这些行为者的目标是秘密利用广泛使用的软件中的漏洞。在见识到历经多年将后门插入 **Linux XZ Utils** 的复杂操作之后，我们可以预计会有新的类似攻击尝试并会发现之前植入的后门。这种不断升级的威胁突显了开源社区迫切需要加强安全措施和提高警惕。

网络犯罪生态系统的去中心化

执法部门最近在打击主要勒索软件操作和僵尸网络方面取得的成功，促使恶意行为者转向更小、更分散的网络、方法和操作。大型勒索软件项目已重组为较小的团体，而由信息窃取软件驱动的生态系统已成为促进初始访问的主要手段。这种去中心化使得防御者必须调整他们的策略，突出了加强协作和情报共享的重要性。

监管要求的增加和更严格的网络保险标准

由于新的网络安全法规，包括欧盟物联网法规、美国证券交易委员会网络安全披露规则、数字运营弹性法案 (**DORA**) 和 **NIS2** 指令，组织将面临越来越大的压力。要遵守这些框架，在诸如政策制定和新安全技术等举措上需要投入大量的时间和资源。

虽然这些法规旨在改进安全措施，但它们同时也提高了安全操作的复杂程度。这要求企业投入更多的关注和努力来达到这些标准。此外，预计网络保险政策将变得更加严格，保险公司将实施更严格的控制和合规要求作为承保的先决条件。这将进一步加剧组织必须应对的监管挑战。

不断扩大的网络安全人才缺口

全球网络安全专业人员的短缺给试图抵御日益复杂和大量的网络威胁的组织带来了重大挑战。组织投资于多种安全产品，因此需要更多熟练的专家来有效管理和整合这些工具，否则会导致安全管理分散且低效。对众多供应商的依赖和内部专业知识的不足使组织容易受到攻击，因为他们的安全措施变得越来越难以管理且效果不佳。公司将不得不简化安全操作，并优先提升员工技能，以保持网络安全防护的弹性。





CISO 建议

2025 年网络安全状况

01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议

1. 在您的安全体系中采用层级化方法

组织应当实施多层安全策略，其中包括定期数据备份、对员工进行网络钓鱼防范意识培训以及强大的电子邮件过滤，以减轻勒索软件和信息窃取软件造成的威胁。利用终端检测和响应 (EDR) 工具有助于及早发现并隔离威胁。此外，保持严格的访问控制并采用最小权限原则可以限制潜在的入侵损害。定期更新软件和系统以修补漏洞，并进行定期的安全评估和事件响应演练，对于确保做好抵御攻击的准备工作至关重要。

2. 优先考虑先进的云安全解决方案

组织应当优先考虑 API 安全、身份管理和零信任架构，以解决云漏洞问题。强大的 API 网关和定期的安全评估可以降低数据交换风险。实施最小权限访问和多因素身份验证对于保护资源至关重要。零信任模型通过在访问前验证用户和设备来增强安全性。云安全态势管理 (CSPM) 工具可识别并修复配置错误，而云工作负载保护平台 (CWPP) 则可保护工作负载。这些策略共同实施有助于有效管理云基础设施风险。

3. 利用人工智能进行预防和检测

利用先进的人工智能技术的力量来加强预防和检测策略。通过开发强大的、由人工智能驱动的系统，组织能够在潜在威胁升级之前有效地识别和减轻威胁。这种积极主动的方法包括实施利用人工智能能力的自动化解决方案，以实时提供及时和准确的问题检测。这样的系统提高了整体安全性并简化了响应工作，使团队能够迅速有效地应对新出现的安全挑战。

4. 全面了解您的攻击面

犯罪分子利用自带设备实践和云原生应用程序中的漏洞，由于诸如硬编码凭证和弱认证等问题，增加了违规的风险。他们经常使用合法的凭证和工具，模糊了常规用户活动和恶意行为之

间的界限。组织必须理解身份、云、终端和数据保护之间的联系，以便在多个系统中识别这些威胁。由于一般企业使用超过 45 种安全工具，数据孤岛可能导致威胁的可见性降低。具有人工智能功能的统一安全平台提高了可见性和控制，改善了违规检测和加强了威胁预防，同时节省了时间和金钱。

5. 制定客户信任计划以确保合规

组织必须建立客户信任计划，以确保在当今迅速变化的监管环境中保持合规。实施合规自动化可以简化对严格法规的遵守，并减少审计和报告期间的人为错误。优先考虑数据主权使企业能够保持对敏感信息的控制。通过将隐私纳入设计之中，公司可以主动保护客户数据、增强安全性，并可以实现防御优先的

防护策略。这种方法培育了一个强大的合规框架，最终能够建立客户信任。

6. 实施漏洞和风险管理计划

新漏洞的迅速出现，特别是零日攻击，给漏洞管理带来了重大挑战。通常可公开访问的边缘设备尤其面临风险。为了有效地管理这些风险，评估其威胁级别并相应地确定优先级以便及时进行修补至关重要。面向外部的资产和关键系统应是首要关注的重点。

此外，将威胁情报与外部攻击面管理结合使用，可以为您提供有关对手如何看待您的安全措施的宝贵可见性和建议。凭借这

“

当我们回顾 2024 年的事件时，关注导致攻击者成功的关键因素以及防御者可以采用的战略缓解措施来挫败此类威胁至关重要。本部分内容总结了关于网络安全趋势的重要见解，并为网络安全专业人员提供了可行的建议。这些指南作为一个实用的框架，通过解决过去导致网络攻击的常见系统性问题和错误，来加强防御并防止出现本报告中描述的一些严重事件。

”

JONATHAN FISCHBEIN

Check Point 软件全球 CISO
欧洲、中东、非洲和拉丁美洲



01 引言

02 2024 年网络安全事件

03 网络安全趋势

- 网络战争 - 2024 版
- 勒索软件生态系统
- 信息窃取软件的崛起
- 云的复杂性
- 边缘设备和 ORB

04 全球分析

05 备受瞩目的漏洞

06 事件响应视角

07 2025 年行业预测

08 CISO 建议

种洞察力，您可以实施即时的预防策略。

7. 选择一个您信任的安全产品制造商

在选择体现数字信任的安全产品制造商时，寻找一家具有有效安全实践的良好记录和低安全漏洞率的公司。优先考虑那些能确保及时发布补丁，让用户能够迅速应对潜在威胁的供应商。此外，评估他们的事件响应策略和过去处理违规事件的经历。

8. 优化安全操作

鉴于缺乏熟练的网络安全人员，人工智能对于提高效率至关重要，团队可以借此更好地管理和确定威胁管理的优先级。人工智能工具可以使重复性任务自动化，通过自动化将花在诸如事件分析和故障排除等任务上的时间最小化。安全专业人员可以专注于战略创新和积极措施，并精简流程。

9. 关注恢复能力和事件响应

组织在面临来自勒索软件和地缘政治网络战日益增长的威胁时，必须优先考虑运营弹性。为了强化您的 IT 战略，请确保您的运营得到有效隔离。这种方法将在遭受攻击时可以增强您的事件响应能力。此外，定期评估和更新您的灾难恢复计划，以尽量减少由网络攻击或 IT 中断造成的干扰。

加强用户教育在防止恶意软件感染方面至关重要。员工应当了解文件和电子邮件的来源，以及他们是否可以信任发件人。最常见的勒索软件感染方法仍然是钓鱼邮件和恶意网页下载。用户意识的提高往往能够防止攻击。对您的用户进行教育，并鼓励他们立即向安全团队报告任何不寻常或可疑的情况。



关于 CHECK POINT SOFTWARE TECHNOLOGIES LTD.

Check Point 软件技术有限公司 (www.checkpoint.com.cn) 是一家由人工智能驱动、在云端交付的网络安全平台提供商，居于行业领先地位，为全球超过 10 万家组织提供保护。Check Point 利用无处不在的人工智能力量，通过其 Infinity 平台提高网络安全效率和准确性，其业界领先的捕获率实现了主动威胁预测和更智能、更快速的响应时间。其全面的平台包括在云端交付的技术，如保护工作空间安全的 Check Point Harmony、保护云端安全的 Check Point CloudGuard、保护网络安全的 Check Point Quantum，以及用于协同安全运营和服务的 Check Point Infinity Core Services。



全球总部

5 Shlomo Kaplan Street, Tel Aviv 6789159, Israel

电子邮箱: info@checkpoint.com

遭受攻击?

联系我们的事件响应团队:

emergency-response@checkpoint.com

为获取我们的最新研究及其它独家内容，
请访问我们的网站 www.research.checkpoint.com.cn

联系我们

中国总部

上海市黄浦区延安东路 550 号海洋大厦 1806-1808 室，邮编：200020

售前电话：021-60293505 售后电话：4008180087

www.checkpoint.com.cn

Check Point 官方微信



© 2025 Check Point Software Technologies Ltd. 保留所有权利。